Cs627(1-5) - These are the notes of first five weeks

Professional practices (Virtual University of Pakistan)



Scan to open on Studocu

Studocu is not sponsored or endorsed by any college or university
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

CS627 - Cyber Security

Lec#1:

Importance of Cyber Security

• Mobile Phones

•Total population of Pakistan (2020) → 219,067,896

• Number of mobile phone users in Pakistan has reached 161.183 million, as of May 2019.

• Smart phones

• Traditional phones: • SMS / Call Scams

Importance of Cyber Security

• Drones

• Here's How Hackers Could Have Spied On Your DJI Drone Account

https://thehackernews.com/2018/11/dji-drone-hack_8.html



• Health / Medical

• Pacemaker: a device for stimulating the heart muscle and regulating its contractions.

• Robotic Surgeons

• 5 Medical Robots Making a Difference in Healthcare

https://online-engineering.case.edu/blog/medical-robots-making_a-difference

Remote Surgery

• China completes world's first 5G remote surgery in test on animal

https://www.youtube.com/watch?v=yFR61jjL1vo

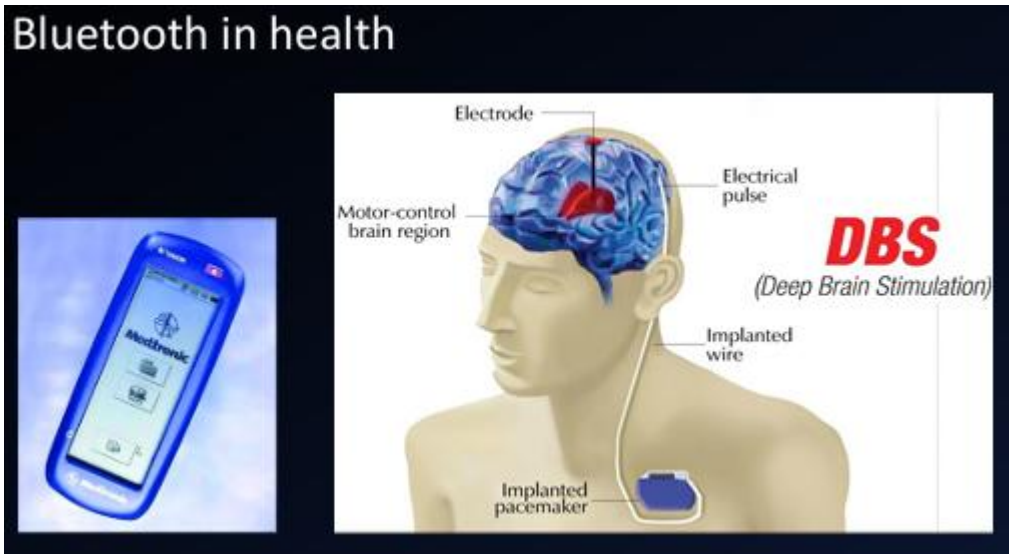
• Robot Helps Perform First Long-Distance Heart Surgery

• A surgeon in India performed the first remote heart operation on a patient 20 miles away.

https://www.popularmechanics.com/technology/robots/a28941 179/robot-performs-first-long-distance-heart-surgery

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)



The field of **'Cyber Security'** is becoming more important due to increased reliance on

• computer systems

• the Internet

• wireless network standards

• such as Bluetooth and Wi-Fi

• due to the growth of "smart" devices

• including smartphones , televisions , and the "Internet of things ".

• Owing to its complexity, both in terms of politics and technology, cybersecurity is also one of the major challenges in the contemporary world.

• Ease of use results in increasing underlying complexity

What is Cyber Security?

• Cyber

Relating to or characteristic of the culture of computers, information technology, and virtual reality.

• Cyberspace is a term for virtual reality coined by William Gibson.

https://en.wikipedia.org/wiki/Cyberspace

• Cyber- is derived from "cybernetic ",

[https://en.wikipedia.org/wiki/Cybernetics] which comes from the Greek word κυβερνητικός meaning 'skilled in steering or governing'. • Pronunciation:

[https://forvo.com/word/%CE%BA%CF%85%CE%B2%CE%B5%CF%81%CE%BD%CE%B7%CF%84%CE%B9 %CE%BA%CF%8C%CF%82/]

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

• **Cybernetics:** the science of communications and automatic control systems in both machines and living things.

• Used to describe policies and politics regarding computer systems and networks.

• Term used in Information Technology industry and the Internet era.

https://en.wikipedia.org/wiki/Internet-related_prefixes#.22Cyber-.22

https://en.wikipedia.org/wiki/Cyber

What is Cyber Security?

• Security • Degree of 'protection' [safe & secure]

. • The state of being free from danger or threat.

• Security is freedom from, or resilience against, potential harm caused by others. [Wikipedia] •

https://en.wikipedia.org/wiki/Security

• Computer security, cybersecurity or information technology security (IT security) is the protection of computer systems from the theft of or damage to their hardware , software , or from electronic data , as well as from the disruption or misdirection of the services they provide.

• https://en.wikipedia.org/wiki/Computer_security

Security Realms

• Information Security

• IT Security

• Cyber Security

• Network Security

• System Security

• Data Security

• Operating System Security

• Physical Security

Information Security

• Information security, sometimes shortened to infosec, is the 'practice of protecting information ' by mitigating information risks

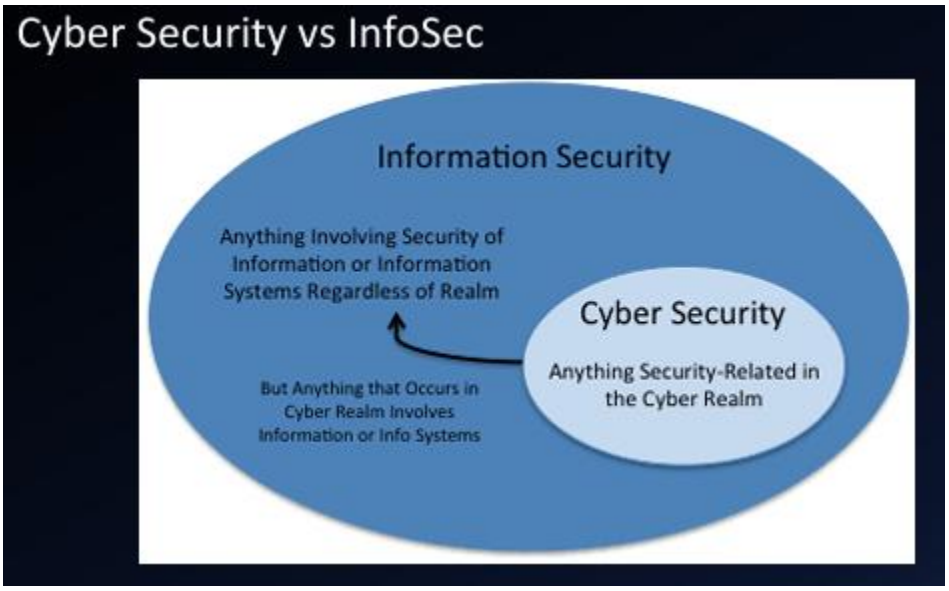
• It is part of information risk management .

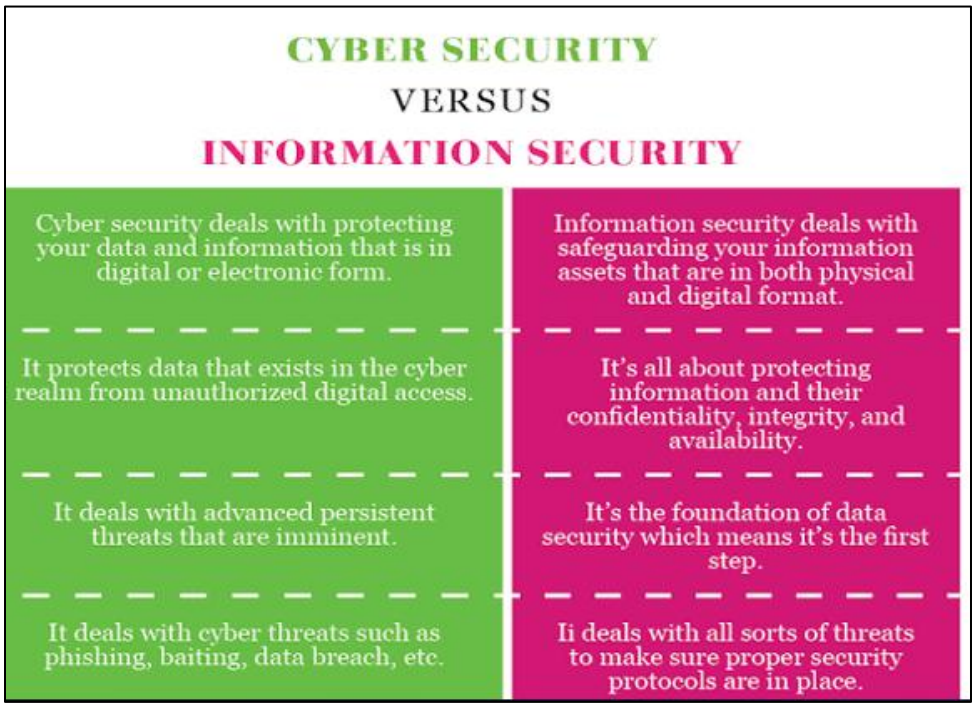
• It typically involves preventing or at least reducing the probability of unauthorized/inappropriate access, use, disclosure, disruption, deletion/destruction, corruption, modification, inspection (monitor), recording or devaluation of data and/or systems.

• Information may take any form, e.g. electronic or physical. Cyber Security vs InfoSec

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)





Cyber Security Jobs & Careers

https://www.cybersecurityeducation.org/careers/

• Start at any point in your life / career.

• Wide range of responsibilities.

• Crux of the job is to protect online data and systems form being compromised.

• Cyber security careers are complex.

• Many roles can be found with banks, retailers and government organizations.

• On the job, you can expect to: • safeguard an organization's files and network

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

• install / configure firewalls

• create security plans • monitor activity

• If a breach occurs, you'll be responsible for identifying the problem and finding a solution quickly.

• Because of the frequency of cyber attacks, careers are varied and qualified professionals are in demand.

• If you're ready to get started in this fast-growing career, start exploring cyber careers now.

Job Titles

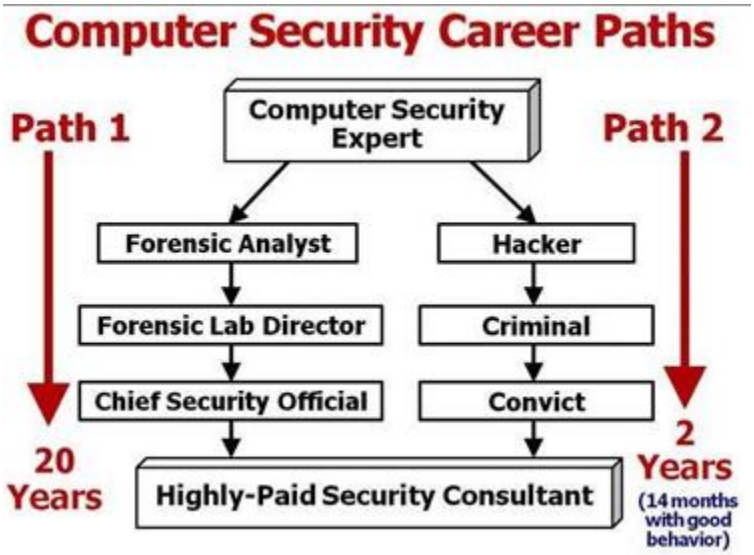
- Cyber Security Vendor Solution Provider Services
- Security Auditor
- PenTester / Ethical Hacker
- Security Analyst
- InfoSec Engineer
- InfoSec Consultant
- Malware Analyst
- Forensic Analyst/Expert/Investigator
- Incident Handler / Manager
- InfoSec / Cyber Security Specialist
- InfoSec Manager
- CISO



This document is available on studocu

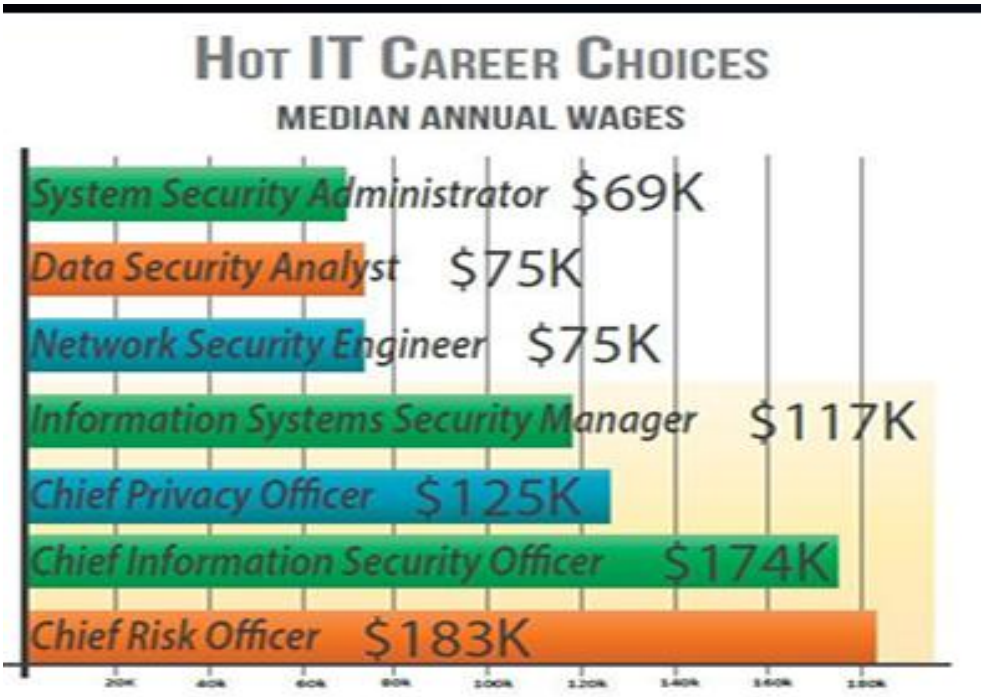
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

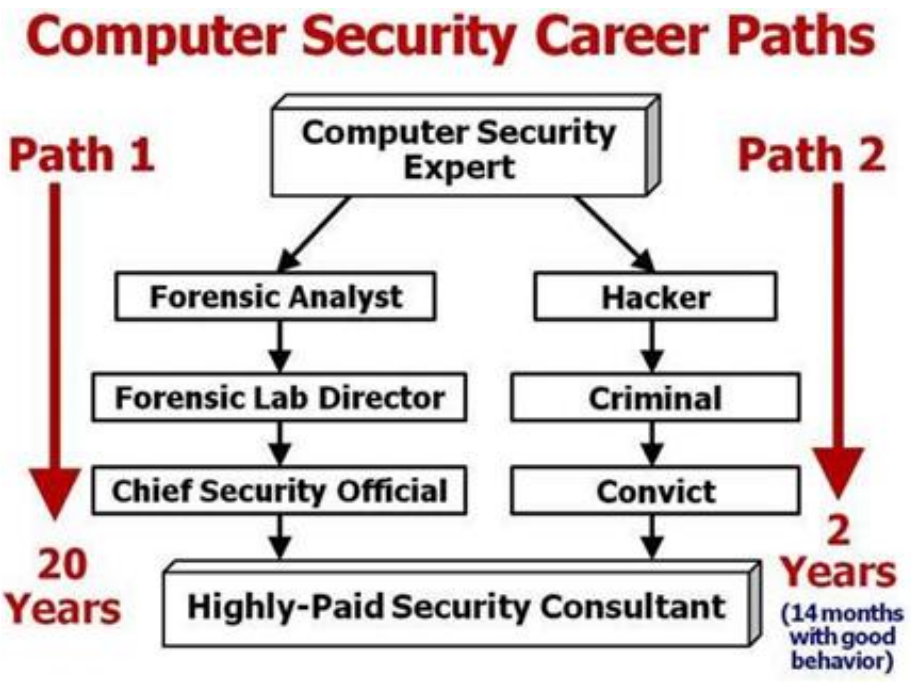






Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

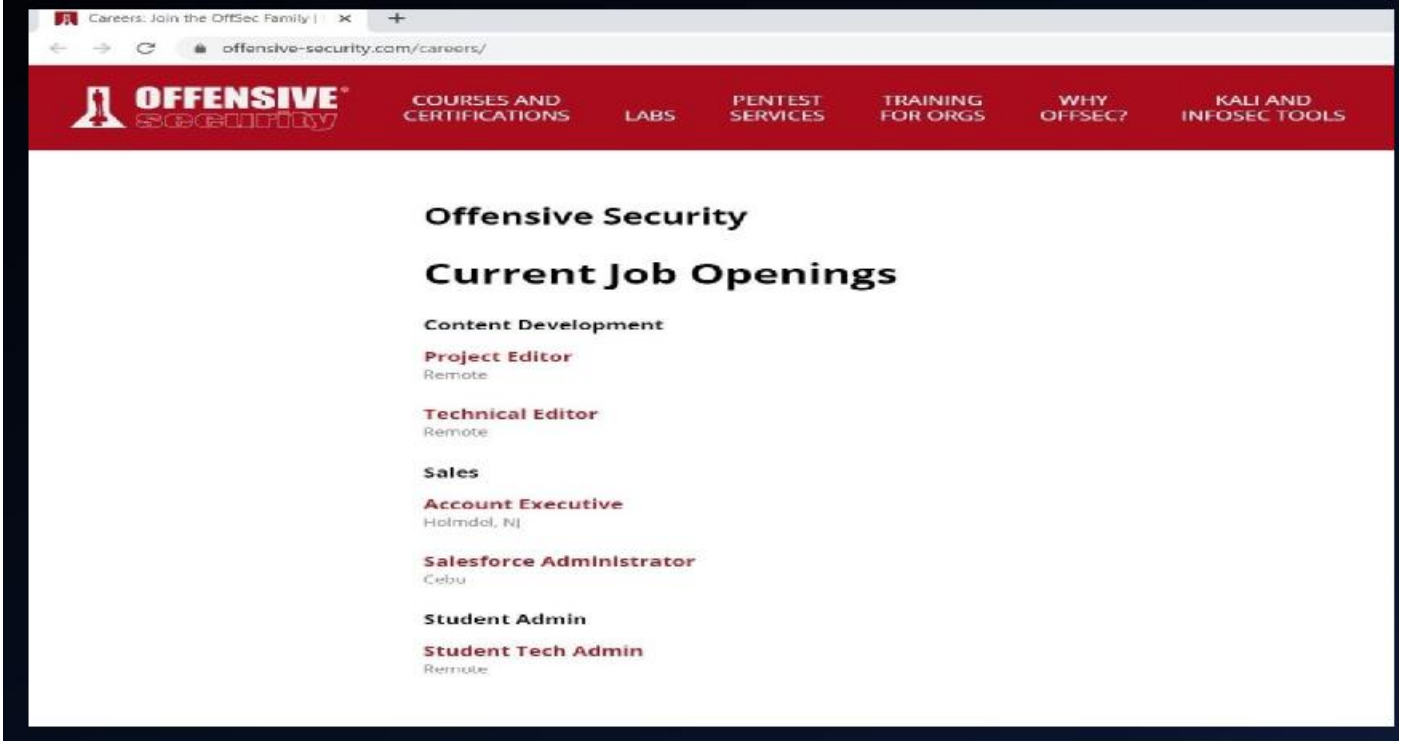




This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

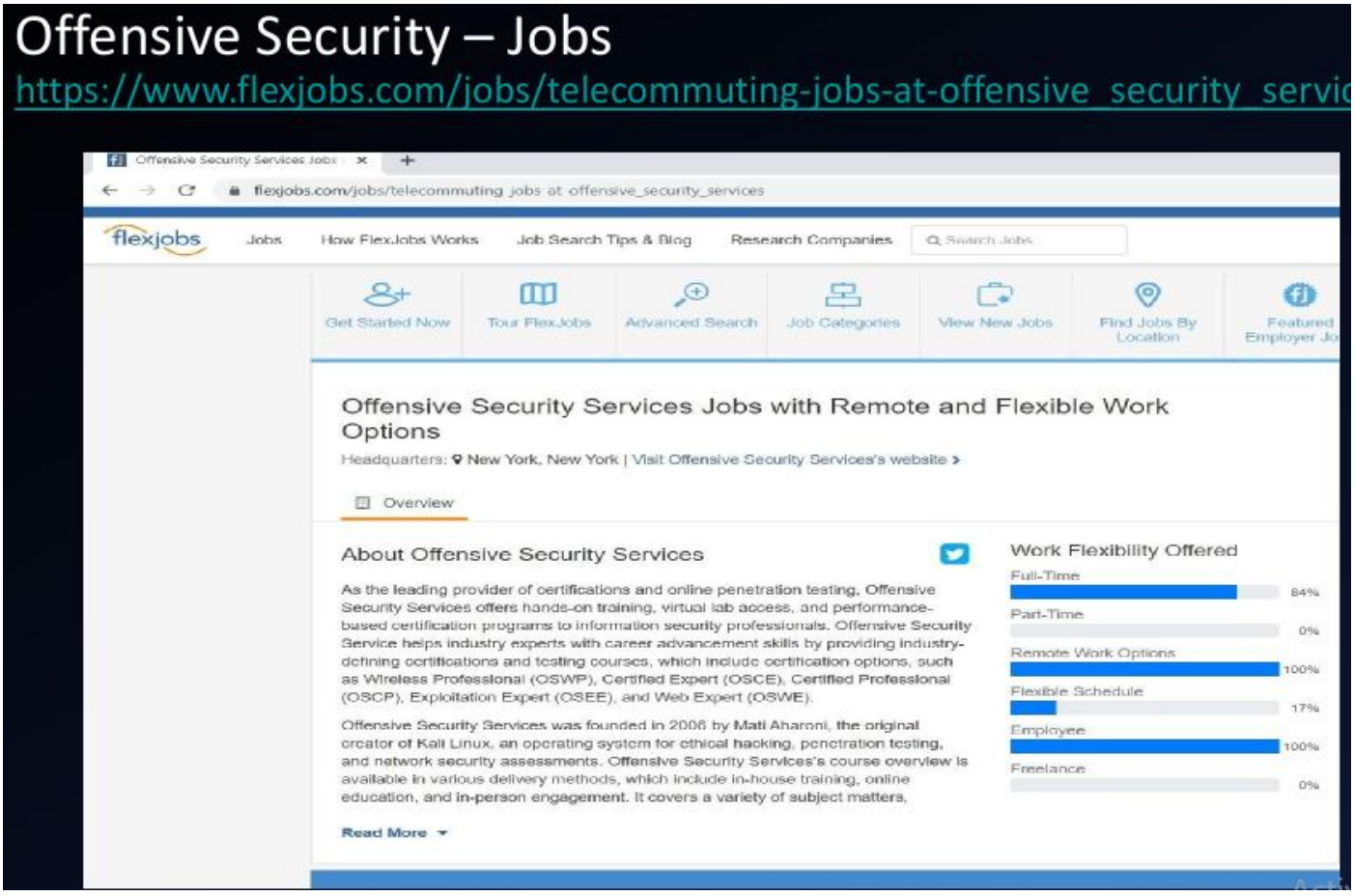
Offensive Security – Jobs

https://www.offensive-security.com/careers/



Offensive Security – Jobs

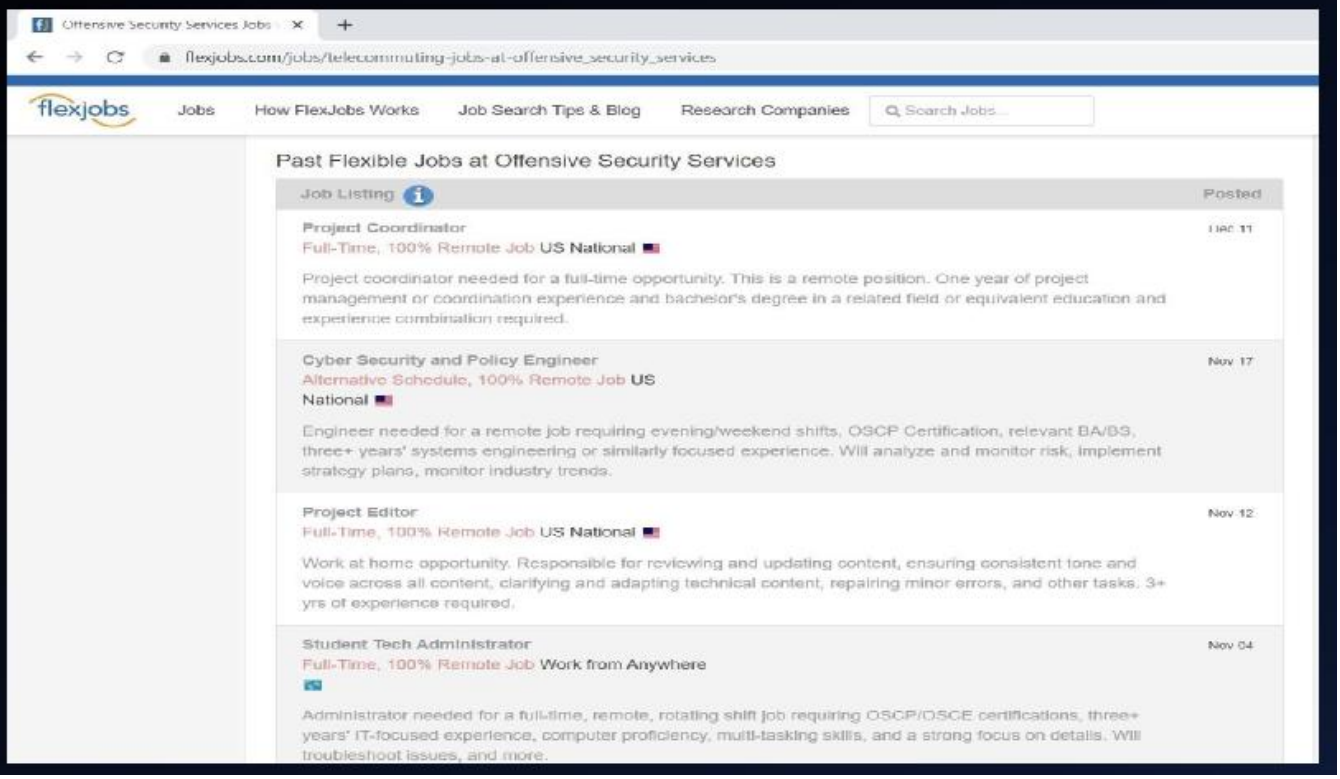
https://www.flexjobs.com/jobs/telecommuting-jobs-at-offensive_security_servic



Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

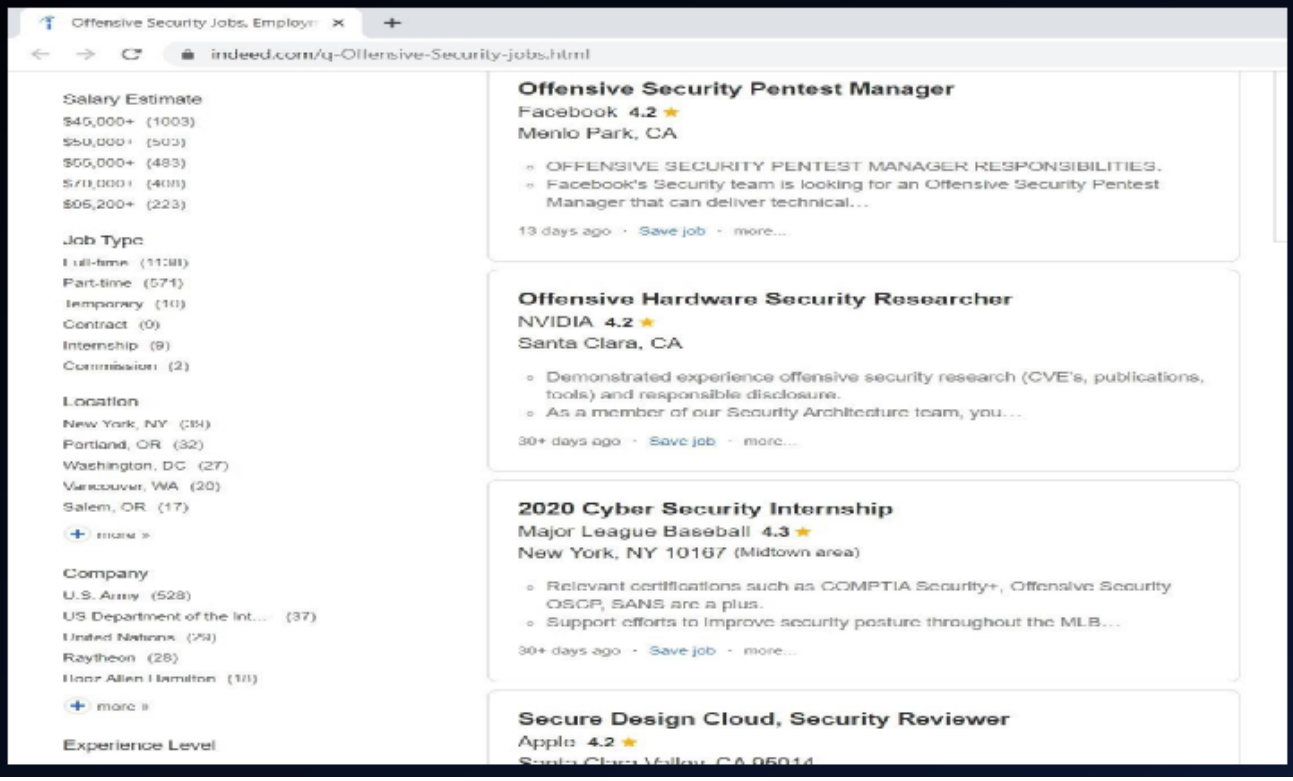
Offensive Security – Jobs

https://www.flexjobs.com/jobs/telecommuting-jobs-at-offensive_security_service



Offensive Security – Jobs

https://www.indeed.com/q-Offensive-Security-jobs.html

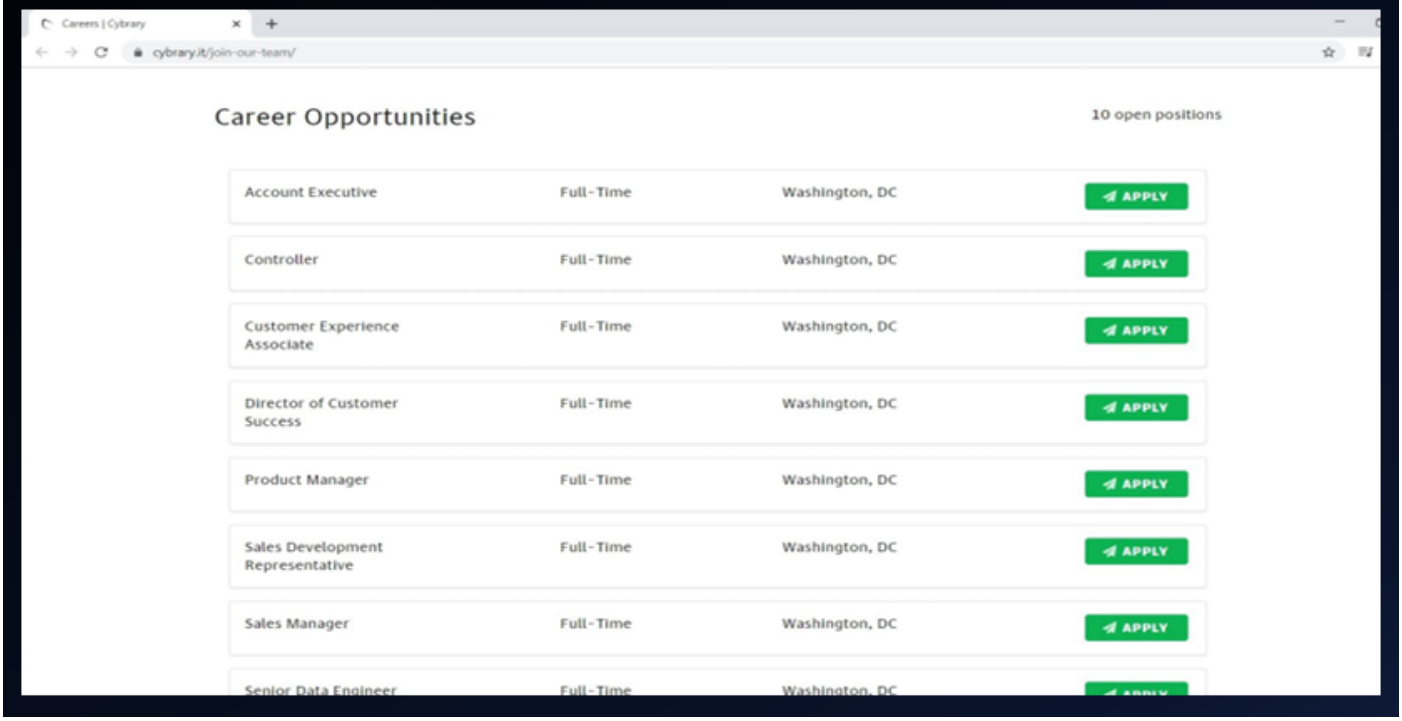


This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

CYBRARY Career Opportunities

https://www.cybrary.it/join-our-team/



CYBRARY Career Opportunities

https://www.cybrary.it/contribute/









Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

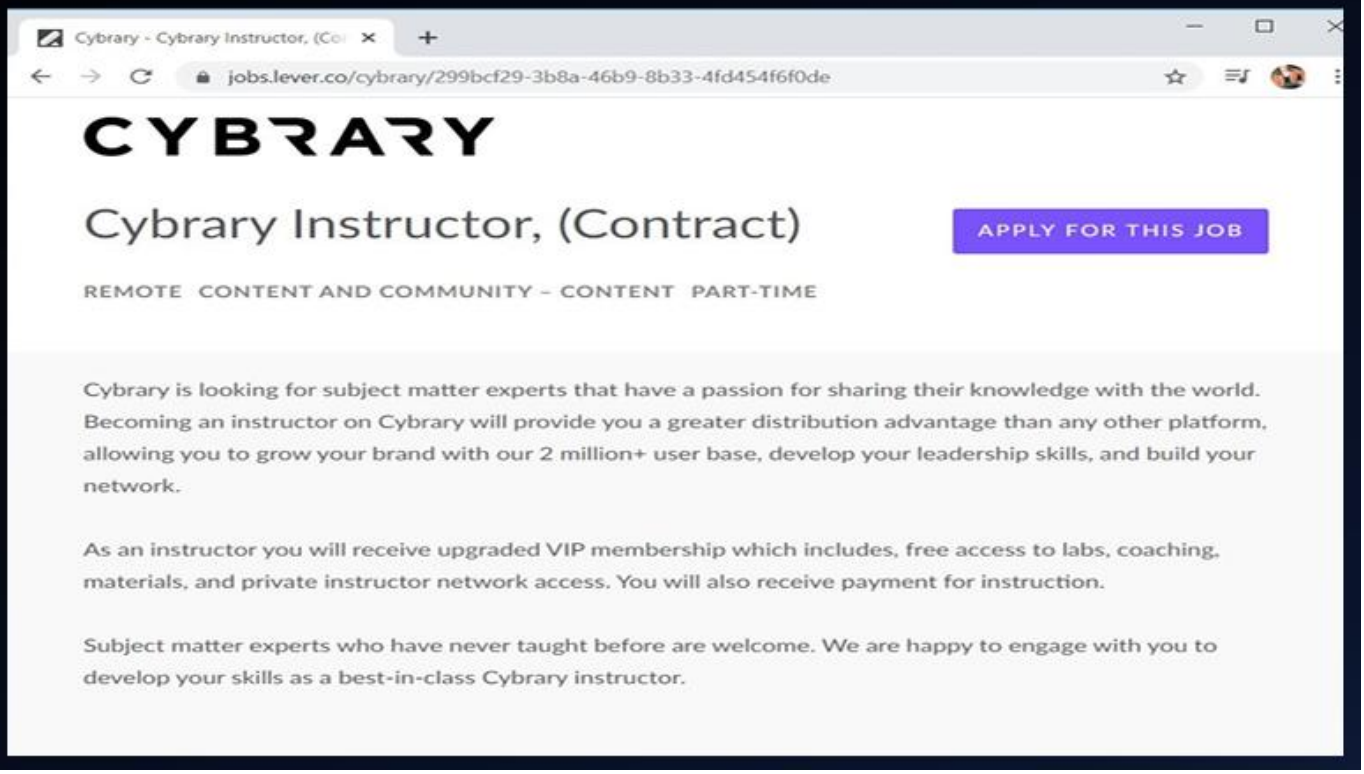
CYBRARY Career Opportunities

https://www.cybrary.it/contribute/



CYBRARY Instructor

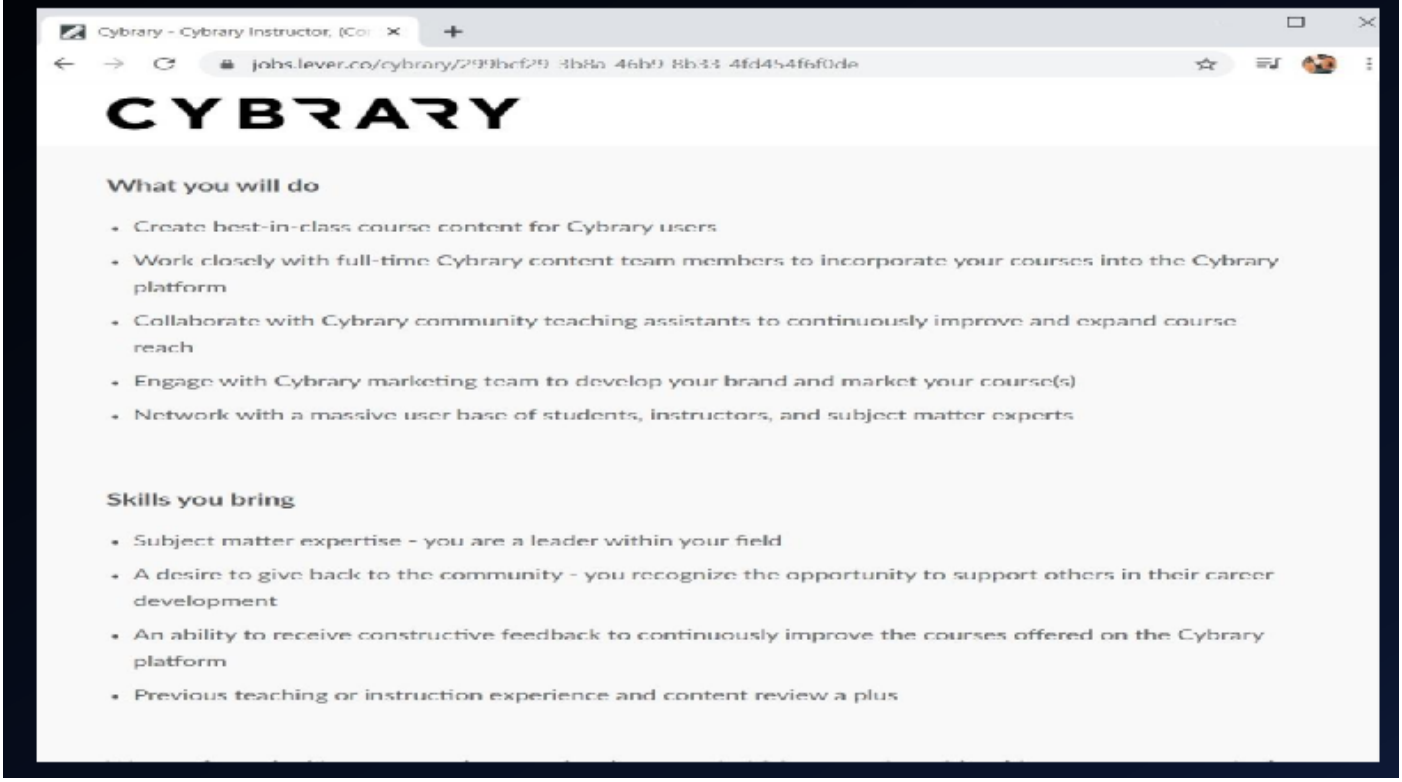
https://jobs.lever.co/cybrary/299bcf29-3b8a-46b9-8b33-4fd454f6f0de



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

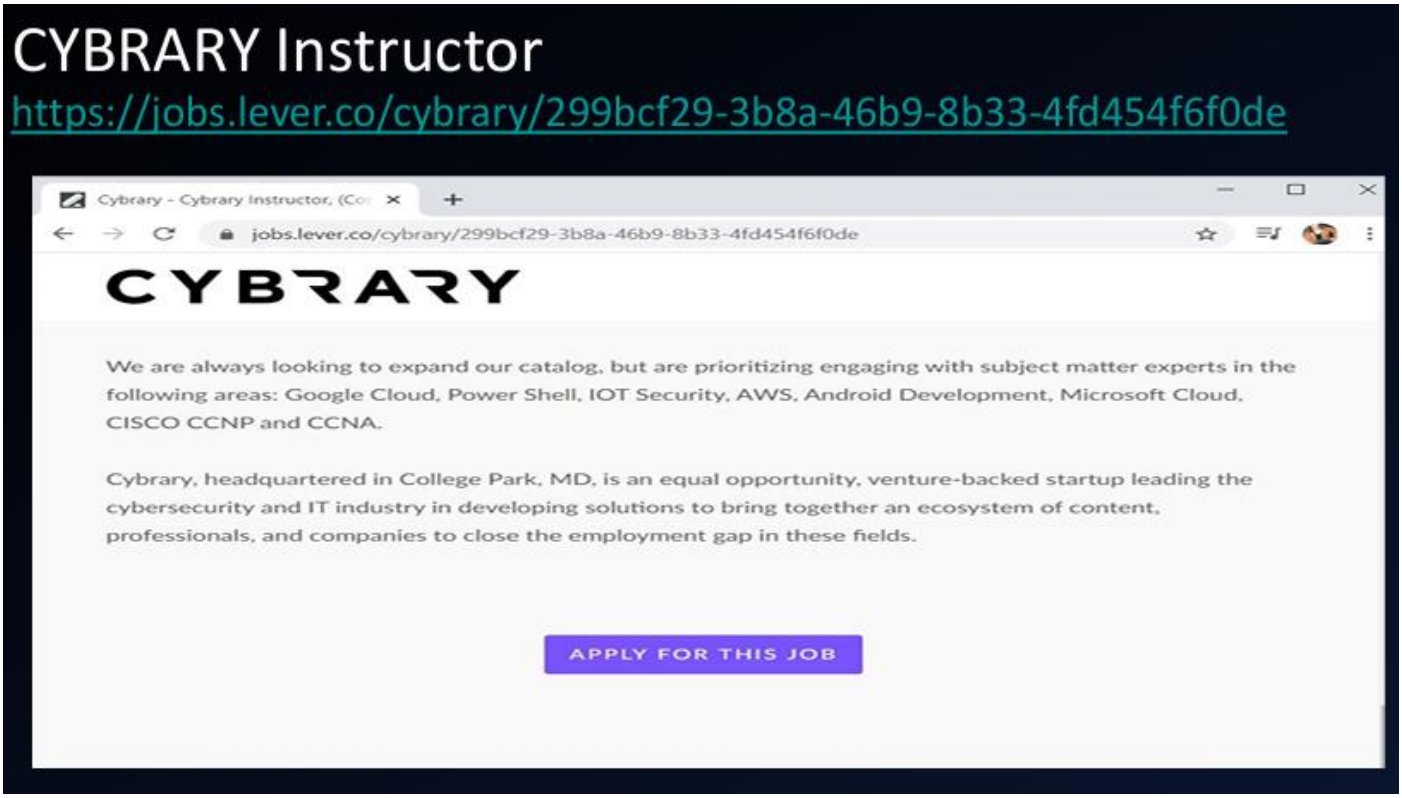
CYBRARY Instructor

https://jobs.lever.co/cybrary/299bcf29-3b8a-46b9-8b33-4fd454f6f0de



CYBRARY Instructor

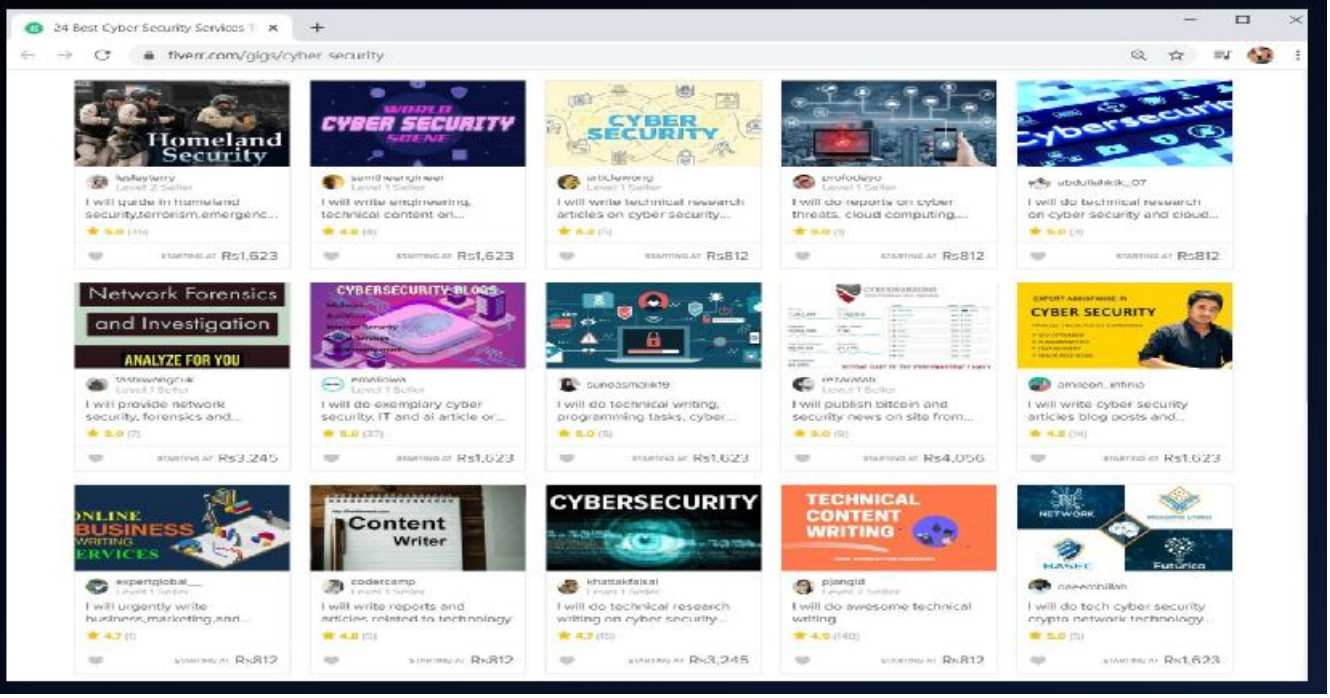
https://jobs.lever.co/cybrary/299bcf29-3b8a-46b9-8b33-4fd454f6f0de



Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Fiverr Security Projects

https://www.fiverr.com/gigs/cyber-security



Online Job Application / Search Sources

- Job Websites / Online Career Portals
- Social Media
  - Facebook
  - LinkedIn
- Company Websites
- InfoSec Organization's career portals

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Other Ways

- Search for company contact, submit CV's, turn up in-person.
- Word of mouth
  - Increase your social circle
- Attend InfoSec/IT related meetups, seminars, workshops & conferences.

Where the cybersecurity jobs are

Metros with the most job postings for cybersecurity roles

Rank	Metro area	Rank	Metro area
1	Washington, DC	6	Atlanta, GA
2	New York, NY	7	Boston, MA
3	Dallas-Fort Worth, TX	8	San Francisco, CA
4	Baltimore, MD	9	Los Angeles, CA
5	Chicago, IL	10	San Jose, CA

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Pre-requisites / Previous Knowledge

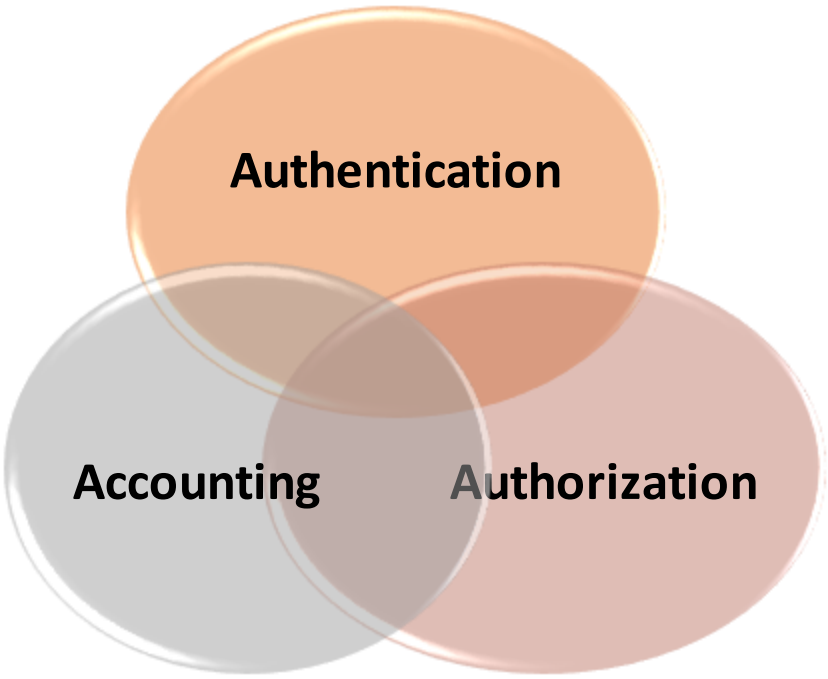
- Hardware
  - PC, Server, DC
  - Network Devices: Router, Switch, Load Balancer
- Operating Systems
  - Microsoft Windows, Apple Mac, Unix, Linux
- Networking
  - OSI, TCP/IP, Ports, Protocols, Devices
- Virtualization / Cloud Computing
- Programming / Scripting

This document is available on studocu

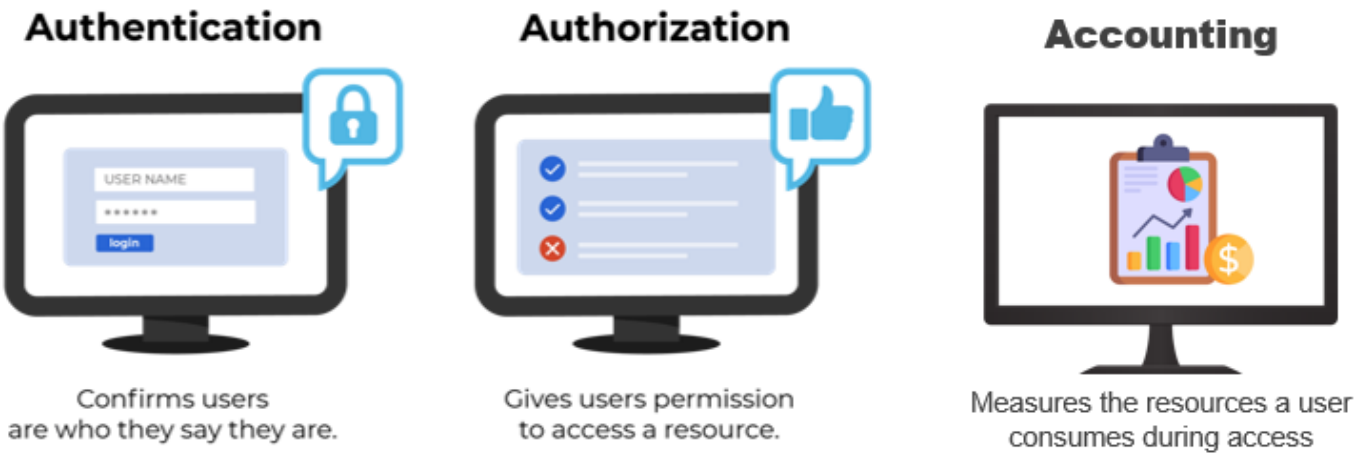
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Week#2





Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

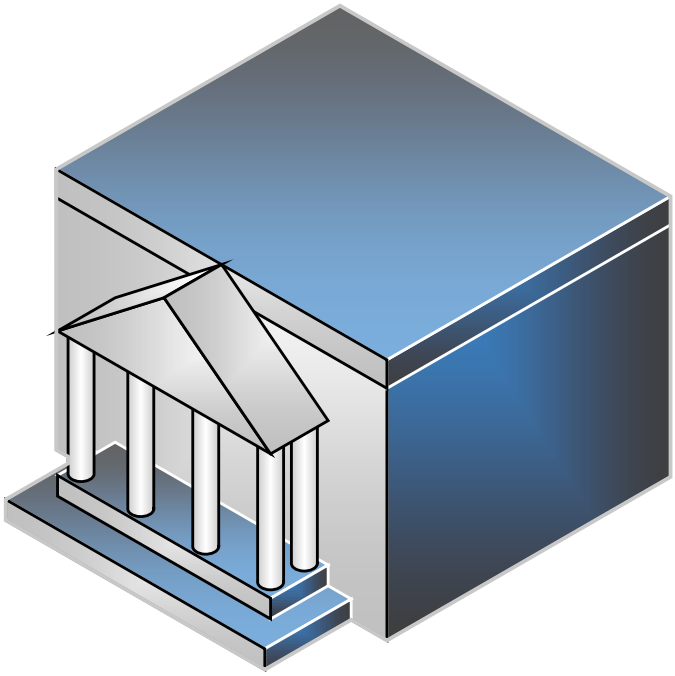


Authentication, Authorization, and Accounting (AAA

AAA is a term referred to the framework for

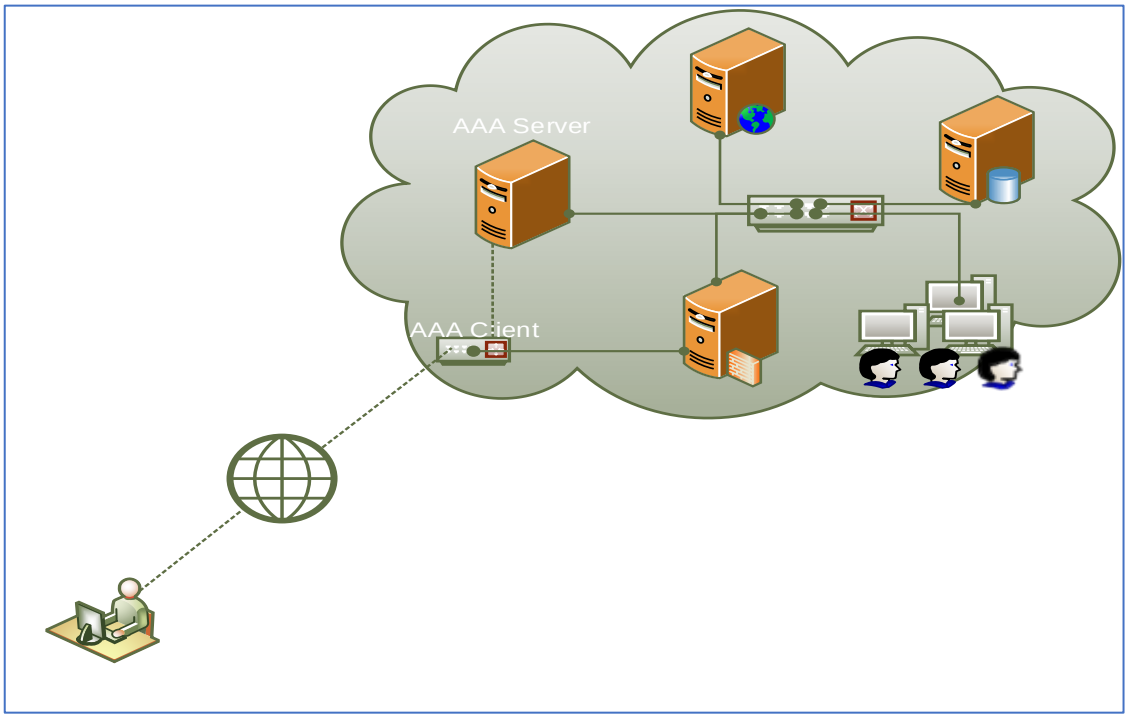
- Intelligently controlling access to the systems and resources
- Enforcing polices
- Auditing usage…
- Source: https://www.okta.com/identity-101/authentication-vs-authorization/

Illustration – Physical World



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Illustration – Cyber World





Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

AAA vs. IAM (Difference)

AAA

- AAA (Authentication, Authorization, and Accounting) is a general term that refers to a set of security processes that control access to computer resources.
- AAA servers are primarily used for network infrastructure.

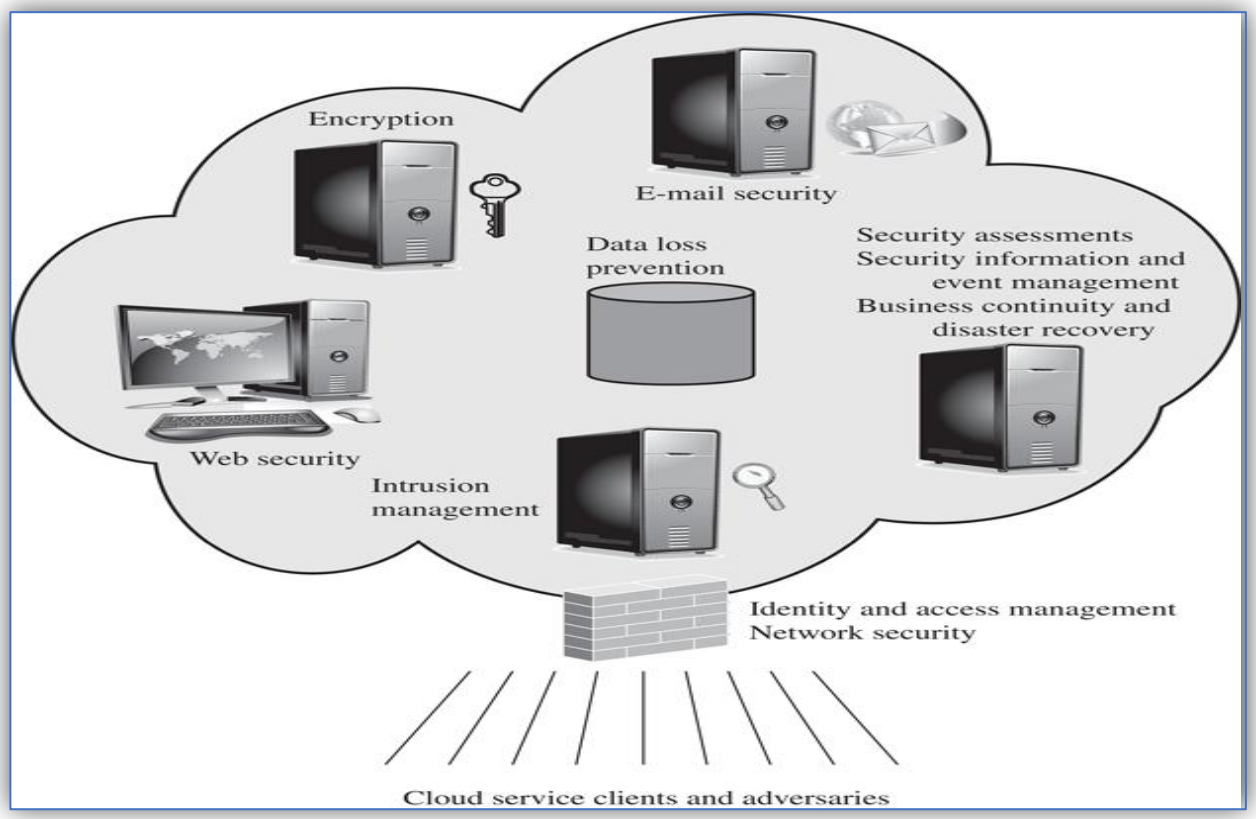
IAM

- IAM (Identity and Access Management) is a specific set of technologies and policies used to manage access to an organization's IT resources.
- IAM systems are used for managing access to enterprise applications and data.

Identity and Access Management (IAM)

To ensure that the right people and things have

- ☞ the right access to
- ☞ the right resources
- ☞ at the right time.
- ☞ IAM include establishing trusted user profile and policy information, using it to control access within the cloud service, and doing this in an auditable way.



Elements of Cloud Security as a Service

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

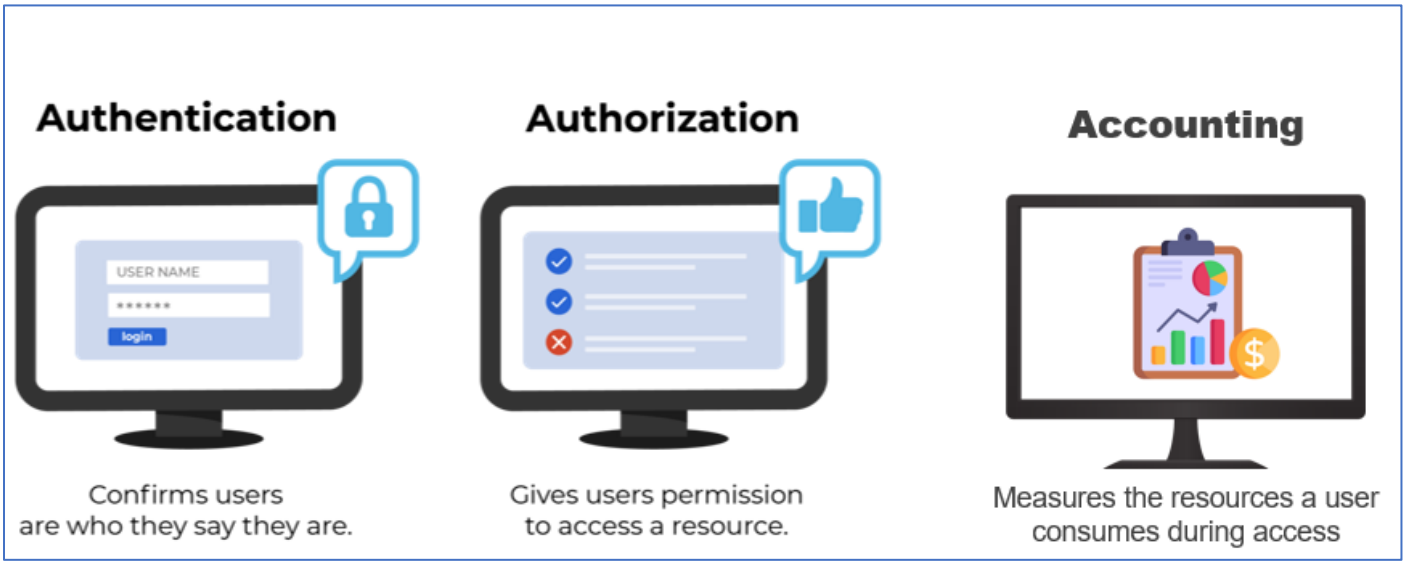
Identity Theft

- Consumers lost $56 billion to identity fraud in America during 2021 [CNBC]
- The COVID-19 pandemic has created more points of vulnerability
- Identity theft scams - criminals interact directly with consumers to steal their information through methods such as robocalls and phishing emails.
- Three common red flags to watch
    - **Unsolicited calls or emails**
    - **High-pressure tactics**
    - **Outdated passwords**

Source https://www.cnbc.com/2021/03/23/consumers-lost-56-billion-dollars-to-identity-fraud-last-year.html

MEANS OF USER AUTHENTICATION

Recap



The four means of authenticating user identity are based on:

- 1/4 Something the individual knows

    Password, PIN, answers to prearranged questions



Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

- 2/4 Something the individual possesses (token)

  Smartcard, electronic keycard, physical key





- 3/4 Something the individual is (static biometrics)

  Fingerprint, retina, face







- 4/4 Something the individual does (dynamic biometrics)

  Voice pattern, handwriting, typing rhythm





This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Summary

There are four general means of authenticating a user's identity, which can be used alone or in combination:

• **Something the individual knows:** Examples includes a password, a personal identification number (PIN), or answers to a prearranged set of questions.

• **Something the individual possesses(token):** Examples include electronic keycards, smart cards, and physical keys. This type of authenticator is referred to as a *token*.

• **Something the individual is (static biometrics):** Examples include recognition by fingerprint, retina, and face.

• **Something the individual does (dynamic biometrics):** Examples include recognition by voice pattern, handwriting characteristics, and typing rhythm.

All of these methods, properly implemented and used, can provide secure user authentication. However, each method has problems. An adversary may be able to guess or steal a password. Similarly, an adversary may be able to forge or steal a token. A user may forget a password or lose a token. Further, there is a significant administrative overhead for managing password and token information on systems and securing such information on systems. With respect to biometric authenticators, there are a variety of problems, including dealing with false positives and false negatives, user acceptance, cost, and convenience.

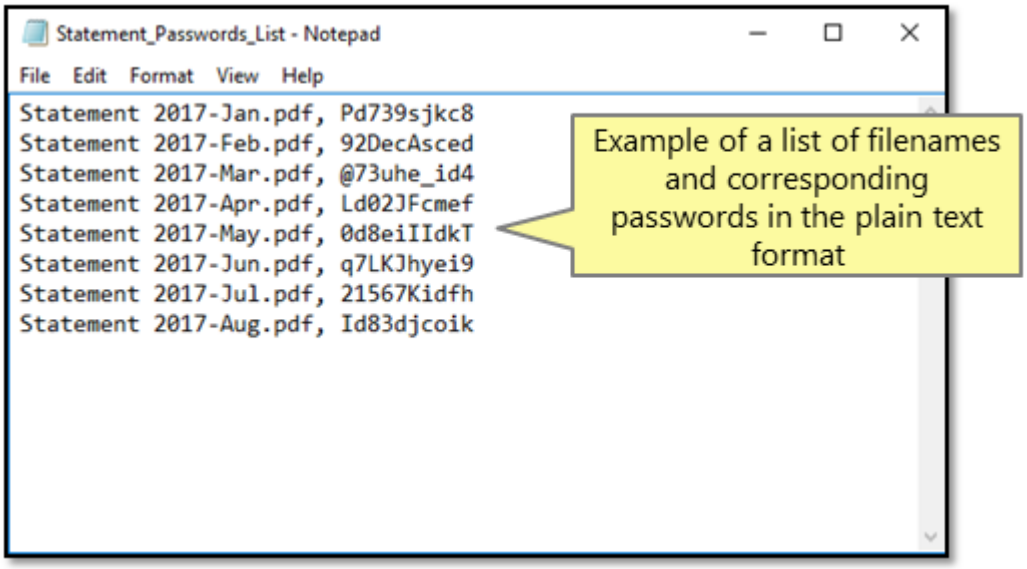


PASSWORD-BASED AUTHENTICATION

- Widely used line of defense against intruders
  - User provides name/login and password
  - System compares password with the one stored for that specified login
- The user ID:
  - Determines that the user is authorized to access the system
  - Determines the user's privileges
  - Is used in discretionary access control

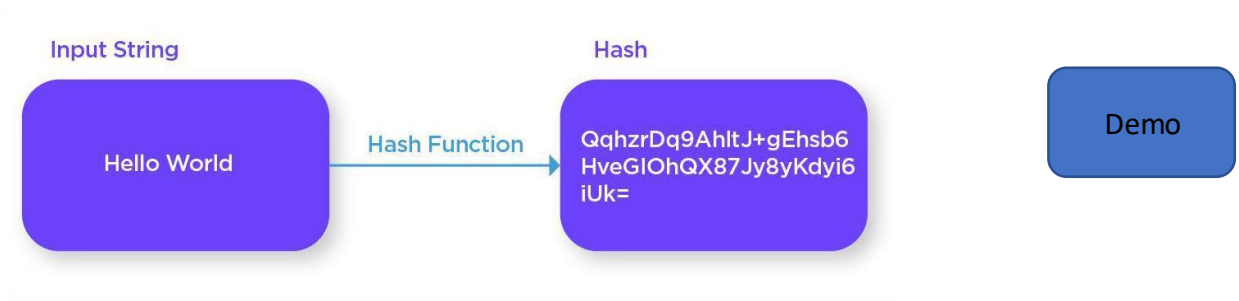
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

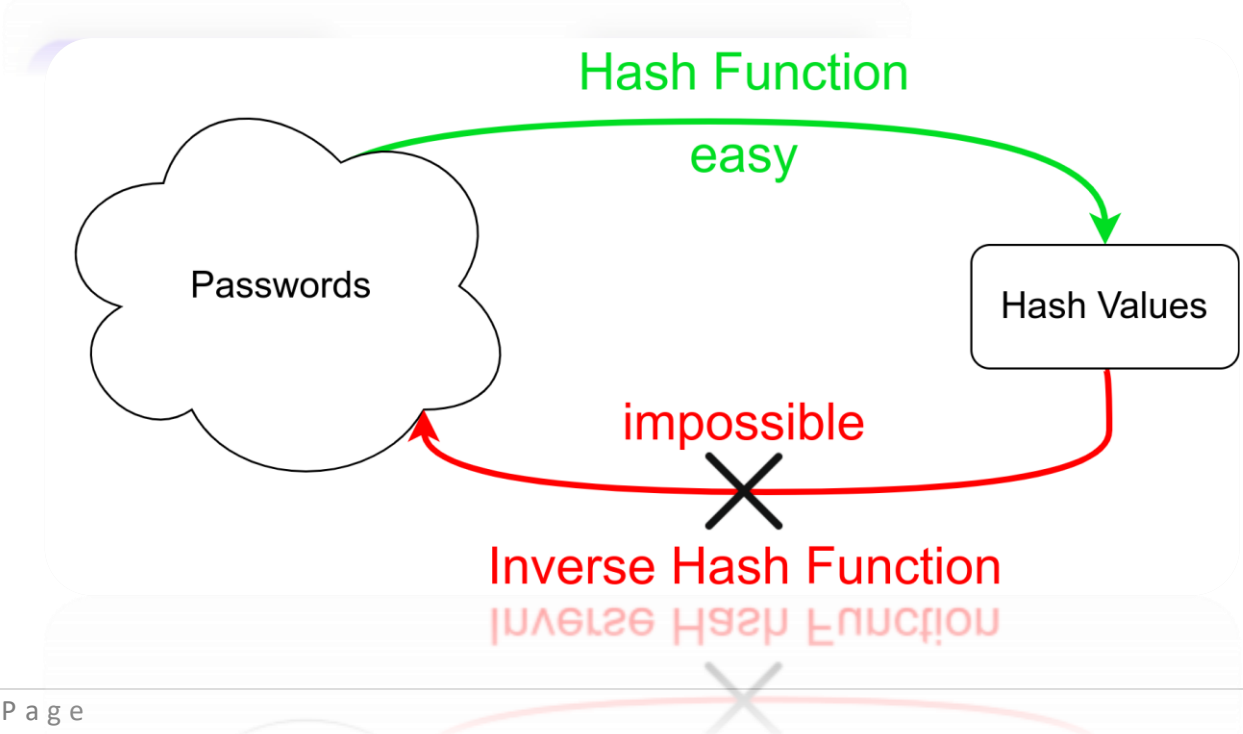
PASSWORD STORAGE Plain Text



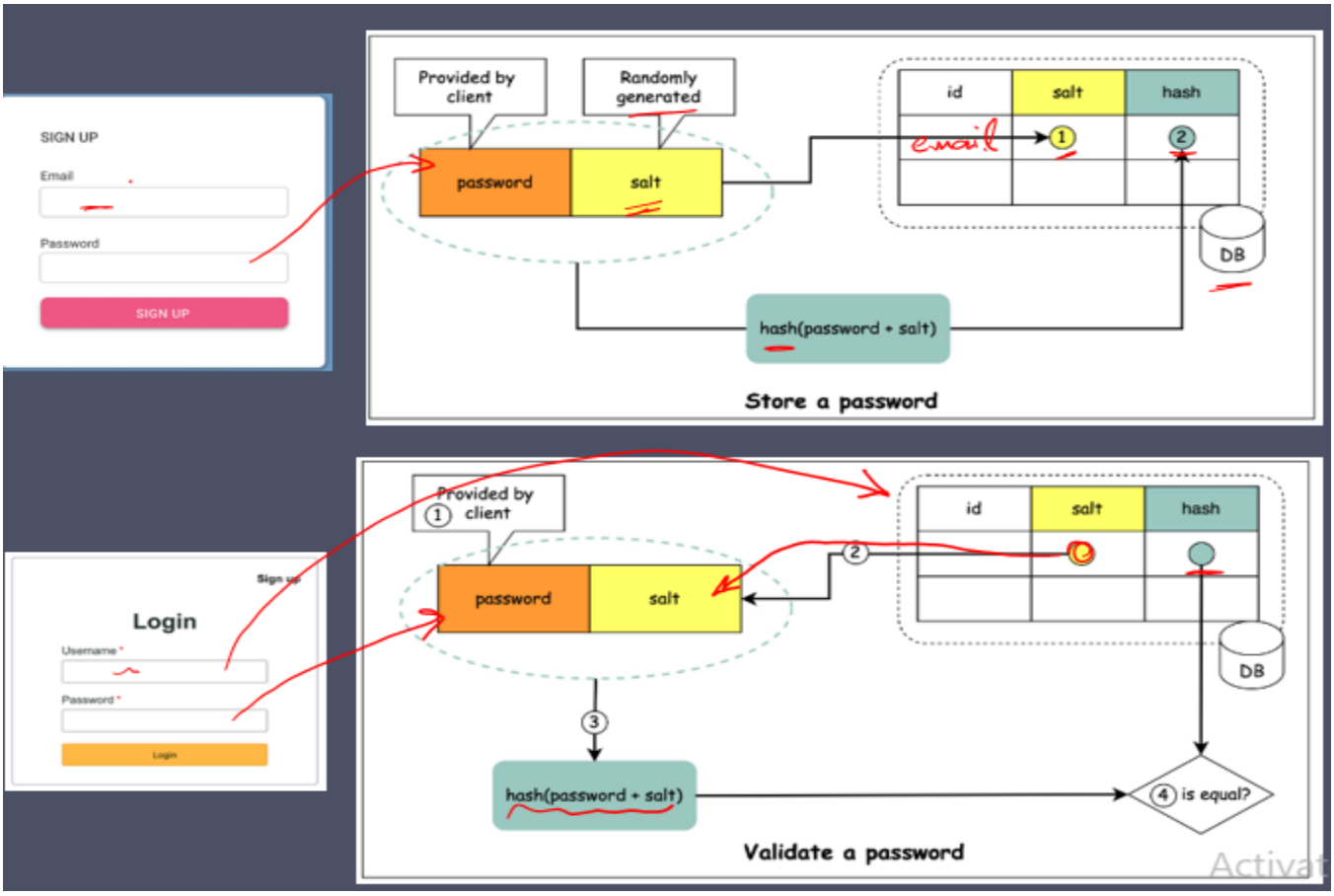
- Storing passwords in plaintext dangerous
  - because it puts both the system and users at risk.

PASSWORD STORAGE Hash Function





This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)



A widely used password security technique is the use of hashed passwords and a salt value. This scheme is found on virtually all UNIX variants as well as on a number of other operating systems. The following procedure is employed (Figure 3.3a). To load a new password into the system, the user selects or is assigned a password. This password is combined with a fixed-length **salt** value [MORR79]. In older implementations, this value is related to the time at which the password is assigned to the user. Newer implementations use a pseudorandom or random number. The password and salt serve as inputs to a hashing algorithm to produce a fixed-length hash code. The hash algorithm is designed to be slow to execute in order to thwart attacks. The hashed password is then stored, together with a plaintext copy of the salt, in the password file for the corresponding user ID. The hashed password method has been shown to be secure against a variety of cryptanalytic attacks [WAGN00]. When a user attempts to log on to a UNIX system, the user provides an ID and a password (Figure 3.3b). The operating system uses the ID to index into the password file and retrieve the plaintext salt and the encrypted password. The salt and user-supplied password are used as input to the encryption routine. If the result matches the stored value, the password is accepted.

The salt serves three purposes:

- It prevents duplicate passwords from being visible in the password file. Even if two users choose the same password, those passwords will be assigned different salt values. Hence, the hashed passwords of the two users will differ.
- It greatly increases the difficulty of offline dictionary attacks. For a salt of length b bits, the number of possible passwords is increased by a factor of 2^b, increasing the difficulty of guessing a password in a dictionary attack.
- It becomes nearly impossible to find out whether a person with passwords on two or more systems has used the same password on all of them.

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

To see the second point, consider the way that an offline dictionary attack would work. The attacker obtains a copy of the password file. Suppose first that the salt is not used. The attacker's goal is to guess a single password. To that end, the attacker submits a large number of likely passwords to the hashing function. If any of the guesses matches one of the hashes in the file, then the attacker has found a password that is in the file. But faced with the UNIX scheme, the attacker must take each guess and submit it to the hash function once for each salt value in the dictionary file, multiplying the number of guesses that must be checked.
There are two threats to the UNIX password scheme. First, a user can gainaccess on a machine using a guest account or by some other means and then runa password guessing program, called a password cracker, on that machine. Theattacker should be able to check many thousands of possible passwords with little resource consumption. In addition, if an opponent is able to obtain a copy of the password file, then a cracker program can be run on another machine at leisure. This enables the opponent to run through millions of possible passwords in a reasonable period.

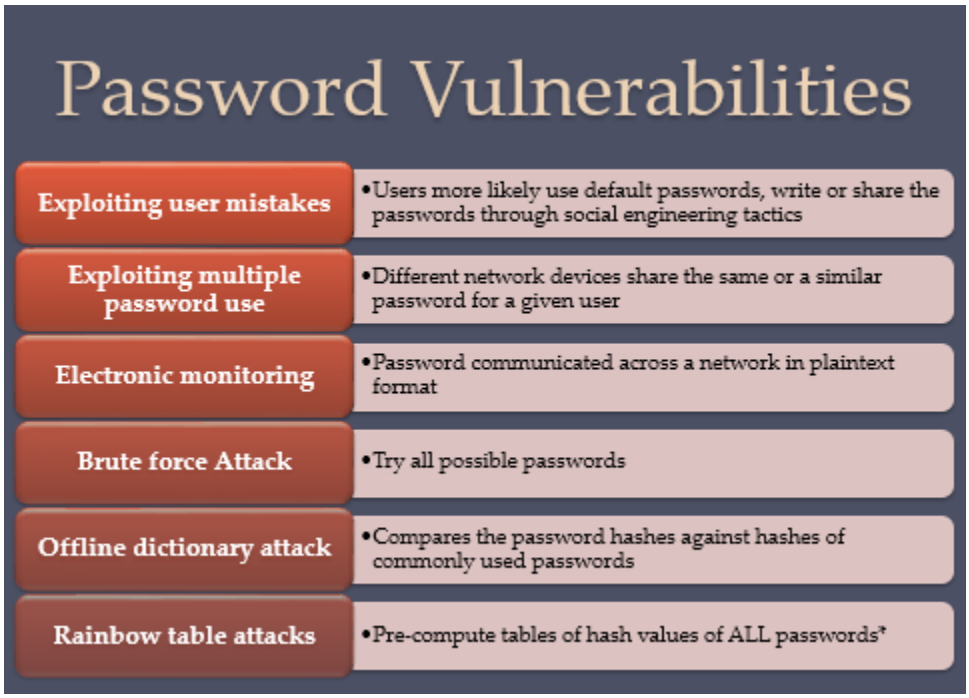


Password Vulnerabilities

Password Hacking and Cracking

- Password hacking and password cracking are terms that are often used interchangeably, but there is a subtle difference between the two.
- Password Hacking
  - refers to gaining unauthorized access to a system
  - Usually, original password is changed
- Password Cracking
  - to the process of attempting to recover a password
  - Usually, original password is NOT changed

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)



In this subsection, we outline the main forms of attack against password-basedauthentication and briefly outline a countermeasure strategy. The remainder ofSection 3.2 goes into more detail on the key countermeasures.We can identify the following attack strategies:

• **Offline dictionary attack:**

Typically, strong access controls are used to protectthe system's password file. However, experience shows that determinedhackers can frequently bypass such controls and gain access to the file. Theattacker obtains the system password file and compares the password hashesagainst hashes of commonly used passwords. If a match is found, the attackercan gain access by that ID/password combination. Countermeasures include controls to prevent unauthorized access to the password file, intrusion detectionmeasures to identify a compromise, and rapid reissuance of passwordsshould the password file be compromised.

• **Exploiting user mistakes:**

If the system assigns a password, then the user ismore likely to write it down because it is difficult to remember. This situationcreates the potential for an adversary to read the written password. A user may intentionally share a password, to enable a colleague to share files, for example. Also, attackers are frequently successful in obtaining passwords by using social engineering tactics that trick the user or an account manager into revealing a password. Many computer systems are shipped with preconfigured passwords for system administrators. Unless these preconfigured passwords are changed, they are easily guessed. Countermeasures include user training, intrusion detection, and simpler passwords combined with another authentication mechanism.

• **Exploiting multiple password use.**

Attacks can also become much more effective or damaging if different network devices share the same or a similar password for a given user. Countermeasures include a policy that forbids the same or similar password on particular network devices.

• **Electronic monitoring:**

If a password is communicated across a network tolog on to a remote system, it is vulnerable to eavesdropping. Simple encryptionwill not fix this problem, because the encrypted password is, in effect, the password and can be observed and reused by an adversary.

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Offline Dictionary Attack

Dictionary of Commonly Used Passwords

Password	Password Hash
Jhon	Hkdjutve
Secret	Lfjaskebad
Bold	Fasf572dnas
2023	Adnskjf30
World	42n34nasd
…	…
…	…
Cooler	Af45xbc2js
…	…

Target User

UID	Password Hash
Admin	af45xbc2js

Rainbow Table Attack

Hash Values of ALL Passwords
(of Length 04 in this example)

Password	Password Hash
Aaaa	Kfj8673hdb
Aaab	Hfge7w95j
Aaac	Jfhty673
Aaad	Hdg486hd
Aaae	Hdri9274
…	…
…	…
Cool	Rh75jd3h5
…	…

Target User

UID	Password Hash
Admin	Rh75jd3h5

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)



Securing Passwords

Modern Approaches

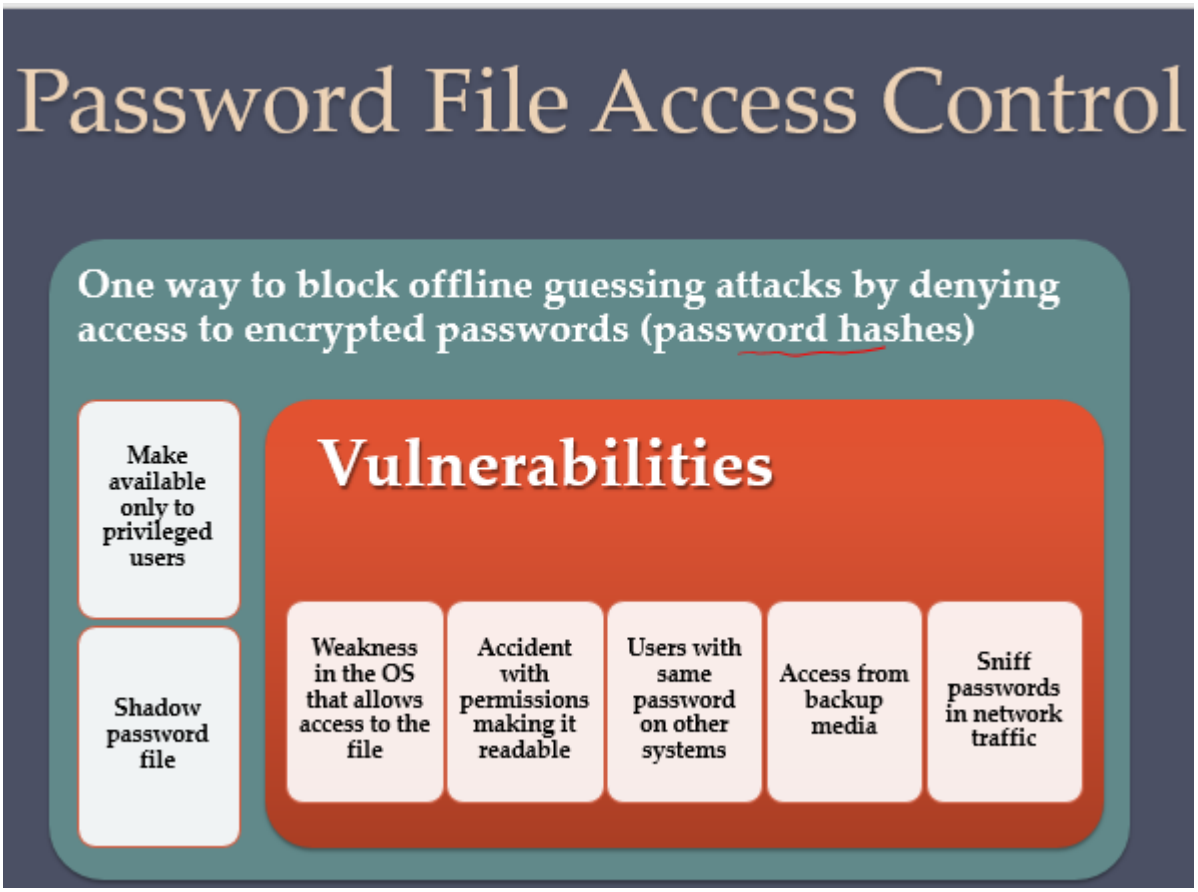
- Complex password policy
  - Forcing users to pick stronger passwords
  - However, password-cracking techniques have also improved
  - The processing capacity available for password cracking has increased dramatically
  - The use of sophisticated algorithms to generate potential passwords
  - Studying examples and structures of actual passwords in use

Detail:

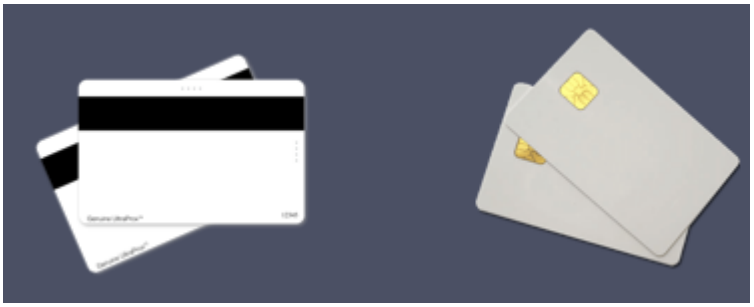
Sadly, this type of vulnerability has not lessened in the past 25 years or so. Users are doing a better job of selecting passwords, and organizations are doing a better job of forcing users to pick stronger passwords, aconcept known as a complex password policy, as discussed subsequently. However, password-cracking techniques have improved to keep pace. The improvements are of two kinds. First, the processing capacity available for password cracking has increased dramatically. Now used increasingly for computing, graphics processors allow password-cracking programs to work thousands of times faster than they did just a decade ago on similarly priced PCs that used traditional CPUs alone. A PC running a single AMD Radeon HD7970 GPU, for instance, can try on average an $8.2 * 10^9$ password combinations each second, depending on the algorithm used to scramble them [GOOD12a]. Only a decade ago, such speeds were possible only when using pricey supercomputers. The second area of improvement in password cracking is in the use of sophisticated algorithms to generate potential passwords. For example, [NARA05] developed a model for password generation using the probabilities of letters in natural language. The researchers used standard Markov modeling techniques from natural language processing to dramatically reduce the size of the password space to be searched. But the best results have been achieved by studying examples of actual passwords in use. To develop techniques that are more efficient and effective than simple dictionary and brute-force attacks, researchers and hackers have studied the structure of passwords. To do this, analysts need a large pool of real-word passwords to study, which they now have. The first big breakthrough came in late 2009, when an SQL injection attack against online games service RockYou.com exposed 32 million plaintext passwords used by its members to log in to their accounts [TIMM10]. Since then, numerous sets of leaked password files have become available for analysis.

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

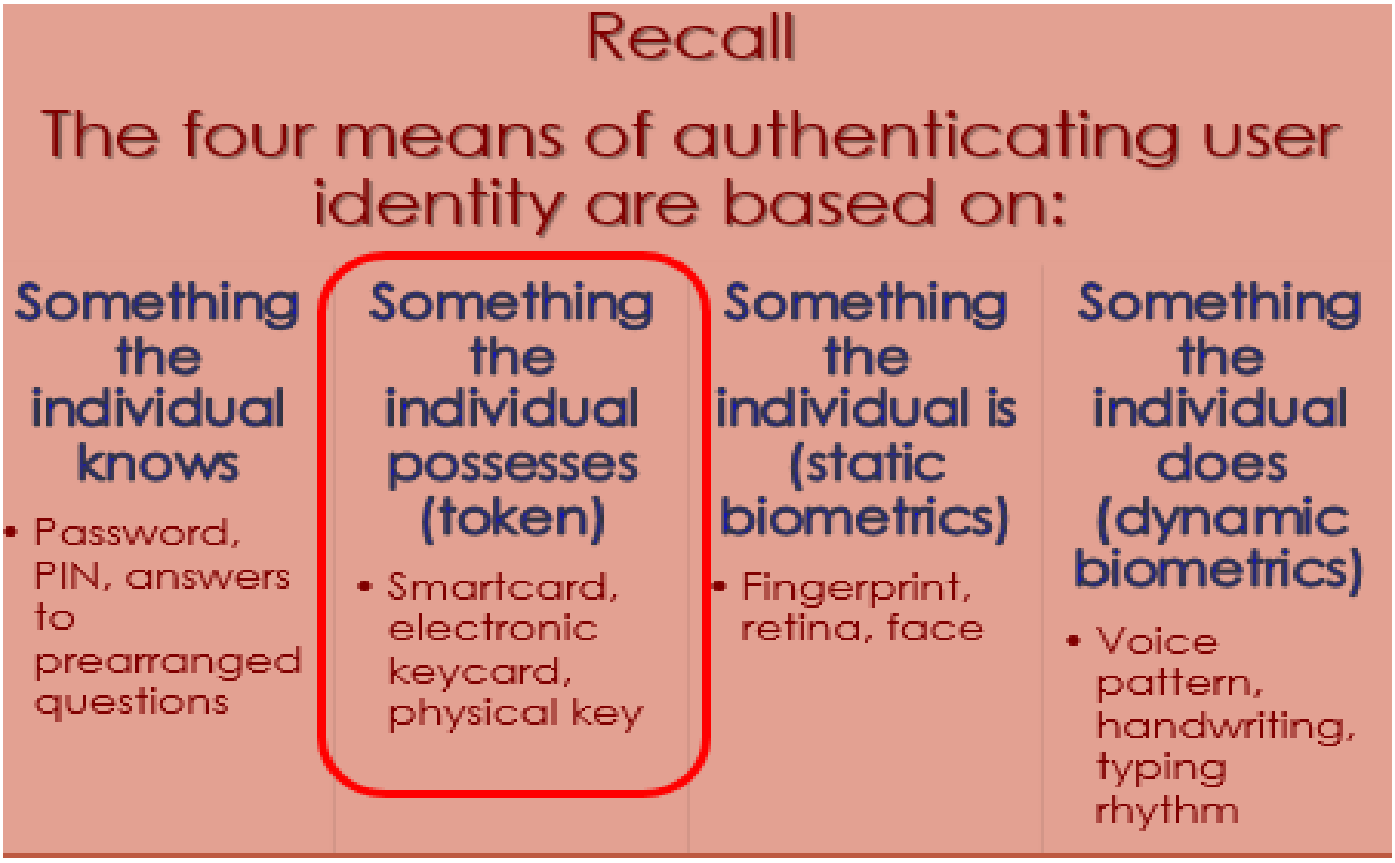
Using large datasets of leaked passwords as training data, [WEIR09] reports on the development of a probabilistic context-free grammar for password cracking. In this approach, guesses are ordered according to their likelihood, based on the frequency of their character-class structures in the training data, as well as the frequency of their digit and symbol substrings. This approach has been shown to be efficient in password cracking [KELL12, ZHAN10].



Memory Cards and Smart Cards



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)



Detail:

There are four general means of authenticating a user's identity, which can be used alone or in combination:

• **Something the individual knows:** Examples includes a password, a personal identification number (PIN), or answers to a prearranged set of questions.

• **Something the individual possesses:** Examples include electronic keycards, smart cards, and physical keys. This type of authenticator is referred to as a *token*.

• **Something the individual is (static biometrics):** Examples include recognition by fingerprint, retina, and face.

• **Something the individual does (dynamic biometrics):** Examples include recognition by voice pattern, handwriting characteristics, and typing rhythm.

All of these methods, properly implemented and used, can provide secure user authentication. However, each method has problems. An adversary may be able to guess or steal a password. Similarly, an adversary may be able to forge or steal a token. A user may forget a password or lose a token. Further, there is a significant administrative overhead for managing password and token information on systems and securing such information on systems. With respect to biometric authenticators, there are a variety of problems, including dealing with false positives and false negatives, user acceptance, cost, and convenience.

Memory Cards

- Can store but do not process data
- The most common is the magnetic stripe card e.g. ATM
- Can include an internal electronic memory



Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

- Can be used alone for physical access
    - Hotel room
    - ATM
- Provides significantly greater security when combined with a password or PIN
- Drawbacks of memory cards include:
    - Requires a special reader
    - Loss/theft of token/memory card
    - User dissatisfaction

Detail:

Memory cards can store but not process data. The most common such card is the bank card with a magnetic stripe on the back. A magnetic stripe can store only a simple security code, which can be read (and unfortunately reprogrammed) by an inexpensive card reader. There are also memory cards that include an internal electronic memory. Memory cards can be used alone for physical access, such as a hotel room. For computer user authentication, such cards are typically used with some form of password or personal identification number (PIN). A typical application is an automatic teller machine (ATM). The memory card, when combined with a PIN or password, provides significantly greater security than a password alone. An adversary must gain physical possession of the card (or be able to duplicate it) plus must gain knowledge of the PIN. Among the potential drawbacks NIST SP 800-12 (*An Introduction to Computer Security: The NIST Handbook* , October 1995) notes the following:

• Requires special reader: This increases the cost of using the token and creates the requirement to maintain the security of the reader's hardware and software.

• Token loss: A lost token temporarily prevents its owner from gaining system access. Thus there is an administrative cost in replacing the lost token. In addition, if the token is found, stolen, or forged, then an adversary now need only determine the PIN to gain unauthorized access.

• User dissatisfaction: Although users may have no difficulty in accepting the use of a memory card for ATM access, its use for computer access may bedeemed inconvenient.

Smart Tokens

- Physical characteristics:
  Include an embedded microprocessor
  A smart token may look like a bank card
  Can look like calculators, keys, small portable objects
- User interface:
  Manual interfaces include a keypad and display for human/token interaction
- Electronic interface
  A smart card or other token requires an electronic interface to communicate with a compatible reader/writer
  Contact and contactless interfaces
- Authentication protocol:
  Classified into three categories:
    - Static
    - Dynamic password generator
    - Challenge-response



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Detail:

A wide variety of devices qualify as smart tokens. These can be categorized along three dimensions that are not mutually exclusive:

• **Physical characteristics**: Smart tokens include an embedded microprocessor.A smart token that looks like a bank card is called a smart card. Other smart tokens can look like calculators, keys, or other small portable objects.

• **User interface**: Manual interfaces include a keypad and display for human/token interaction.

Electronic interface: A smart card or other token requires an electronic interface to communicate with a compatible reader/writer. A card may have one or both of the following types of interface:

—— Contact: A contact smart card must be inserted into a smart card reader with a direct connection to a conductive contact plate on the surface of the card (typically gold plated). Transmission of commands, data, and card status takes place over these physical contact points.

—— Contactless: A contactless card requires only close proximity to a reader. Both the reader and the card have an antenna, and the two communicate using radio frequencies. Most contactless cards also derive power for the internal chip from this electromagnetic signal. The range is typically one-half to three inches for non-battery-powered cards, ideal for applications such as building entry and payment that require a very fast card interface.

• Authentication protocol: The purpose of a smart token is to provide a means for user authentication. We can classify the authentication protocols used with smart tokens into three categories:

— Static: With a static protocol, the user authenticates himself or herself to the token and then the token authenticates the user to the computer. The latter half of this protocol is similar to the operation of a memory token.

— Dynamic password generator: In this case, the token generates a unique password periodically (e.g., every minute). This password is then entered into the computer system for authentication, either manually by the user or electronically via the token. The token and the computer system must be initialized and kept synchronized so that the computer knows the password that is current for this token.

— Challenge-response: In this case, the computer system generates a challenge, such as a random string of numbers. The smart token generates a response based on the challenge. For example, public-key cryptography could be used and the token could encrypt the challenge string with the token's private key.

Smart Cards

- Most important category of smart token
  - Has the appearance of a credit card
  - Has an electronic interface
  - May use any of the smart token protocols
- Contain:
  - An entire microprocessor
    - Processor
    - Memory
    - I/O ports



Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

- Typically include three types of memory:
    - Read-only memory (ROM)
        - Stores data that does not change during the card's life
    - Electrically erasable programmable ROM (EEPROM)
        - Holds application data and programs
    - Random access memory (RAM)
        - Holds temporary data generated when applications are executed

For user authentication the most important category of smart token is the smart card, which has the appearance of a credit card, has an electronic interface,and may use any of the type of protocols just described. The remainder of this section discusses smart cards. A smart card contains within it an entire microprocessor, including processor, memory, and I/O ports. Some versions incorporate a special co-processing circuit for cryptographic operation to speed the task of encoding and decoding messages or generating digital signatures to validate the information transferred. In some cards, the I/O ports are directly accessible by a compatible reader by means of exposed electrical contacts. Other cards rely instead on an embedded antenna for wireless communication with the reader. A typical smart card includes three types of memory. Read-only memory (ROM) stores data that does not change during the card's life, such as the card number and the cardholder's name. Electrically erasable programmable ROM(EEPROM) holds application data and programs, such as the protocols that the card can execute. It also holds data that may vary with time. For example, in a telephone card, the EEPROM holds the talk time remaining. Random access memory (RAM) holds temporary data generated when applications are executed.

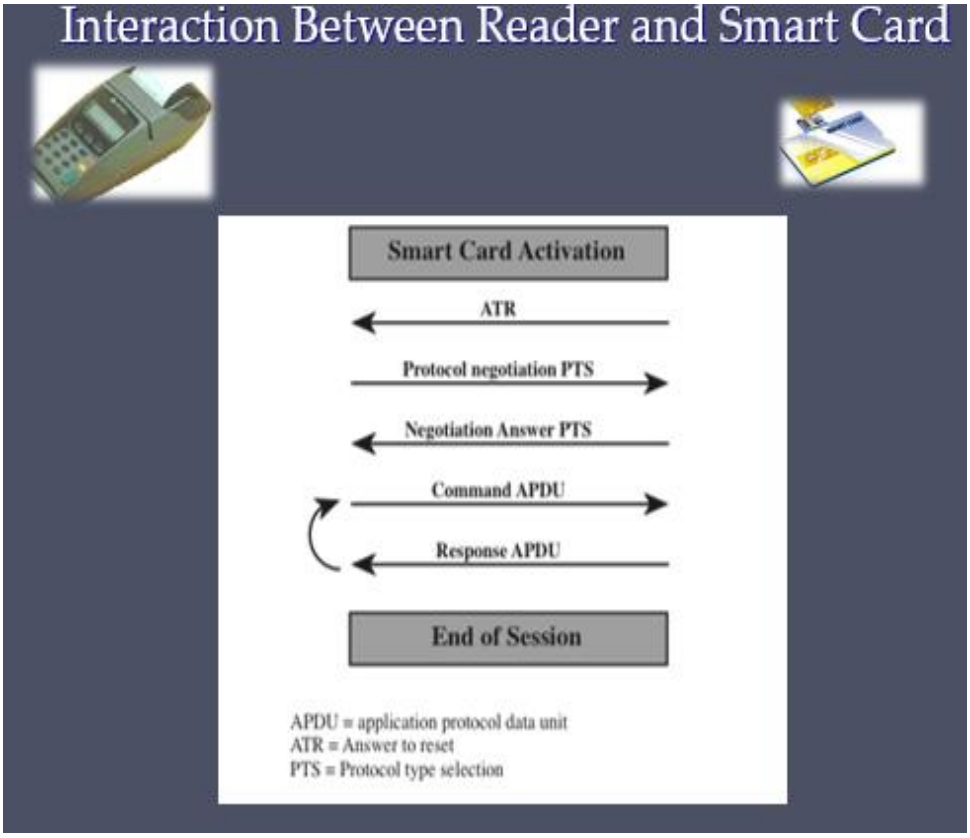


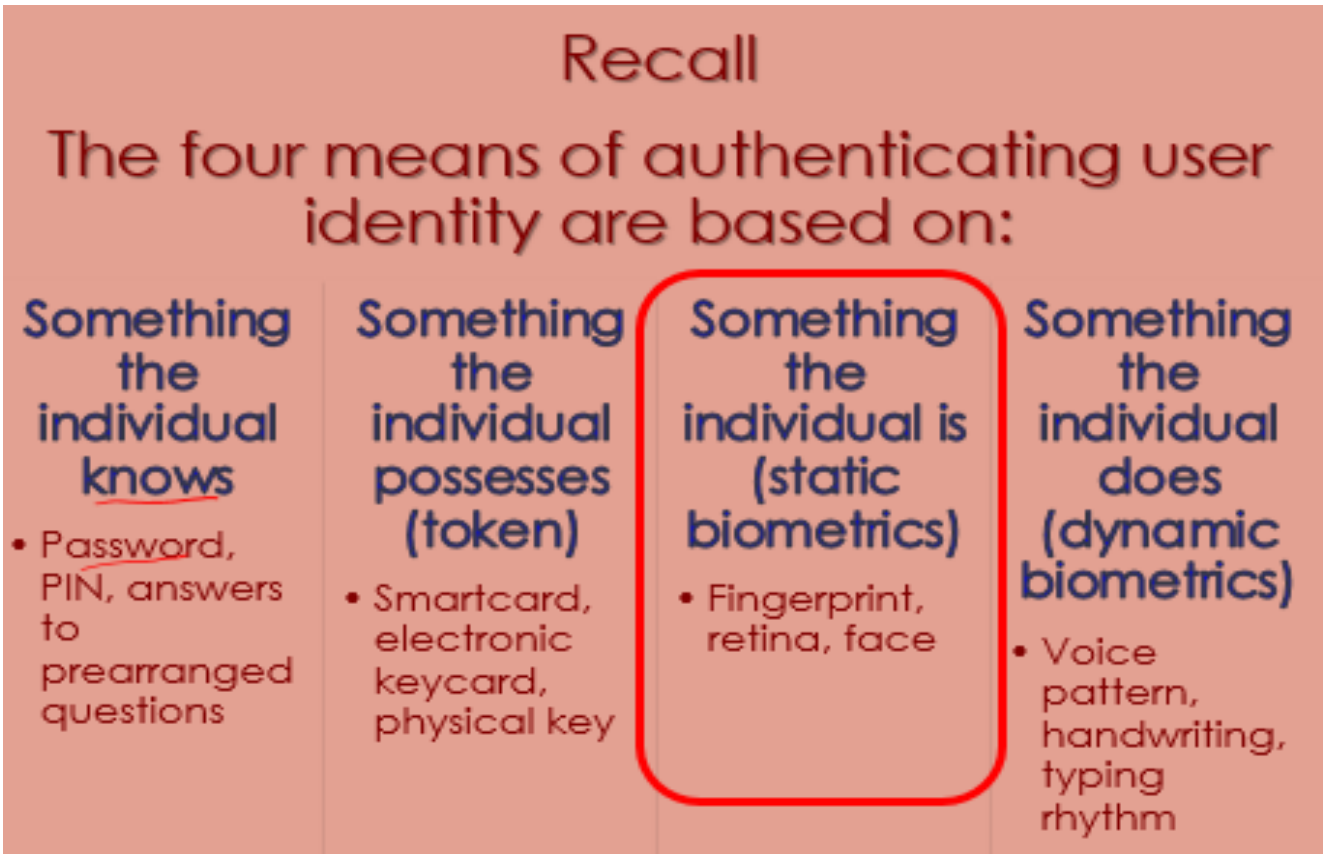
Figure 3.6 illustrates the typical interaction between a smart card and a reader or computer system. Each time the card is inserted into a reader, a reset is initiated by the reader to initialize parameters such as clock value. After the reset function is performed, the card responds with answer to reset (ATR) message. This message defines the parameters and protocols that the card can use and the functions it can perform. The

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

terminal may be able to change the protocol used and other parameters via a protocol type selection (PTS) command. The cards PTS response confirms the protocols and parameters to be used. The terminaland card can now execute the protocol to perform the desired application.



Biometric Authentication



Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Detail:

There are four general means of authenticating a user's identity, which can be used alone or in combination:
• **Something the individual knows:** Examples includes a password, a personal identification number (PIN), or answers to a prearranged set of questions.
• **Something the individual possesses:** Examples include electronic keycards, smart cards, and physical keys. This type of authenticator is referred to as a *token*.
• **Something the individual is (static biometrics):** Examples include recognition by fingerprint, retina, and face.
• **Something the individual does (dynamic biometrics):** Examples include recognition by voice pattern, handwriting characteristics, and typing rhythm.
All of these methods, properly implemented and used, can provide secure user authentication. However, each method has problems. An adversary may be able to guess or steal a password. Similarly, an adversary may be able to forge or steal a token. A user may forget a password or lose a token. Further, there is a significant administrative overhead for managing password and token information on systems and securing such information on systems. With respect to biometric authenticators, there are a variety of problems, including dealing with false positives and false negatives, user acceptance, cost, and convenience.

Biometric Authentication

- Attempts to authenticate an individual based on unique physical characteristics
- Based on pattern recognition
- This is technically complex and expensive when compared to passwords and tokens
- Physical characteristics used include:
    - Facial characteristics
    - Fingerprints
    - Hand geometry
    - Retinal pattern
    - Iris
    - Signature
    - Voice

Detail:

A biometric authentication system attempts to authenticate an individual based onhis or her unique physical characteristics. These include static characteristics, suchas fingerprints, hand geometry, facial characteristics, and retinal and iris patterns;and dynamic characteristics, such as voiceprint and signature. In essence, biometricsis based on pattern recognition. Compared to passwords and tokens, biometric authentication is both technically complex and expensive. While it is used in a number of specific applications, biometrics has yet to mature as a standard tool for user authentication to computer systems .A number of different types of physical characteristics are either in use or under study for user authentication. The most common are the following:

• Facial characteristics: Facial characteristics are the most common means of human-to-human identification; thus it is natural to consider them for identification by computer. The most common approach is to define characteristics based on relative location and shape of key facial features, such as eyes, eyebrows, nose, lips, and chin shape. An alternative approach is to use an infrared camera to produce a face thermogram that correlates with the underlying vascular system in the human face.

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

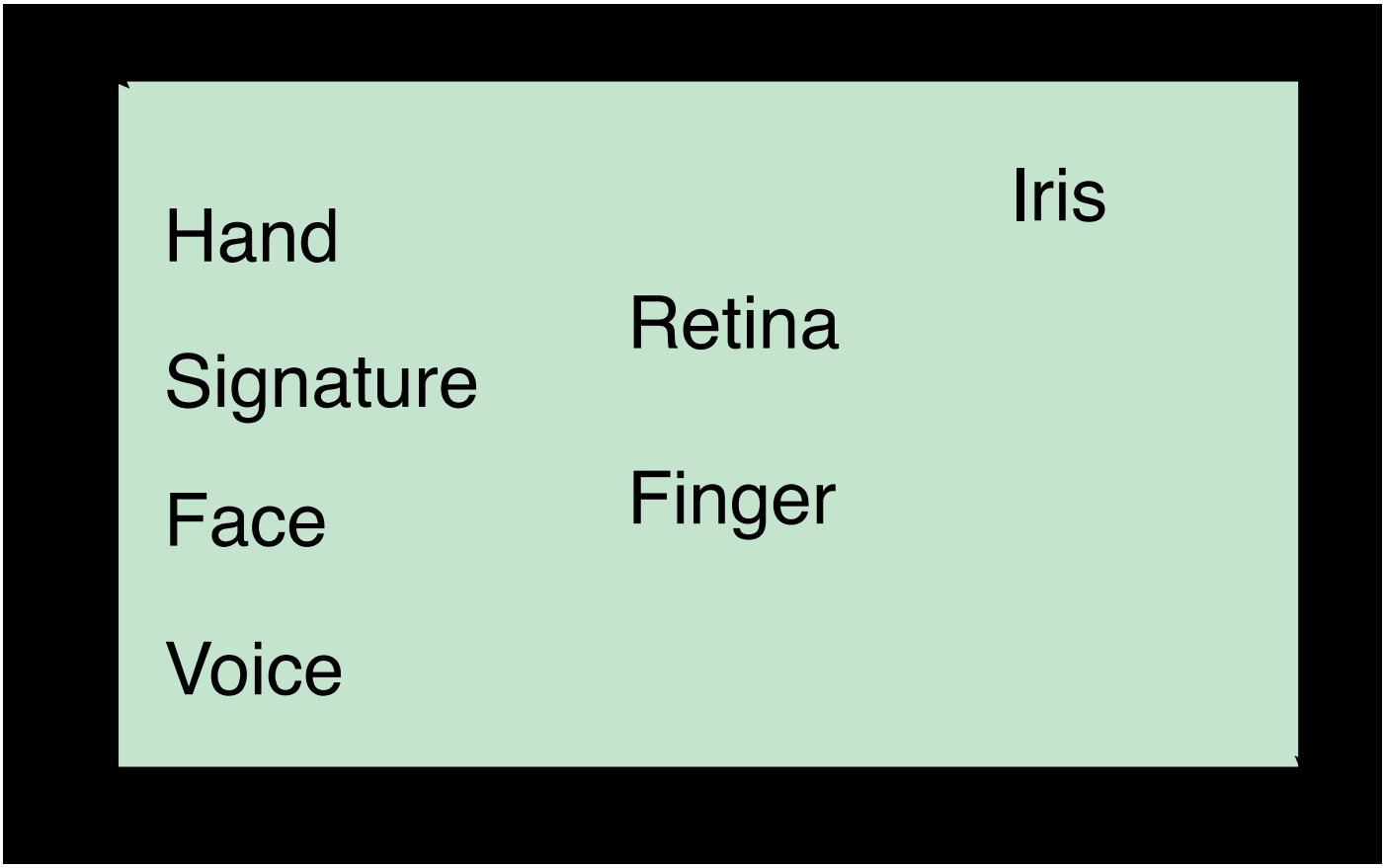
• Fingerprints: Fingerprints have been used as a means of identification for centuries, and the process has been systematized and automated particularly for law enforcement purposes. A fingerprint is the pattern of ridges and furrows on the surface of the fingertip. Fingerprints are believed to be unique across the entire human population. In practice, automated fingerprint recognition and matching system extract a number of features from the fingerprint for storage as a numerical surrogate for the full fingerprint pattern.

• Hand geometry: Hand geometry systems identify features of the hand, including shape, and lengths and widths of fingers.

• Retinal pattern: The pattern formed by veins beneath the retinal surface is unique and therefore suitable for identification. A retinal biometric system obtains a digital image of the retinal pattern by projecting a low-intensity beam of visual or infrared light into the eye.

• Iris: Another unique physical characteristic is the detailed structure of the iris.
• Signature: Each individual has a unique style of handwriting and this isnreflected especially in the signature, which is typically a frequently written sequence. However, multiple signature samples from a single individual will not be identical. This complicates the task of developing a computer representation of the signature that can be matched to future samples.

• Voice: Whereas the signature style of an individual reflects not only the unique physical attributes of the writer but also the writing habit that has developed, voice patterns are more closely tied to the physical and anatomical characteristics of the speaker. Nevertheless, there is still a variation from sample to sample over time from the same speaker, complicating the biometric recognition task.

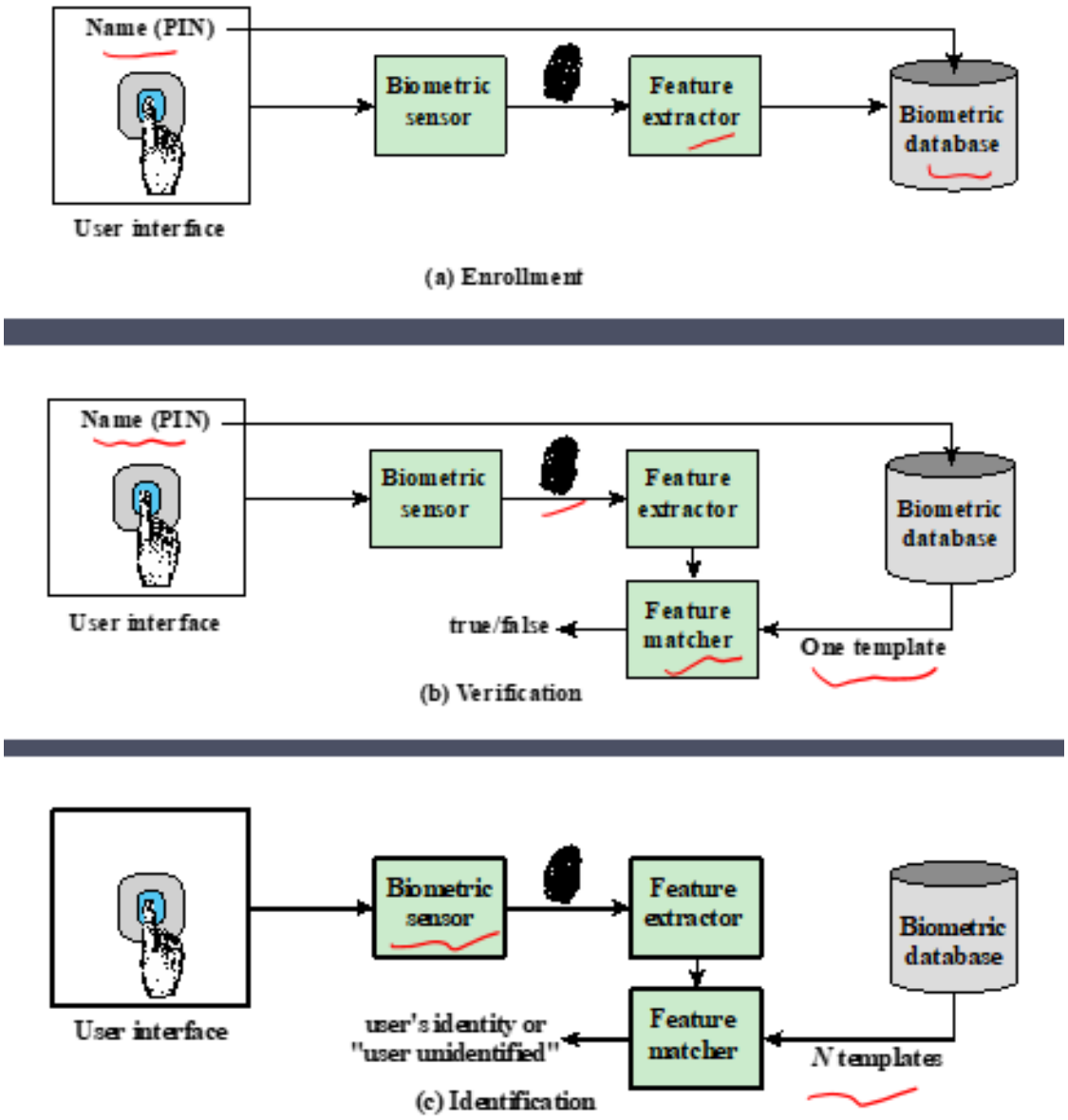


Detail:

Figure 3.8 gives a rough indication of the relative cost and accuracy of these biometric measures. The concept of accuracy does not apply to user authentication schemes using smart cards or passwords. For example, if a user enters a password, it either matches exactly the password expected for that user or not. In

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

the case of biometric parameters, the system instead must determine how closely a presented biometric characteristic matches a stored characteristic. Before elaborating on the concept of biometric accuracy, we need to have a general idea of how biometric systems work.



Detail:

Figure 3.9 illustrates the operation of a biometric system. Each individual who is to be included in the database of authorized users must first be **enrolled** in the system. This is analogous to assigning a password to a user. For a biometric system, the user presents a name and, typically, some type of password or PIN to the system. At the same time the system senses some biometric characteristic of this user (e.g., fingerprint ofright index finger). The system digitizes the input and then extracts a set of features that can be stored as a number or set of numbers representing this unique biometric characteristic; this set of numbers is referred to as the user's template. The user is now enrolled in the system, which maintains for the user a name (ID), perhaps a PIN or password, and the biometric value. Depending on application, user authentication on a biometric system involves either **verification** or **identification**. Verification is analogous to a user logging on to a system by using a memory card or smart card coupled with a password or PIN. For biometric verification, the user enters a PIN and also uses a biometric sensor. The system extracts the corresponding feature and compares that to the template stored for this user. If there is a match, then the system

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

authenticates this user. For an identification system, the individual uses the biometric sensor but presents no additional information. The system then compares the presented template with the set of stored templates. If there is a match, then this user is identified. Otherwise, the user is rejected.

Biometric Authentication

Pros

- Difficult to frog
- Convenience
- More secure and non- transferable*

Cons

- Costly
- Complex
- False Acceptance Rate (FAR) and False Rejection Rate (FRR)
- Rigid
- Attacker can fool the system

SFA vs. 2FA vs. MFA

- SFA

Simplestform of authentication method.
Matches one credential to verify a person online.
The most popular example is password (credential) to a username.

- 2FA

2FA uses the same password/username combination, but with the addition of being asked to verify who a person is by using something only he or she owns, such as a mobile device.
Putting it simply: it uses two factors to confirm an identity.

- MFA

Multi-factor authentication uses a combination of the following factors: something you know, something you have, and something you are.
2FA is a subset of MFA,

- Recall
- The four means of authenticating user identity are based on:

Something the individual knows

Password, PIN, answers to prearranged questions

Something the individual possesses (token)

Smartcard, electronic keycard, physical key

Something the individual is (static biometrics)

Fingerprint, retina, face

Something the individual does (dynamic biometrics)

Voice pattern, handwriting, typing rhythm

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Multi-factor Authentication

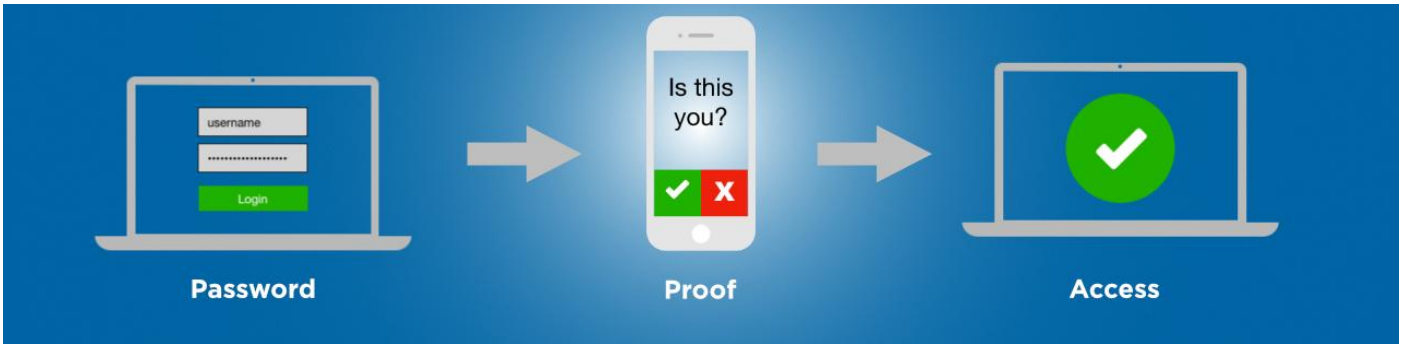
- 80% of hacking data breaches come from weak or compromised passwords, according to Verizon's 2019 Data Breach Investigations Report
- Multi-factor authentication (MFA) is the practice of requiring at least one additional form of user authentication—besides a password—when accessing a remote network.

Detail:

Multifactor authentication refers to the use of more than one of the authentication means in the preceding list (see Figure 3.2). The strength of authentication systems is largely determined by the number of factors incorporated by the system. Implementations that use two factors are considered to be stronger than those that use only one factor; systems that incorporate three factors are stronger than systems that only incorporate two of the factors, and so on.

Multi-factor Authentication

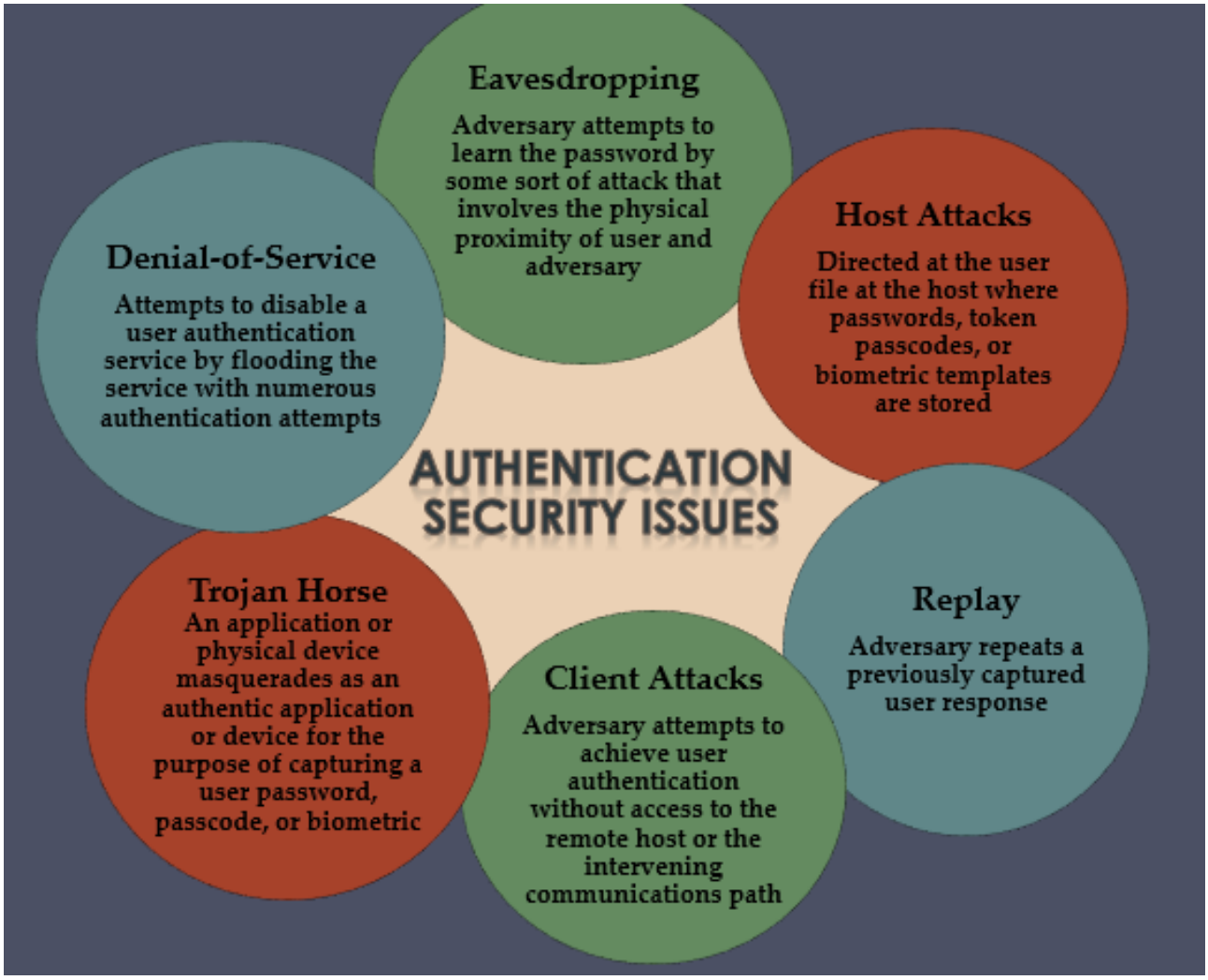
- Most Common Method for MFA
    - When logging in to a system remotely, the user first enters the regular password and is then prompted to enter the one-time password or passcode.
    - This is also commonly known as 2FA



Detail:

Multifactor authentication refers to the use of more than one of the authentication means in the preceding list (see Figure 3.2). The strength of authentication systems is largely determined by the number of factorsincorporated by the system. Implementations that use two factors are considered to be stronger than those that use only one factor; systems that incorporate three factors are stronger than systems that only incorporate two of the factors, and so on.

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)



Detail:

Client attacks are those in which an adversary attempts to achieve user authentication without access to the remote host or to the intervening communications path. The adversary attempts to masquerade as a legitimate user. For a password- based system, the adversary may attempt to guess the likely user password. Multiple guesses may be made. At the extreme, the adversary sequences through all possible passwords in an exhaustive attempt to succeed. One way to thwart such an attack is to select a password that is both lengthy and unpredictable. In effect, such a password has large entropy; that is, many bits are required to represent the password. Another countermeasure is to limit the number of attempts that can be made in a given time period from a given source. A token can generate a high-entropy passcode from a low-entropy PIN or password, thwarting exhaustive searches. The adversary may be able to guess or acquire the PIN or password but must additionally acquire the physical token to succeed.

Host attacks are directed at the user file at the host where passwords, token passcodes, or biometric templates are stored. Section 3.2 discusses the security considerations with respect to passwords. For tokens, there is the additional defense of using one-time passcodes, so that passcodes are not stored in a host passcode file. Biometric features of a user are difficult to secure because they are physical features of the user. For a static feature, biometric device authentication adds a measure of protection. For a dynamic feature, a challenge-response protocol enhances security.

Eavesdropping in the context of passwords refers to an adversary's attempt to learn the password by observing the user, finding a written copy of the password, or some similar attack that involves the physical

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

proximity of user and adversary. Another form of eavesdropping is keystroke logging (keylogging), in which malicious hardware or software is installed so that the attacker can capture the user's keystrokes for later analysis. A system that relies on multiple factors (e.g., password plus token or password plus biometric) is resistant to this type of attack. For a token, an analogous threat is theft of the token or physical copying of the token. Again, a multifactor protocol resists this type of attack better than a pure token protocol. The analogous threat for a biometric protocol is **copying** or imitating the biometric parameter so as to generate the desired template. Dynamic biometrics are less susceptible to such attacks. For static biometrics, device authentication is a useful countermeasure.

Replay attacks involve an adversary repeating a previously captured user response. The most common countermeasure to such attacks is the challenge-response protocol.

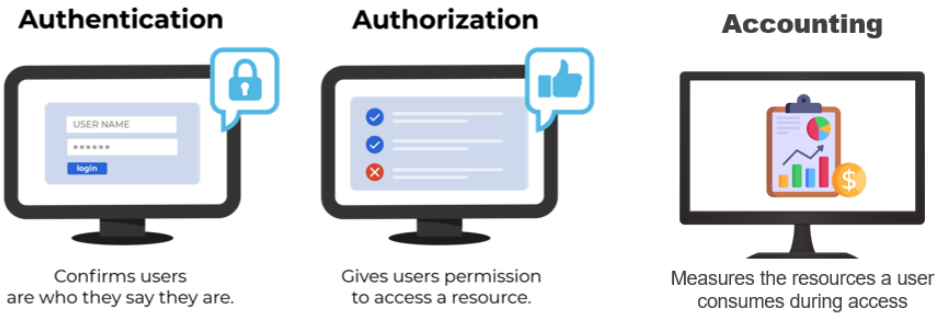
In a **Trojan horse** attack, an application or physical device masquerades as an authentic application or device for the purpose of capturing a user password, passcode, or biometric. The adversary can then use the captured information to masquerade as a legitimate user. A simple example of this is a rogue bank machineused to capture user ID/password combinations.

A **denial-of-service** attack attempts to disable a user authentication service by flooding the service with numerous authentication attempts. A more selective attack denies service to a specific user by attempting logon until the threshold is reached that causes lockout to this user because of too many logon attempts. A multifactor authentication protocol that includes a token thwarts this attack, because the adversary must first acquire the token.



Access Control

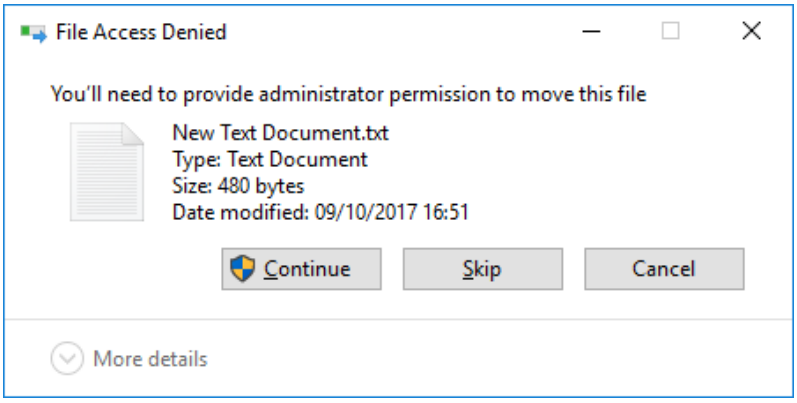
Recap



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Access Control

"The process of granting or denying specific requests to: (1) obtain and use information and related information processing services; and (2) enter specific physical facilities"

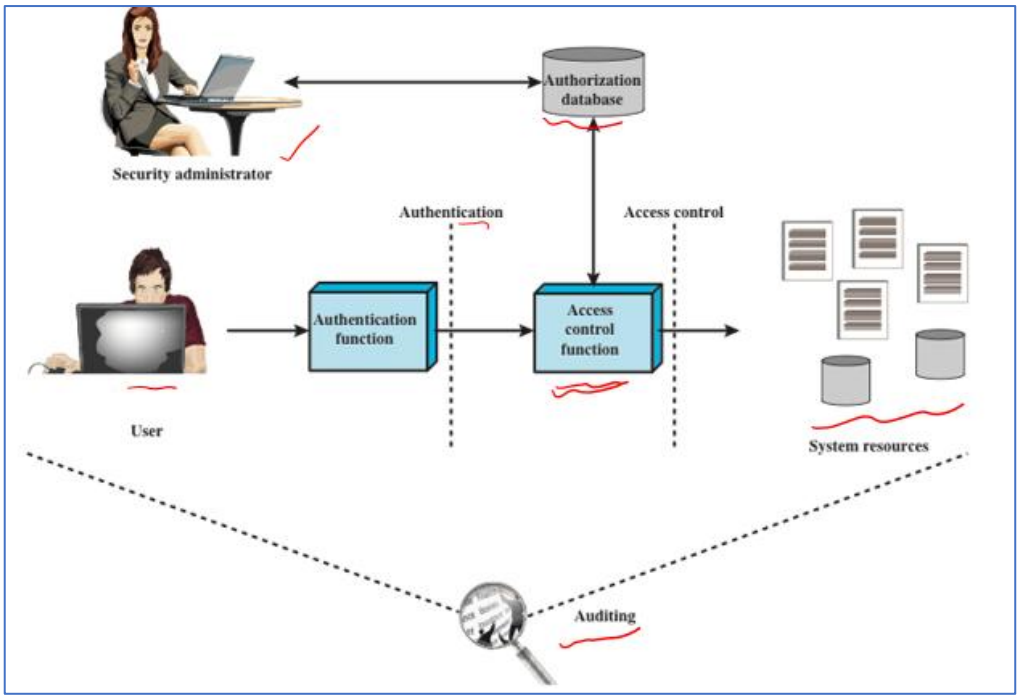




Detail:

Two definitions of access control are useful in understanding its scope.

1. NISTIR 7298 (*Glossary of Key Information Security Terms* , May 2013), defines access control as the process of granting or denying specific requests to: (1) obtain and use information and related information processing services; and (2) enter specific physical facilities.



Detail:

Figure 4.1 shows a broader context of access control. In addition to access control, this context involves the following entities and functions:

• **Authentication**: Verification that the credentials of a user or other system

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

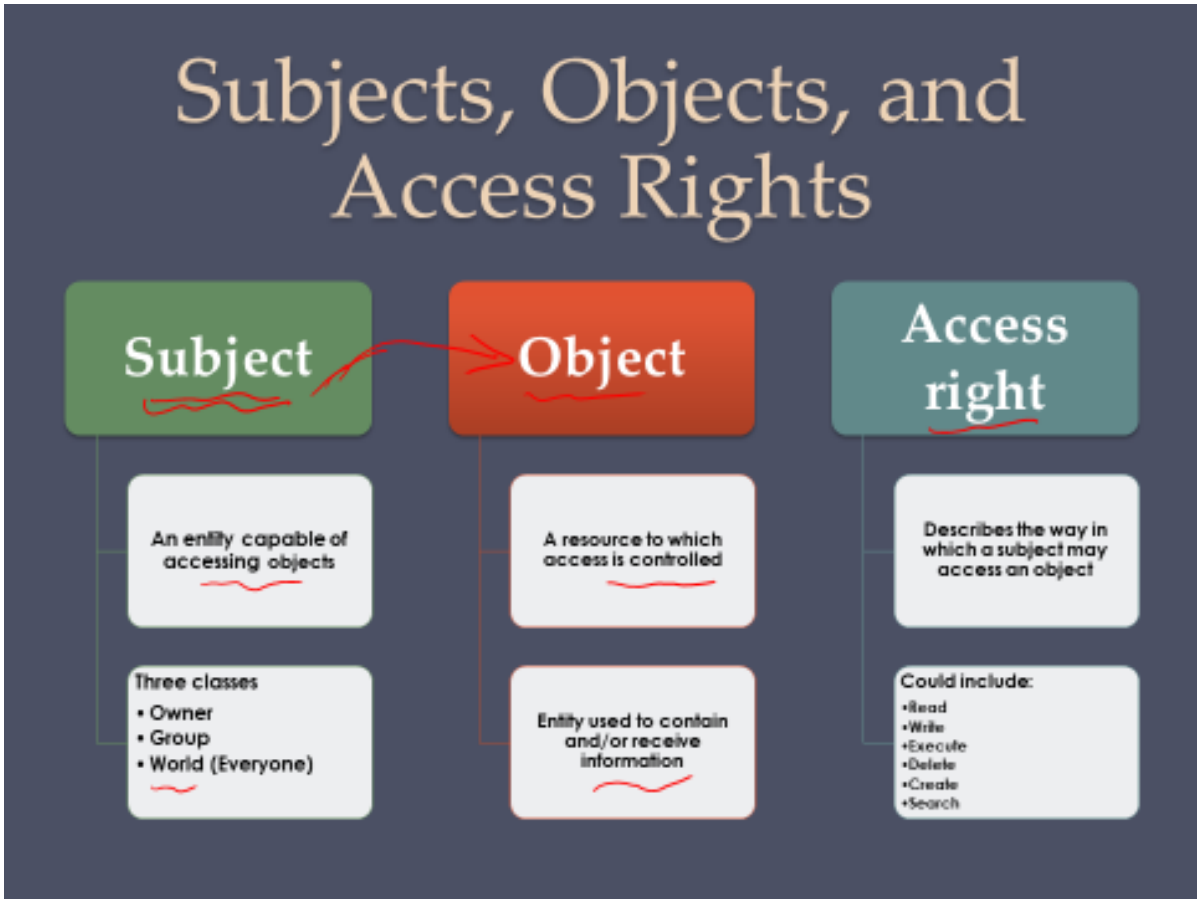
entity are valid.

- **Authorization:** The granting of a right or permission to a system entity to access a system resource. This function determines who is trusted for a given purpose.

• **Audit:** An independent review and examination of system records and activities in order to test for adequacy of system controls, to ensure compliance with established policy and operational procedures, to detect breaches in security, and to recommend any indicated changes in control, policy and procedures.

An access control mechanism mediates between a user (or a process executing on behalf of a user) and system resources, such as applications, operating systems, firewalls, routers, files, and databases. The system must first authenticate an entity seeking access. Typically, the authentication function determines whether the user is permitted to access the system at all. Then the access control function determines if the specific requested access by this user is permitted. A security administrator maintains an authorization database that specifies what type of access to which resources is allowed for this user. The access control function consults this database to determine whether to grant access. An auditing function monitors and keeps a record of user accesses to system resources.

In the simple model of Figure 4.1, the access control function is shown as a single logical module. In practice, a number of components may cooperatively share the access control function. All operating systems have at least a rudimentary, and in many cases a quite robust, access control component. Add-on security packages can supplement the native access control capabilities of the OS. Particular applications or utilities, such as a database management system, also incorporate access control functions. External devices, such as firewalls, can also provide access control services.



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Detail:

The basic elements of access control are: subject, object, and access right.

A **subject** is an entity capable of accessing objects. Generally, the concept of subject equates with that of process. Any user or application actually gains access to an object by means of a process that represents that user or application. The process takes on the attributes of the user, such as access rights.

A subject is typically held accountable for the actions they have initiated, and an audit trail may be used to record the association of a subject with security relevant actions performed on an object by the subject.

Basic access control systems typically define three classes of subject, with different access rights for each class:

• **Owner**: This may be the creator of a resource, such as a file. For system resources, ownership may belong to a system administrator. For project resources, a project administrator or leader may be assigned ownership.

• **Group:** In addition to the privileges assigned to an owner, a named group of users may also be granted access rights, such that membership in the group is sufficient to exercise these access rights. In most schemes, a user may belong to multiple groups.

• **World:** The least amount of access is granted to users who are able to access the system but are not included in the categories owner and group for this resource.

An **object** is a resource to which access is controlled. In general, an object is an entity used to contain and/or receive information. Examples include records, blocks, pages, segments, files, portions of files, directories, directory trees, mailboxes, messages, and programs. Some access control systems also encompass, bits, bytes, words, processors, communication ports, clocks, and network nodes.

The number and types of objects to be protected by an access control system depends on the environment in which access control operates and the desired tradeoff between security on the one hand and complexity, processing burden, and ease of use on the other hand.

An **access right** describes the way in which a subject may access an object.

Access rights could include the following:

• **Read:** User may view information in a system resource (e.g., a file, selected records in a file, selected fields within a record, or some combination). Read access includes the ability to copy or print.

• **Write**: User may add, modify, or delete data in system resource (e.g., files, records, programs). Write access includes read access.

• **Execute**: User may execute specified programs.

• **Delete:** User may delete certain system resources, such as files or records.

• **Create:** User may create new files, records, or fields.

• **Search:** User may list the files in a directory or otherwise search the directory.

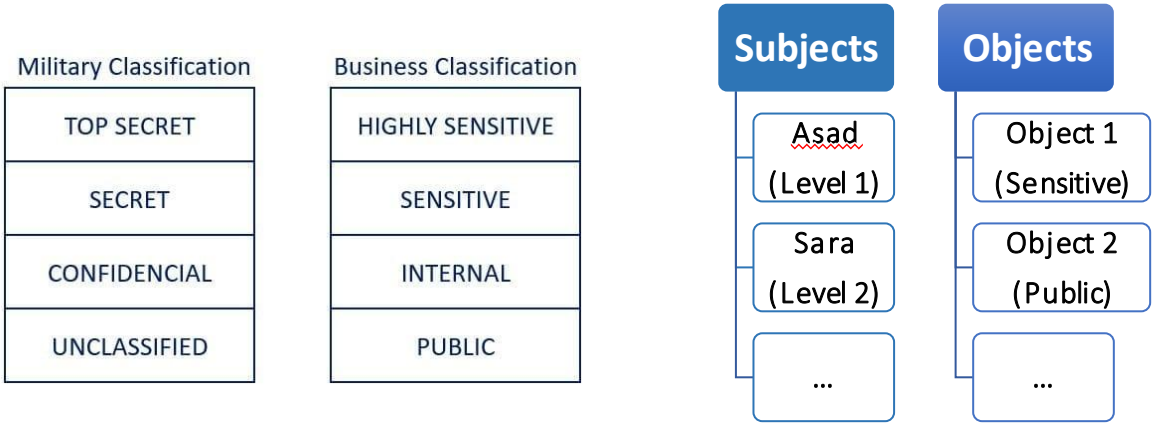
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)



Access Control Policies

- Mandatory access control (MAC)
- Discretionary access control (DAC)
- Role-based access control (RBAC)
- Attribute-based access control (ABAC)

Mandatory Access Control (MAC)

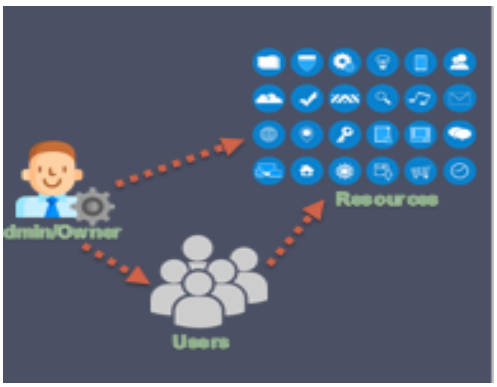


- Controls access based on comparing security labels (which indicate how sensitive or critical system resources are) with security clearances (which indicate system entities are eligible to access certain resources).
- This policy is termed *mandatory because*
    - *passing through security* clearance is *mandatory* for every user…

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

- *an entity that has* clearance to access a resource may not, just by its own volition, enable another entity to access that resource.
- Commonly used in organizations where confidentiality is very important e.g. military etc.
- The higher the clearance the more in depth the background checks should be.

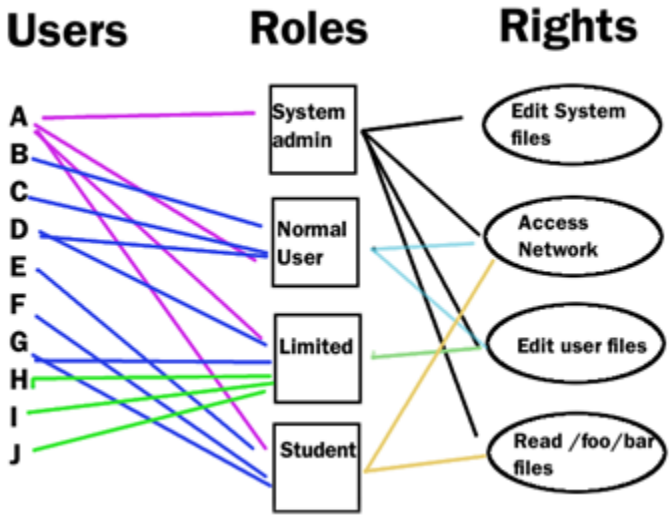
Discretionary Access Control (DAC)



Objects	Users: U1	U2	U3	U4	...	Un
O1		Read/ Write	Write	Read/ Write		
O2	Read					Write
O3	Write			Read/ Write		Read

- Scheme in which an entity may be granted access rights that permit the entity, by its own volition, to enable another entity to access some resource
  - Often provided using an **Access Matrix**
    - One dimension consists of identified subjects that may attempt data access to the resources
    - The other dimension lists the objects that may be accessed
  - Each entry in the matrix indicates the access rights of a particular subject for a particular object
  - Controls access based on the identity
  - Useful for small size organizations…

Role-based Access Control (RBAC)



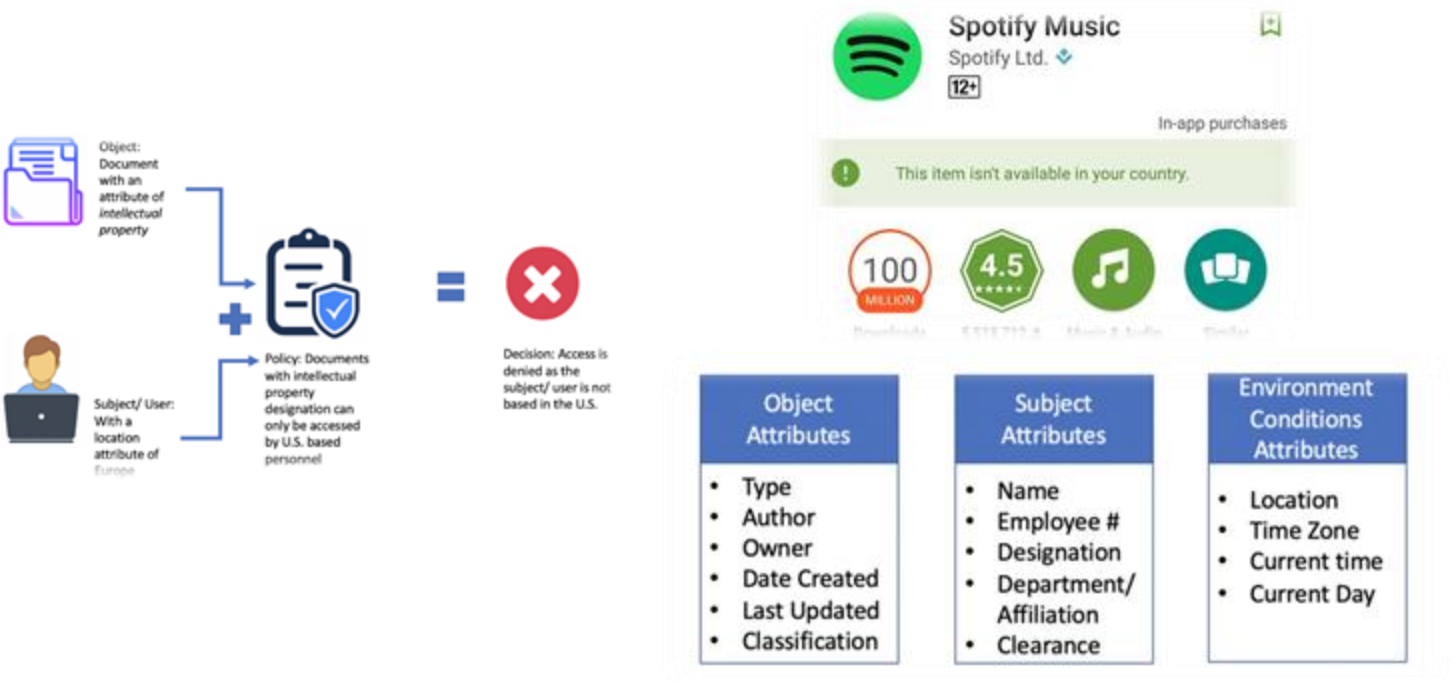
- DAC is not feasible for large size organizations…
  - Something better and easy to manage is needed

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

- Among such solutions is RBAC
- Controls access based on the roles that users have within the system and on rules stating what accesses are allowed to users in given roles.

Attribute-based Access Control (ABAC)

- Controls access based on attributes of the user, the resource to be accessed, and current environmental conditions and policies.



Detail:

As was previously stated, a discretionary access control scheme is one in which an entity may be granted access rights that permit the entity, by its own volition, to enable another entity to access some resource. A general approach to DAC, as exercised by an operating system or a database management system, is that of an **access matrix**. The access matrix concept was formulated by Lampson [LAMP69, LAMP71], and subsequently refined by Graham and Denning [GRAH72, DENN71] and by Harrison et al. [HARR76].

One dimension of the matrix consists of identified subjects that may attempt data access to the resources. Typically, this list will consist of individual users or user groups, although access could be controlled for terminals, network equipment, hosts, or applications instead of or in addition to users. The other dimension lists the objects that may be accessed. At the greatest level of detail, objects may be individual data fields. More aggregate groupings, such as records, files, or even the entire database, may also be objects in the matrix. Each entry in the matrix indicates the access rights of a particular subject for a particular object.

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Summary

- **Mandatory access control (MAC)**
    - Controls access based on comparing security labels with security clearances
- Discretionary access control (DAC)

Controls access based on the identity of the requestor and on access rules (authorizations) stating what requestors

- **Role-based access control (RBAC)**
    - Controls access based on the roles that users have within the system and on rules stating what accesses are allowed to users in given roles
- Attribute-based access control (ABAC)
    - Controls access based on attributes of the user, the resource to be accessed, and current environmental conditions

Detail:

An access control policy, which can be embodied in an authorization database, dictates what types of access are permitted, under what circumstances, and by whom. Access control policies are generally grouped into the following categories:

• **Discretionary access control** (DAC): Controls access based on the identity of the requestor and on access rules (authorizations) stating what requestors are (or are not) allowed to do. This policy is termed *discretionary because an* entity might have access rights that permit the entity, by its own volition, to enable another entity to access some resource.

• **Mandatory access control** (MAC): Controls access based on comparing security labels (which indicate how sensitive or critical system resources are) with security clearances (which indicate system entities are eligible to access certain resources). This policy is termed *mandatory because an entity that has* clearance to access a resource may not, just by its own volition, enable another entity to access that resource.

• **Role-based access control (**RBAC): Controls access based on the roles that users have within the system and on rules stating what accesses are allowed to users in given roles.

• **Attribute-based access control** (ABAC): Controls access based on attributes of the user, the resource to be accessed, and current environmental conditions. DAC is the traditional method of implementing access control, and is examined in Sections 4.3 and 4.4. MAC is a concept that evolved out of requirements for military information security and is best covered in the context of trusted systems, which we deal with in Chapter 27. Both RBAC and ABAC have become increasingly popular, and are examined in Sections 4.5 and 4.6, respectively.

These four policies are not mutually exclusive. An access control mechanism can employ two or even all three of these policies to cover different classes of system resources.

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

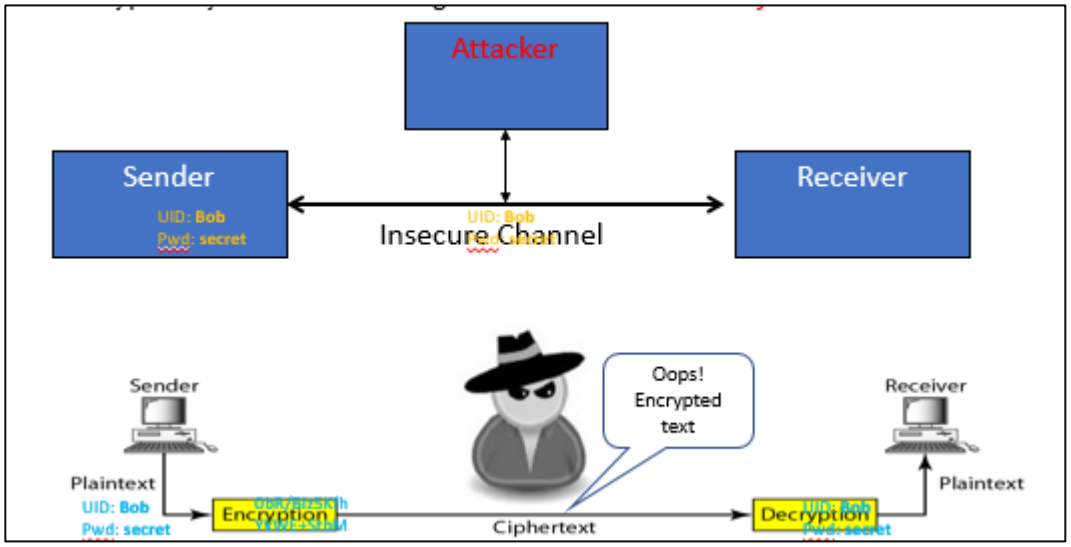
Week#3(Cryptography)

What is cryptography?

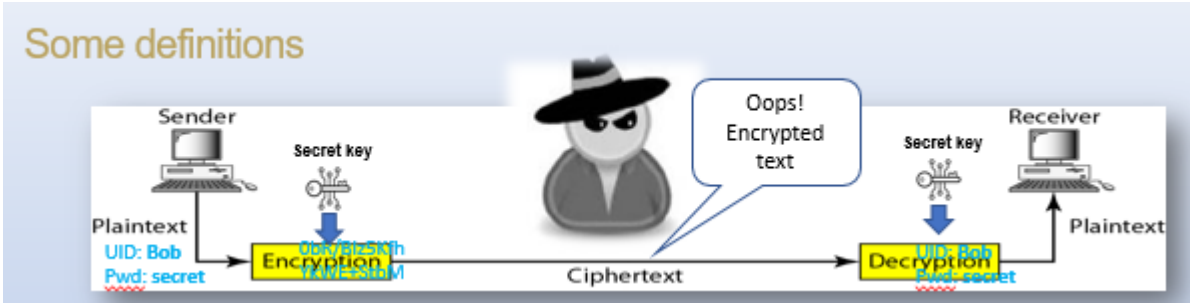
- **Cryptography**
  - The art of secret writing
  - Cryptography is the making
  - **Cryptanalysis**
    - Cryptanalysis is the breaking

- **Why Cryptography?**

  Cryptography aims to provide secure communications in the presence of an adversary/attacker



Cryptography



Plaintext: This is the original message or data that is to be secured.
Encryption algorithm: This is the mechanism of securing the message and data. The encryption algorithm performs various substitutions and transformations on the plaintext.
Secret key: The secret key is also input to the algorithm. The exact substitutions and transformations performed by the algorithm depend on the key.
Ciphertext: This is the scrambled message produced as output. It depends on the plaintext and the secret key. For a given message, two different keys will produce two different ciphertexts.
Decryption algorithm: This is essentially the encryption algorithm run in reverse. It takes the ciphertext and the same secret key and produces the original plaintext.

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

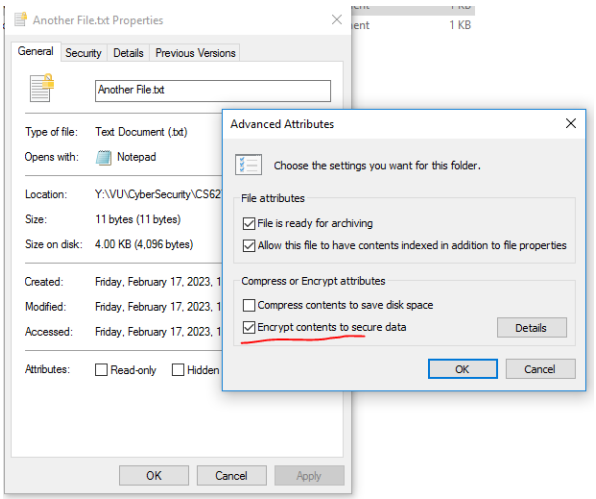
Data Security

- **Access Control** who can access the data
- **Monitoring** who is using the data and how
- **Data Encryption** strong encryption is required to transform the data from plaintext (or human readable format) to cipher text
- **Stages of Data**
  - Data at rest
  - Data in transit
  - Data in use
- **Cryptographic algorithms** helps to protect the data in all stages from un-authorized access and alteration

Data Security

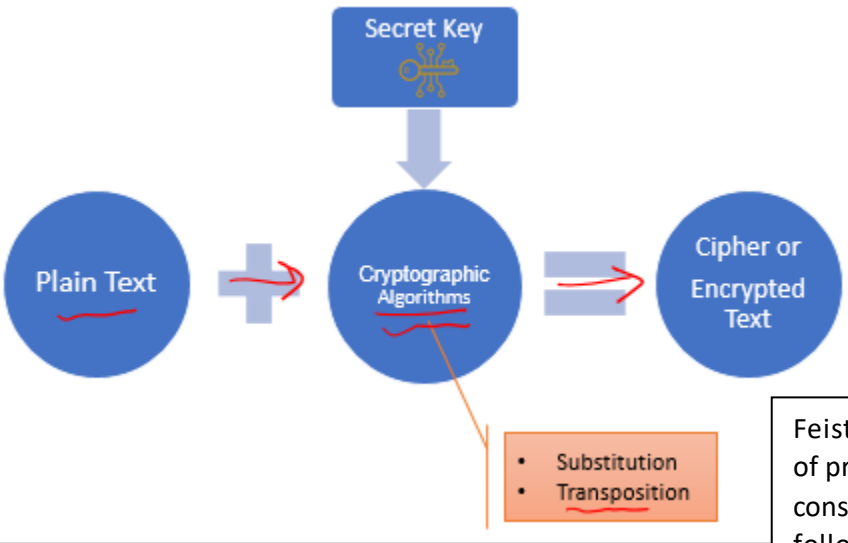
Is it good to encrypt your files always?

- Encrypt when its needed…
- Be careful with Keys when encrypted…
- Windows files security
  - Access rights
  - Encryption



Cryptographic Algorithms and Kerchoff's Principle

Cryptographic Algorithms also referred as Ciphers or Encryption Algorithms

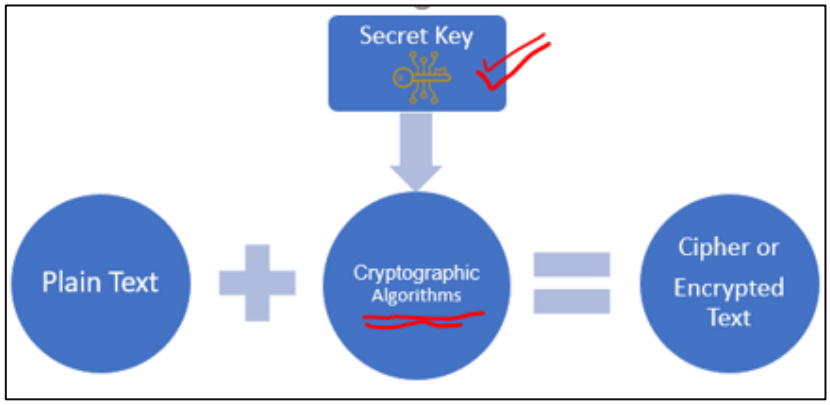


Feistel network consisting multiple rounds of processing of the plaintext, each round consisting of a "substitution" step followed by a permutation step.

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Kerckhoffs's principle of cryptography was stated by Dutch-born cryptographer Auguste Kerckhoffs in the 19th century.

- Kerckhoff's principle is the concept that a Cryptographic system should be designed to be secure, even if all its details, except for the key, are publicly known.



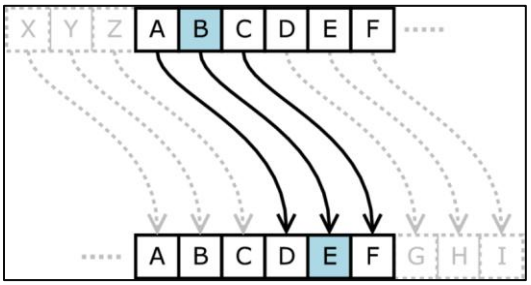
- In other words,
  - Secrecy of the cryptographic system should rely on the secret keys
  - No need to hide the procedure or algorithm for encryption
  - Rather, its better if procedure or algorithm for encryption are made public as this will help in identification and removing the flaws/loopholes

A B C D E F G H I J K L M N O P Q R S T U V W X Y Z

Classical Ciphers

The Caesar Cipher

The Caesar cipher is one of the earliest and simplest methods of encryption technique and is based on substitution and involves shifting each letter of the plaintext message by a certain number of letters,



- **Caesars cipher**
  - Replace every 'A' in the message with a 'D'
  - Replace every 'B' in the message with a 'E'
  - Replace every 'C' in the message with a 'F', etc.

- **Considerations**
  - Algorithms are public (Kerchoff's Principle)
  - Encrypt/decrypt depends on a key
  - The only secret is the key
  - For Caesars cipher, key is ***n***, since shift forward ***n*** to encrypt, shift backward n to decrypt
  - Encryption: $C_i = (P_i + n) \bmod 26$

Decryption: $P_i = (C_i - n) \bmod 26$

Text : **ATTACKATONCE**

Shift: **4**

Cipher: EXXEGOEXSRGI

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Caesar Cipher

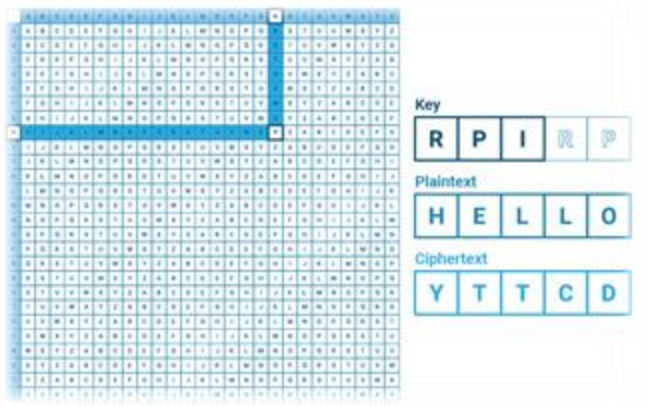
Cryptanalysis of Caesar Cipher – Brute force

- Ciphertext = "GRR MGAR OY JOBOJKJ OT ZNXKK VGXZY"
- Perform decryption with each possible key:
- Plaintext with n= 1
- FQQ LFZQ NX INANIJI NS YMWJJ UFWYX
- Plaintext with n= 2
- EPP KEYP MW HMZMHIH MR XLVII TEVXW
- Plaintext with n= 3
- DOO JDXO LV GLYLGHG LQ WKUHH SDUWV
- Plaintext with n= 4
- CNN ICWN KU FKXKFGF KP VJTGG RCTVU
- Plaintext with n= 5
- BMM HBVM JT EJWJEFE JO UISFF QBSUT
- Plaintext with n= 6
- ALL GAUL IS DIVIDED IN THREE PARTS

Classical Ciphers

Vigenere Cipher

- Developed in 1553.
- It is a method of encrypting alphabetic text by using a series of interwoven Caesar ciphers, based on the letters of a keyword.
- Its based on polyalphabetic substitution
- Key: A word W of Length M.
- Plain text P of length N.
- Repeat the Key until it matches the length of the plain text.
- For each letter P_j of the plain text, apply a Caesar Cipher of length W_j



Example

Key: **RPI**

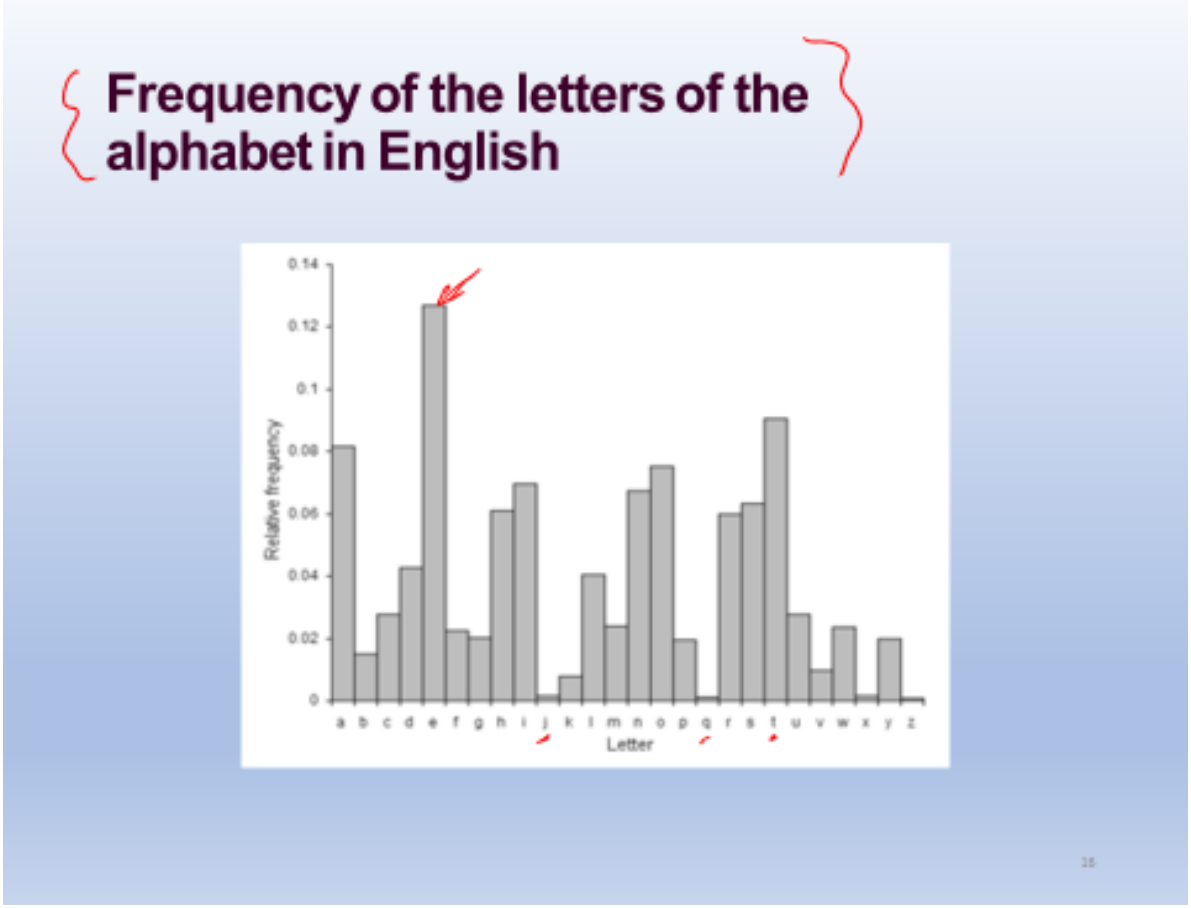
Plain Text: HELLO
Expanded key: RPIRP
Cipher Text: YTTCD

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Exercise

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
A	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
B	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A
C	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B
D	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C
E	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D
F	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E
G	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F
H	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G
I	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H
J	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I
K	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J
L	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K
M	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L
N	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M
O	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N
P	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
Q	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
R	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q
S	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R
T	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S
U	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T
V	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U
W	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V
X	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W
Y	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X
Z	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y

- *The apple is in the corner and the pear is there too (plain)*
- *cat (key)*
- *Find the cipher?*
- *the app lei sin the cor ner and the pea ris the ret oo (plain)*
- *cat cat cat cat cat cat cat cat cat cat cat cat cat ca (key)*
- *Answer*
- *Vhx cpi neb uig vhx eok pek cnw vhx ret til vhx tem qo (cipher)*



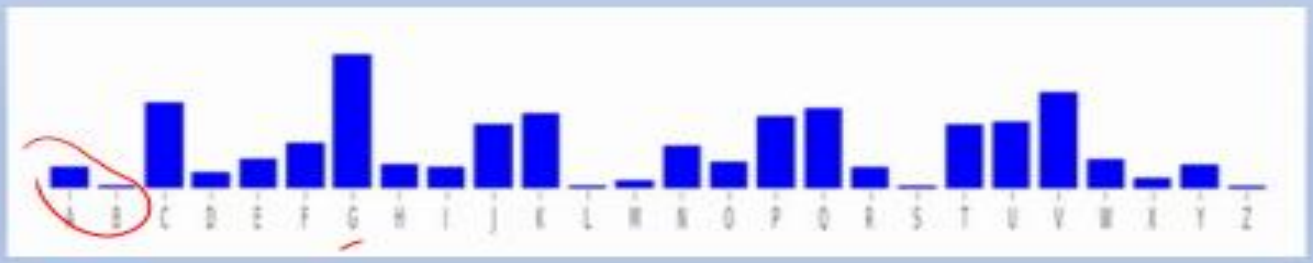
This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Caesar Cipher

Cryptanalysis of Caesar Cipher



Frequency analysis of Plain Text



Frequency analysis of Caesar Cipher Text

Vigenere Cipher

Cryptanalysis of Vigenere Cipher



Frequency analysis of Plain Text



Frequency analysis of Vigenere Cipher Text

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Vigenere Cipher



Cryptanalysis of Vigenere Cipher

- Three steps
  - Find the length of the key (Kasiski test)
  - Divide the message into that many shift cipher encryptions.
  - Use frequency analysis to solve the resulting shift ciphers.

Cipher Text A Q R T U V Q S T V V X S L M P O R ---

A Q R T U V Q S T V V X S L M P O R ---

4

A U

Q V

R

T

C

D

?

?

Cryptanalysis of Vigenere cipher: not just how, but why it

Modern Cryptography Algorithm Types

Symmetric Cryptography



- Need a strong encryption algorithm*
- Secure Key Exchange
- Its relatively fast

Asymmetric Cryptography

also knows as Public Key Cryptography

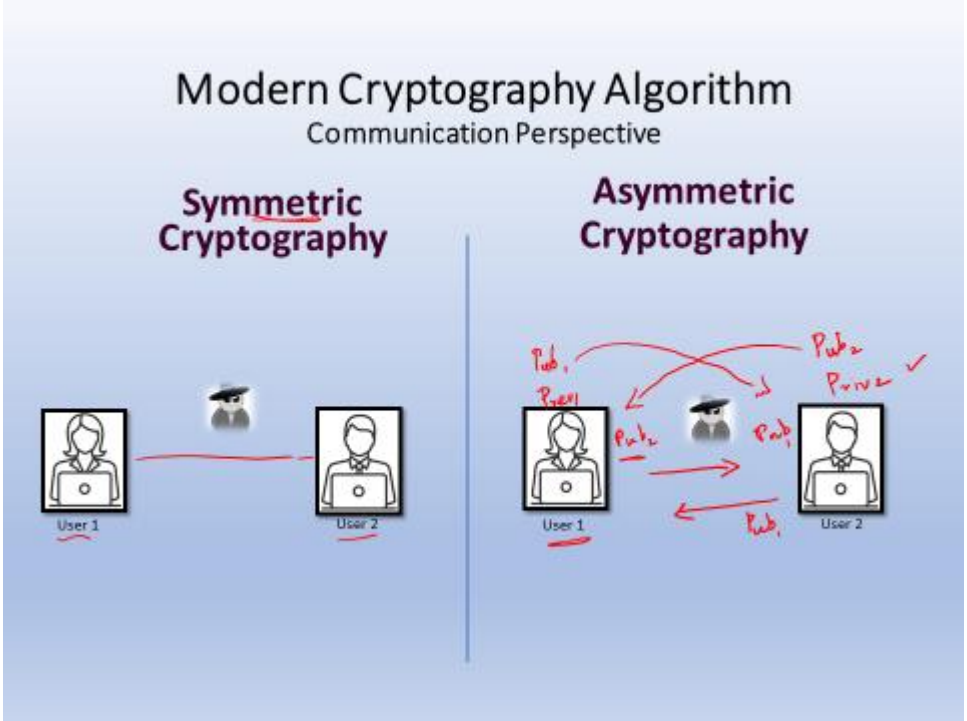


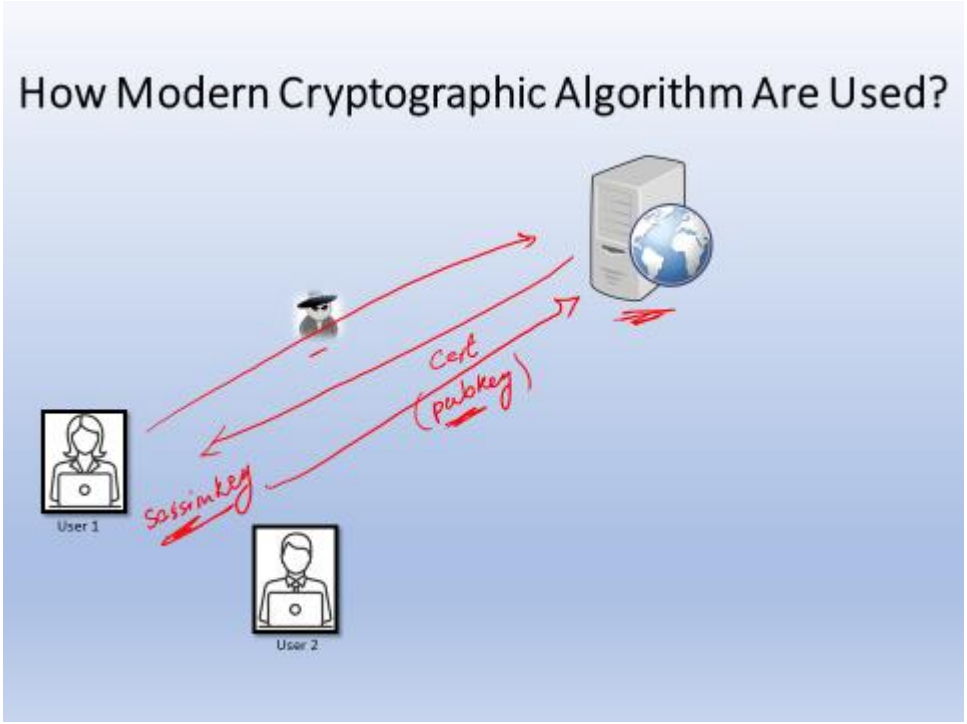
- Public and private keys are mathematically related
- **The private key** is never shared
- Its relatively slow

https://www.ssl2buy.com/wiki/symmetric-vs-asymmetric-encryption-what-are-differences

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

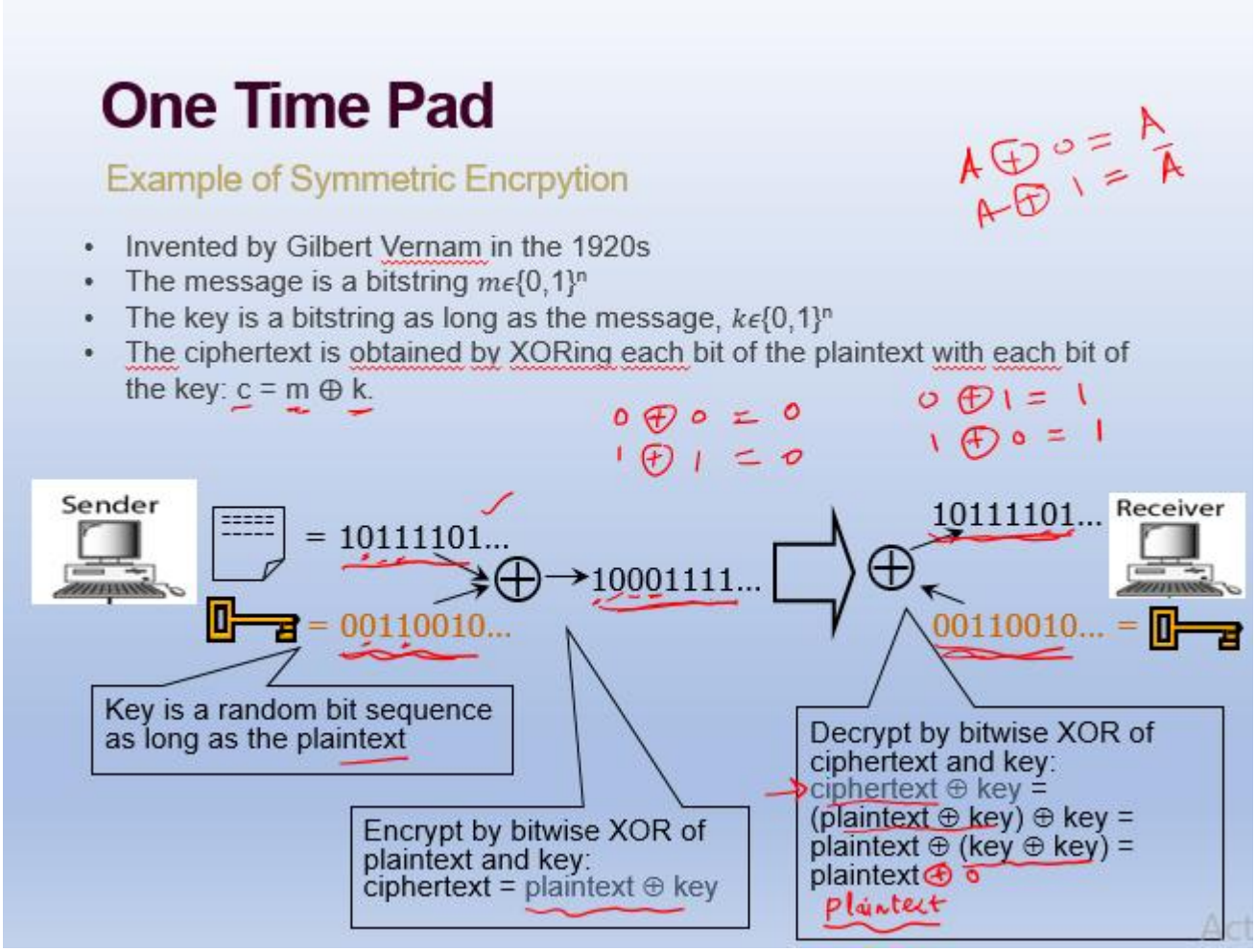




Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Five Aspect of security:

- **Confidentiality**
  - Assurance that information is not disclosed to unauthorized individuals even they get access to it (**Encryption**)
- **Integrity**
  - Information is not tampered by any unauthorized entities, if tempered then receiver must be able to detect that (**Hashing**)
- **Availability**
  - Authorized users have timely and easy access to information when needed (**IDS and IPS**)
- **Authenticity**
  - Prevents impersonation and enables receiver to **verify the sender of the message is who he claimed to be (Digital signature)**
- **Non-Repudiation**
  - Sender can't deny after sending the message (**Digital signature**)



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

One Time Pad Advantages

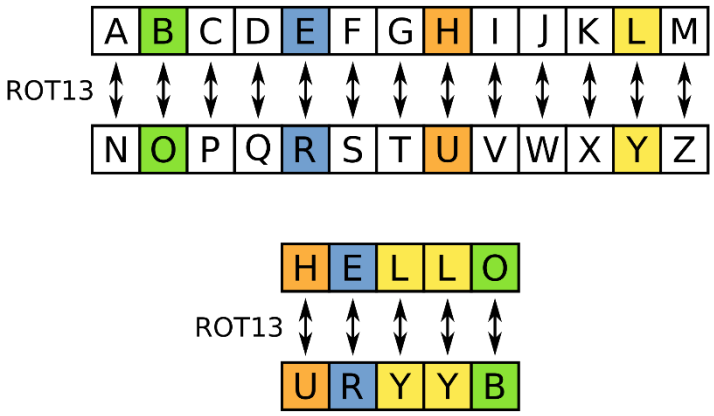
- **Easy to compute**
  - Encryption and decryption are the same operation
  - Bitwise XOR is very cheap to compute
- **As secure as theoretically possible**
  - Given a ciphertext, all plaintexts are equally likely, regardless of attacker's computational resources
  - if and only if the key sequence is truly random
    - True randomness is expensive to obtain in large quantities

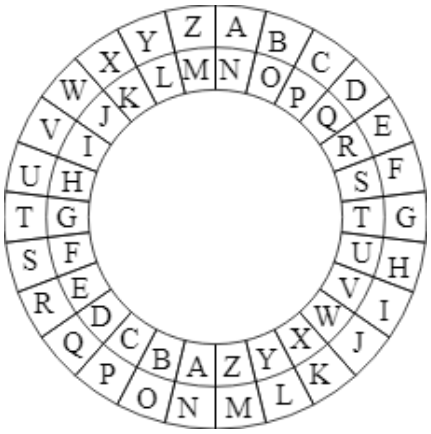
Disadvantages

- Key must be as long as the plaintext
  - Impractical in most realistic scenarios
  - Still used for diplomatic and intelligence traffic
- Does not guarantee integrity
  - One-time pad only guarantees confidentiality
  - Attacker cannot recover plaintext, but can easily change it to something else
- Insecure if keys are reused
  - Attacker can obtain XOR of plaintexts

Symmetric Encryption

ROT13
ROT13 cipher(read as – "rotate by 13 places") is a special case of the Ceaser cipher in which the shift is always 13.
This is an example of substitution **cipher**





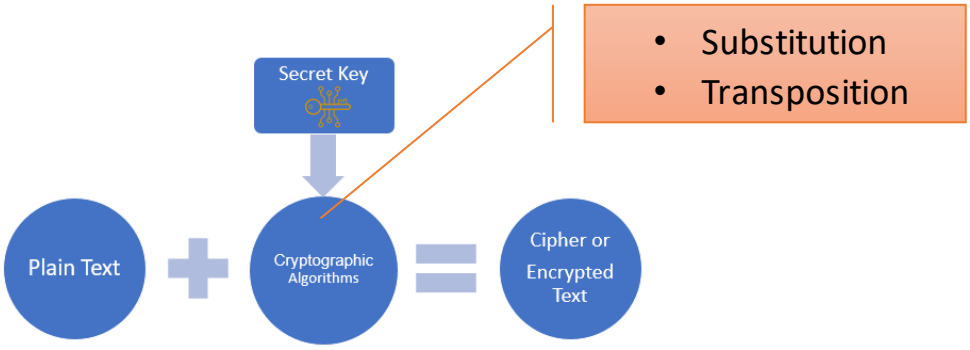
Poor Encryption: ROT13
No "key"
Susceptible to frequency analysis
Susceptible to brute forcing

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Confusion and Diffusion

Properties of the operation of a secure cipher

- Concept was originally presented by Claude Shannon in 1945



- Confusion refers to making the relationship between the Ciphertext and the Key as complex and involved as possible;
    - Make use of Substitution
    - Diffusion refers to dissipating the statistical structure of Plaintext over the bulk of Ciphertext
    - Make use of Transposition

Feistel Cipher/Network consisting multiple rounds of processing of the plaintext, each round consisting of a "substitution" step followed by a permutation step.

Operational Modes of Symmetric Encryption

Symmetric encryption schemes follows two distinct modes of operation:

Stream Cipher

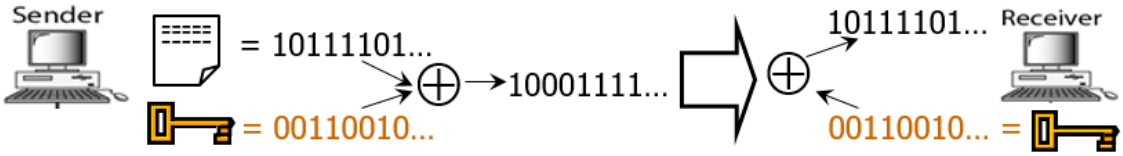
- Plain text is encrypted bit by bit
- Plain text and key are XORed
- **Block Cipher**
- Plain text is encrypted block by block
- The whole block is encrypted with a key

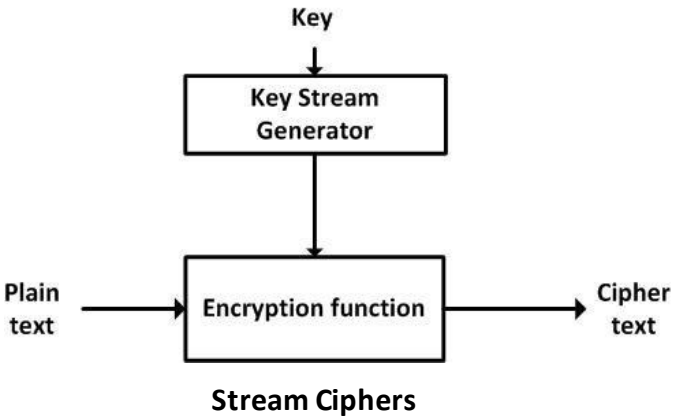
Stream Ciphers

- Each bit of plaintext is encrypted one by one, with the corresponding bit of the keystream, obtaining a bit of ciphertext.
- To describe a stream cipher, it is enough to describe the key stream generator. Once the key stream is obtained, it works like the one- time pad.
- The key stream must be generated from a random seed

This document is available on studocu

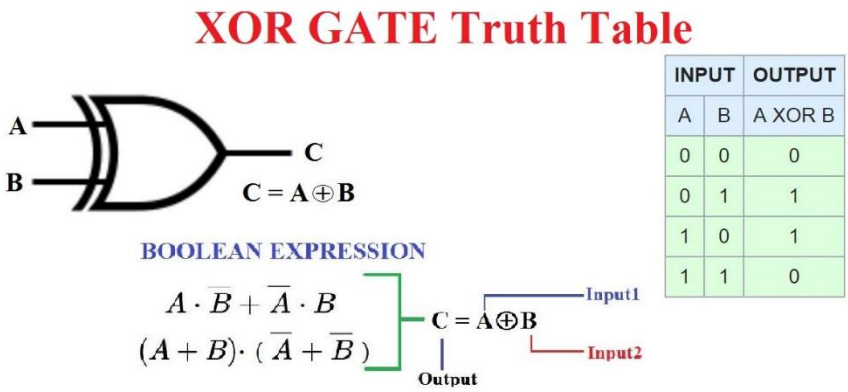
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)



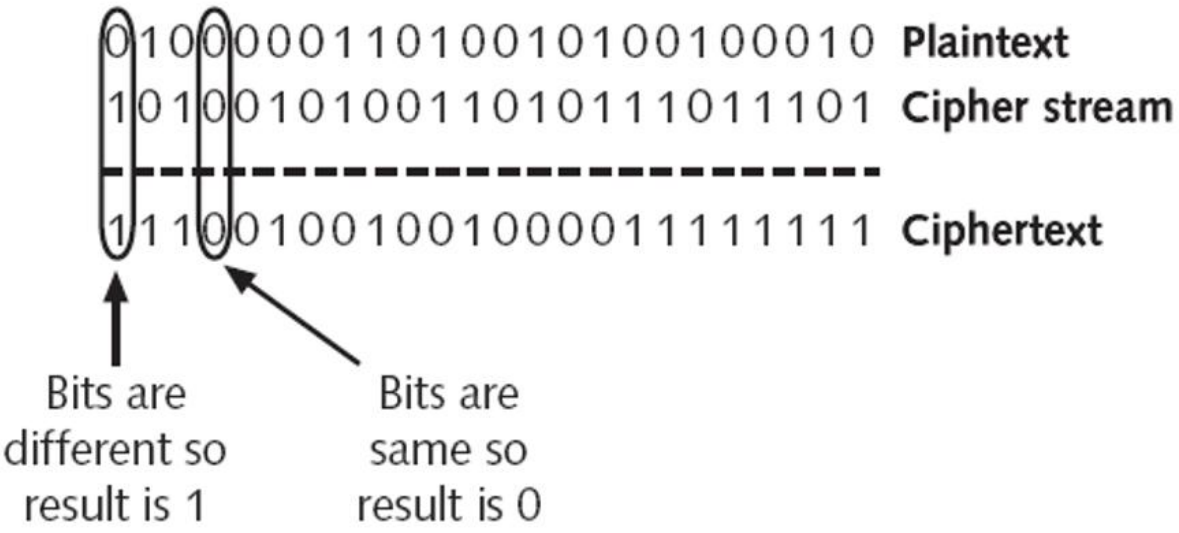


Stream Ciphers

Stream Encryption



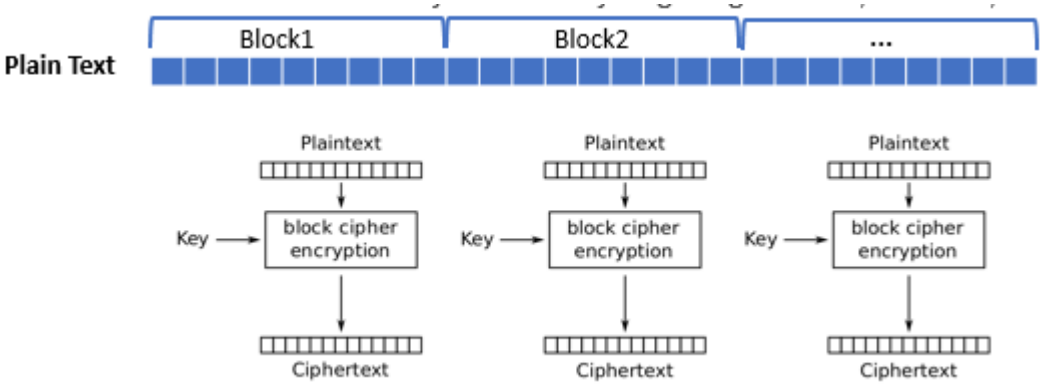
INPUT		OUTPUT
A	B	A XOR B
0	0	0
0	1	1
1	0	1
1	1	0



Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

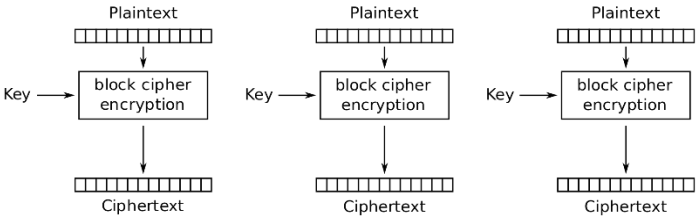
Block Ciphers

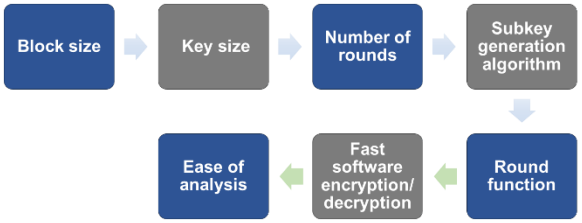
- Block ciphers operate on blocks of plaintext one at a time to produce blocks of ciphertext.
- The encryption of a bit in a plaintext will depend on the other bits in the block.
- The block sizes are usually reasonably large e.g. 64 bits, 128 bits, even more.



- The most famous block cipher is DES (Data Encryption Standard).
- Since DES is the most studied scheme and the design principles of DES have inspired a lot of ciphers used nowadays, we will have a slight view of DES

Block Ciphers Design Considerations





	DES	Triple DES	AES
Plaintext block size (bits)	64	64	128
Ciphertext block size (bits)	64	64	128
Key size (bits)	56	112 or 168	128, 192, or 256

DES = Data Encryption Standard
AES = Advanced Encryption Standard

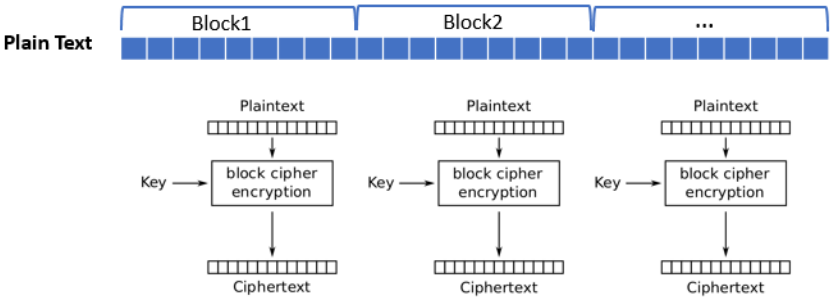
- Processes the input one block of elements at a time
- Produces an output block for each input block
- **Block size:** Larger block sizes mean greater security (all other things being equal) but reduced encryption/decryption speed. block size of 128 bits is a reasonable trade-off.
- **Key size**: Larger key size means greater security but may decrease encryption/ decryption speed. The most common key length in modern algorithms is 128 bits.
- **Number of rounds**: The essence of a symmetric block cipher is that a single round offers inadequate security but that multiple rounds offer increasing security. A typical size is 16 rounds.
- **Subkey generation algorithm** : Greater complexity in this algorithm should lead to greater difficulty of cryptanalysis.
- **Round function**: Again, greater complexity generally means greater resistance to cryptanalysis.
- **Fast software encryption/decryption:** In many cases, encryption is embedded in applications or utility functions and the speed of execution of the algorithm becomes a concern.
- **Ease of analysis:** Although we would like to make our algorithm as difficult as possible to cryptanalyze, there is great benefit in making the algorithm easy to analyze vulnerabilities.

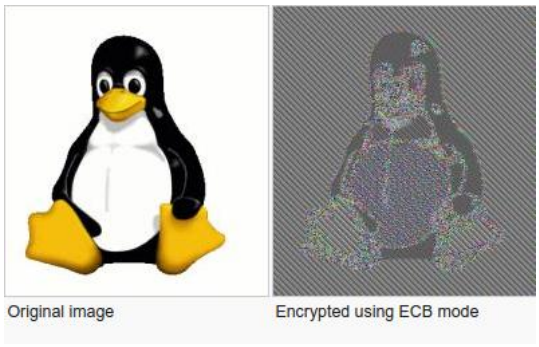
This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Block Cipher Modes - Symmetric Encryption

Practical Security Issues

- Typically, symmetric encryption is applied to a unit of data larger than a single 64-bit or 128-bit block.
- The simplest approach to multiple-block encryption:
  - Each block of plaintext is encrypted using the same key
  - Cryptanalysts may be able to exploit regularities in the plaintext
  - This is commonly known as **Electronic Code Book (ECB) mode**



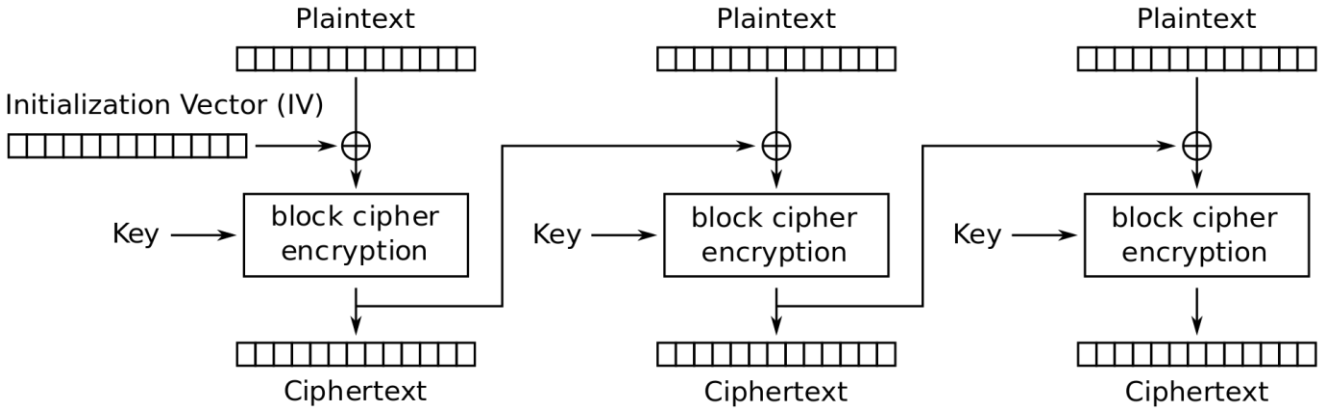


- Alternative techniques developed to increase the security of symmetric block encryption for large sequences
- Overcomes the weaknesses of ECB
- Consequently…different Block cipher modes were designed

- **Electronic Code Book (ECB) Mode**
- Cipher Block Chaining (CBC) Mode
- Cipher Feedback Mode (CFB)
- Output Feedback Mode (OFM)
- Counter mode (CTR)

Cipher Block Chaining Mode

- Input to encryption algorithm is XOR of next 64-bits plaintext and preceding 64-bits ciphertext
- Typical applications: General-purpose block-oriented transmission; authentication
- Initialization Vector (IV) must be known by sender/receiver, but secret from attacker

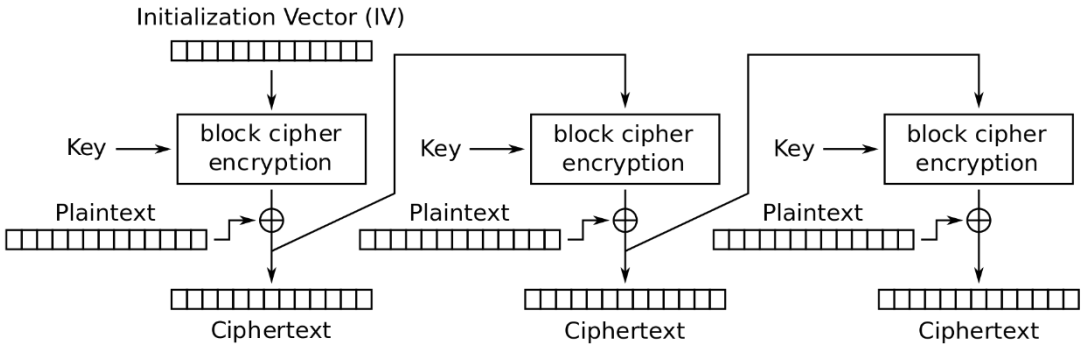


Cipher Feedback Mode

- Converts block cipher into stream cipher
- No need to pad message to integral number of blocks
- Operate in real-time: each character encrypted and transmitted immediately
- Input processed *s* bits at a time
- Preceding ciphertext used as input to cipher to produce pseudo-random output

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

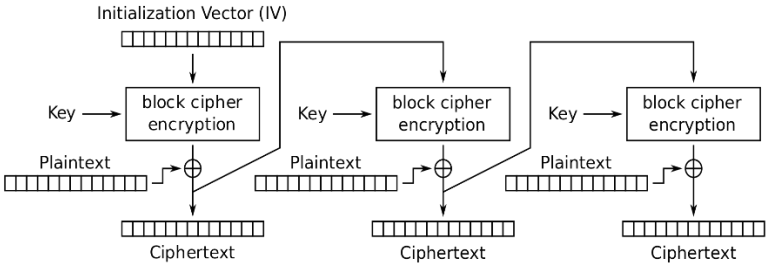
- XOR output with plaintext to produce ciphertext
- Typical applications: General-purpose stream-oriented transmission; authentication



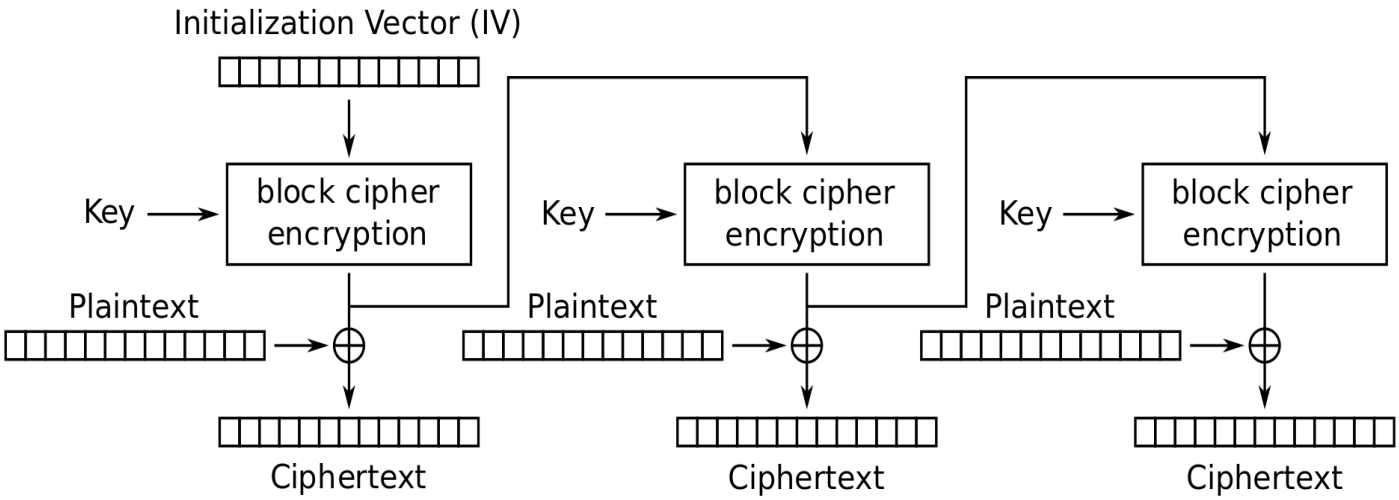
Cipher Feedback (CFB) mode encryption

Output Feedback Mode

- Converts block cipher into stream cipher
- Similar to CFB, except input to encryption algorithm is preceding encryption output
- Typical applications: stream-oriented transmission over noisy channels (e.g. satellite communications)
- Advantage compared to OFB: bit errors do not propagate
- Disadvantage: more vulnerable to message stream modification attack



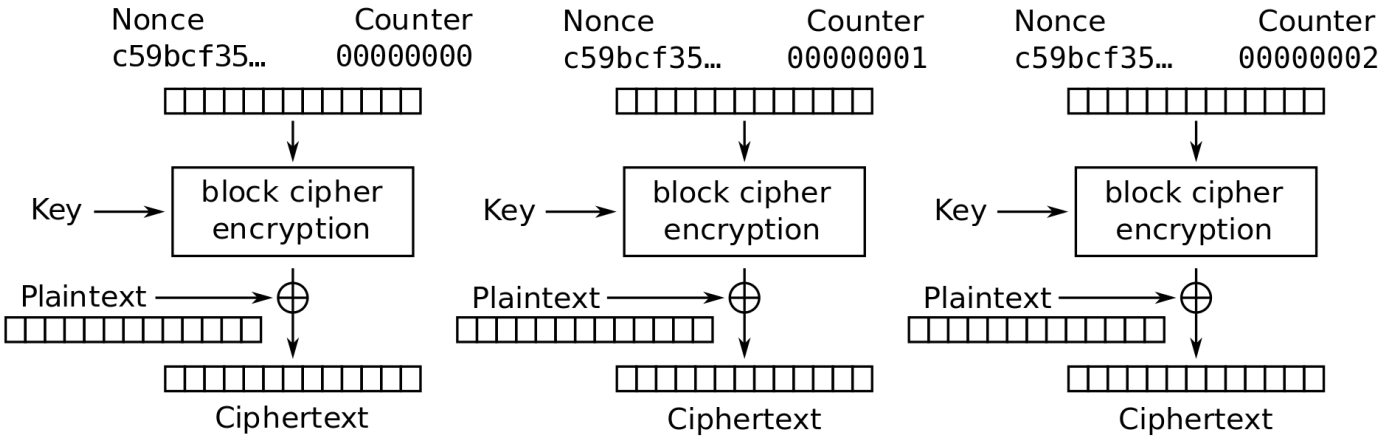
Cipher Feedback (CFB) mode encryption



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Counter Mode

- Converts block cipher into stream cipher
- Each block of plaintext XORed with encrypted counter
- Typical applications: General-purpose block-oriented transmission; useful for high speed requirements
- Efficient hardware and software implementations
- Simple and secure



Block Cipher Modes - Symmetric Encryption (Summary)

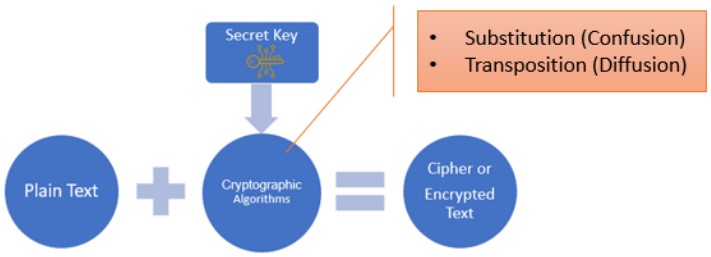
Mode	Description	Typical Application
Electronic Codebook (ECB)	Each block of 64 plaintext bits is encoded independently using the same key.	-Secure transmission of single values (e.g., an encryption key)
Cipher Block Chaining (CBC)	The input to the encryption algorithm is the XOR of the next 64 bits of plaintext and the preceding 64 bits of ciphertext.	-General-purpose block-oriented transmission -Authentication
Cipher Feedback (CFB)	Input is processed *s* bits at a time. Preceding ciphertext is used as input to the encryption algorithm to produce pseudorandom output, which is XORed with plaintext to produce next unit of ciphertext.	-General-purpose stream-oriented transmission -Authentication
Output Feedback (OFB)	Similar to CFB, except that the input to the encryption algorithm is the preceding DES output.	-Stream-oriented transmission over noisy channel (e.g., satellite communication)
Counter (CTR)	Each block of plaintext is XORed with an encrypted counter. The counter is incremented for each subsequent block.	-General-purpose block-oriented transmission -Useful for high-speed requirements

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Attack Strategies on Symmetric Encryption

Brute-force Attacks

- Try all possible keys on some ciphertext until an intelligible translation into plaintext is obtained
- On average half of all possible keys must be tried to achieve success
- Number of Keys are dictated by the key size.

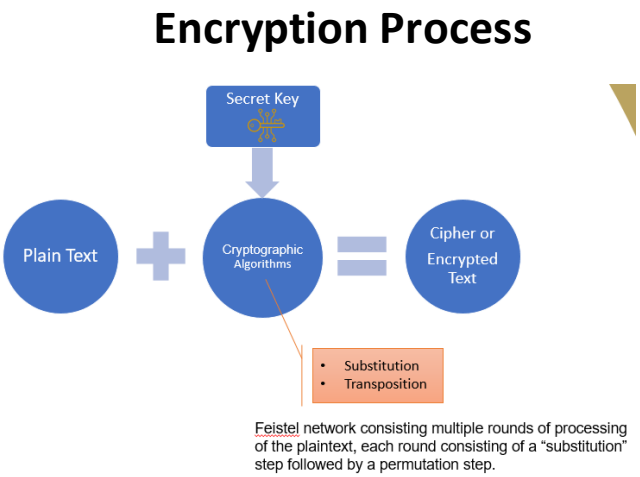


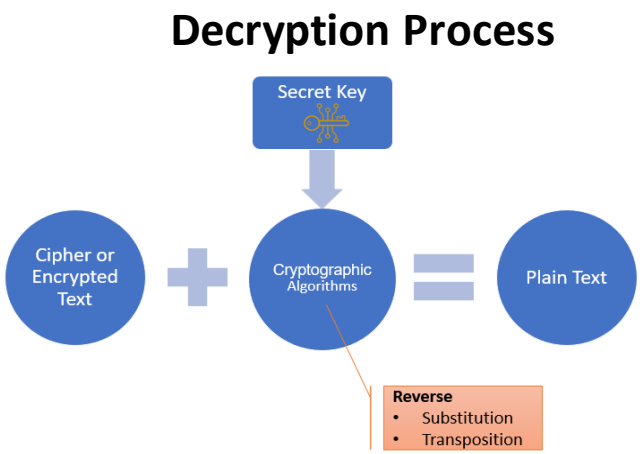
Cryptanalytic Attacks

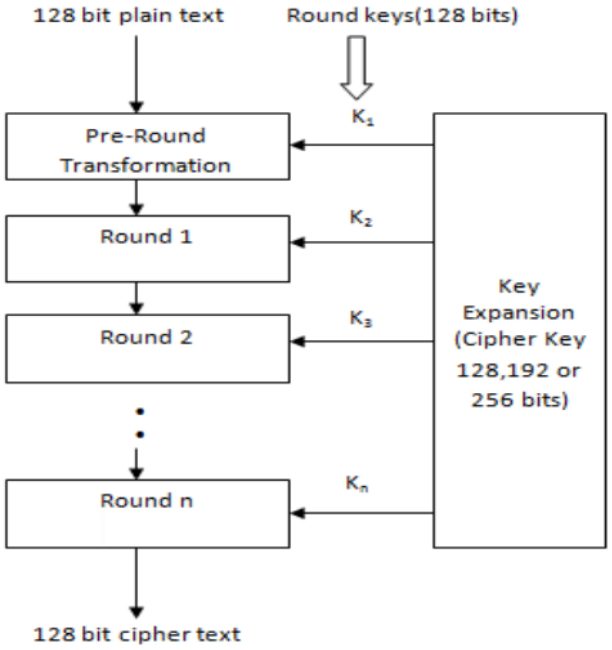
- Rely on:
  - Nature of the algorithm
  - Some knowledge of the general characteristics of the plaintext
  - Some sample plaintext-ciphertext pairs
- Exploits the characteristics of the algorithm to attempt to deduce a specific plaintext or the key being used
  - If successful, all future and past messages encrypted with that key are compromised

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Encryption/Decryption Process



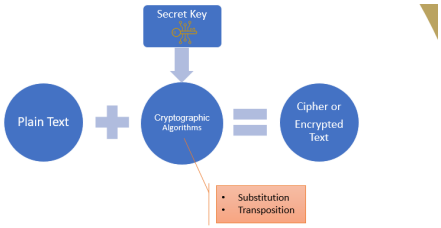




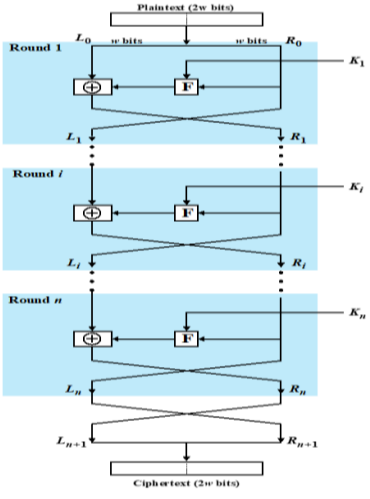
We want to make encryption process hard for attacker to break our algorithm…How?

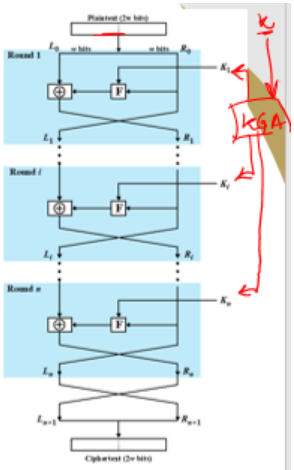
More rounds, complex substitutions and transposition But users with the key should be able decrypt it easily…How?

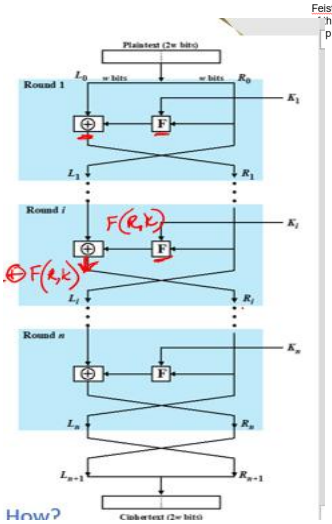
Feistel Network



Feistel Network - Symmetric Encryption







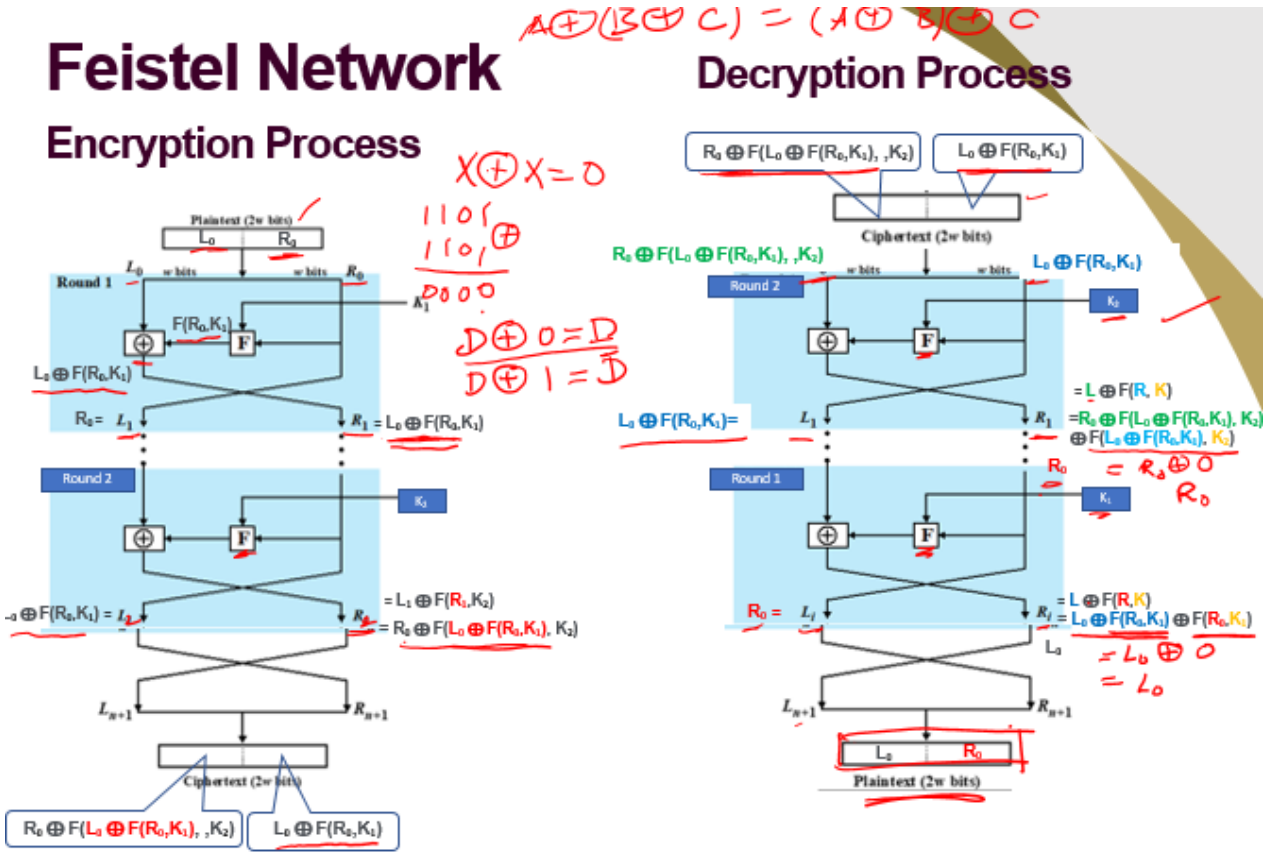
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

- Many encryption algorithms incorporate a structure first proposed by Horst Feistel of IBM (1973); a **Feistel Network**.
- Feistel structure consisting multiple rounds of processing of the plaintext, each round consisting of a "substitution" step followed by a permutation step.
- Many advance encryption algorithms are designed using this Feistel structure
  - This includes the DES standard.
- The inputs to the encryption algorithm are a plaintext block of length 2w bits and a key K .
- The plaintext block is divided into two halves, L^0 and R^0.
- The two halves of the data pass through n rounds of processing and then combine to produce the ciphertext block.
- Each round i has as inputs L^{i-1} and R^{i-1}, derived from the previous round, as well as a subkey K^i, derived from the overall K .
- In general, the subkeys K^i are different from K and from each other and are generated from the key by a subkey generation algorithm.
- All rounds have the same structure. A substitution is performed on the left half of the data.
- This is done by applying a round function F to the right half of the data and then taking the exclusive-OR (XOR) of the output of that function and the left half of the data.
- The round function has the same general structure for each round but is parameterized by the round subkey K^i .
- Following this substitution, a permutation is performed that consists of the interchange of the two halves of the data.

What's happening inside round function "F"?

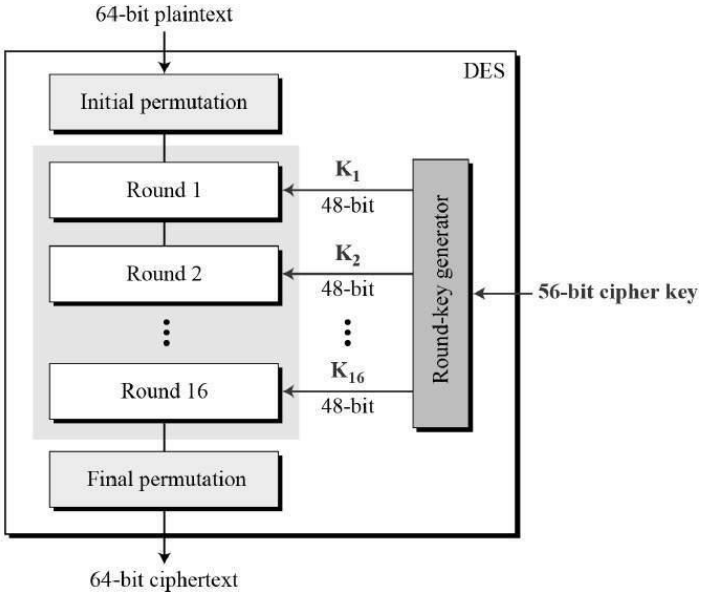
Users with the Key should be able decrypt it easily…How

Data Encryption Standard (DES)



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Symmetric Encryption Algorithm



Until recently was the most widely used encryption scheme

- **Federal Information Processing Standards** FIPS PUB 46
- Referred to as the Data Encryption Algorithm (DEA)
- DES is the most studied encryption algorithm
- DES is a Feistel Cipher.

Working

- **64 bit plaintext block**
- **56 bit key**
- to produce a **64 bit ciphertext block**
- Total**16 rounds**

- Concerns about the use of a 56-bit key
  - Prone to brute-force attack…

Data Encryption Standard (DES)

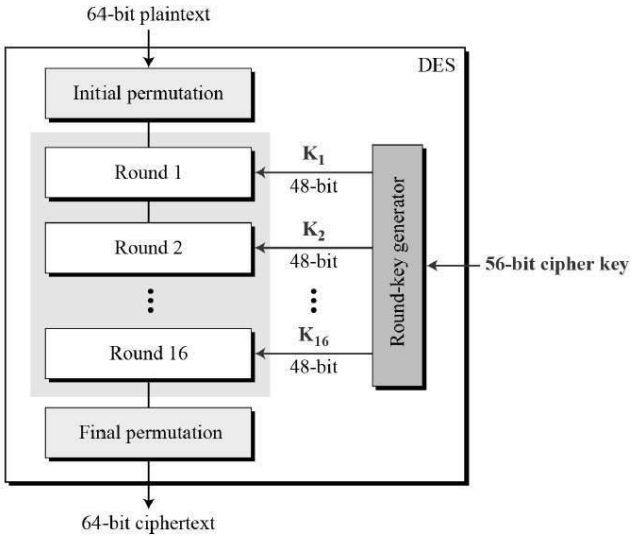
Symmetric Encryption Algorithm

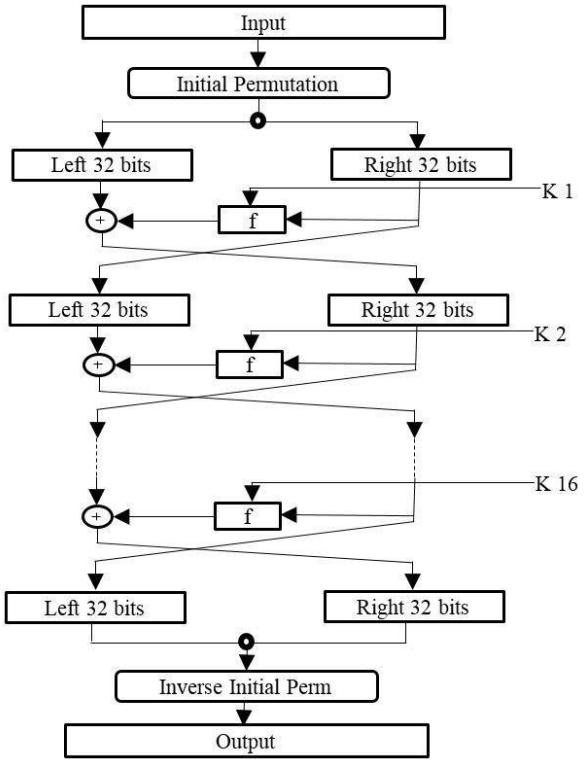
- DES is the most studied encryption algorithm
- DES is a Feistel Cipher.

Working

- **64 bit plaintext block**
- **56 bit key**
- to produce a **64 bit ciphertext block**
- Total**16 rounds**

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)



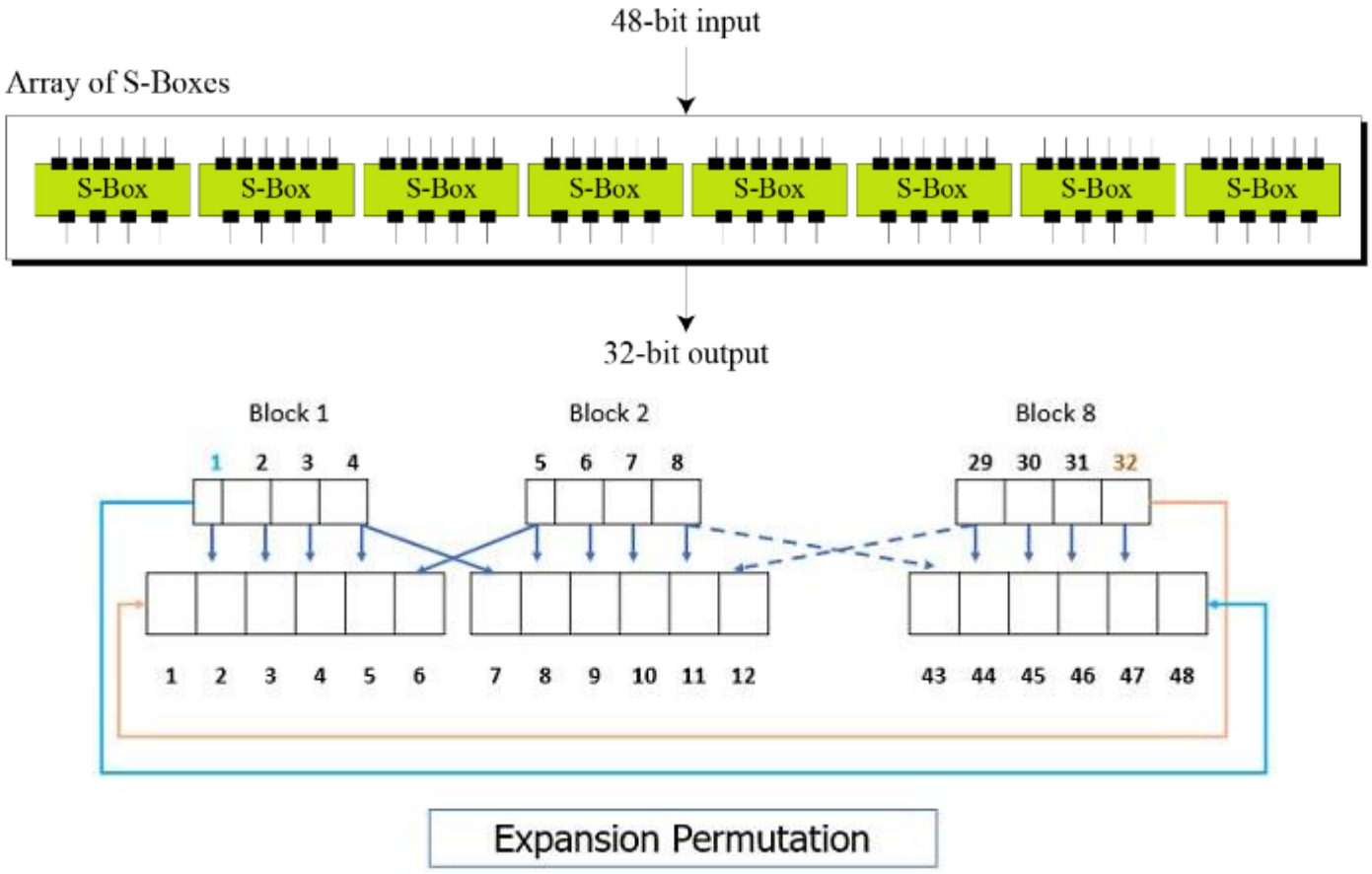


Data Encryption Standard (DES)

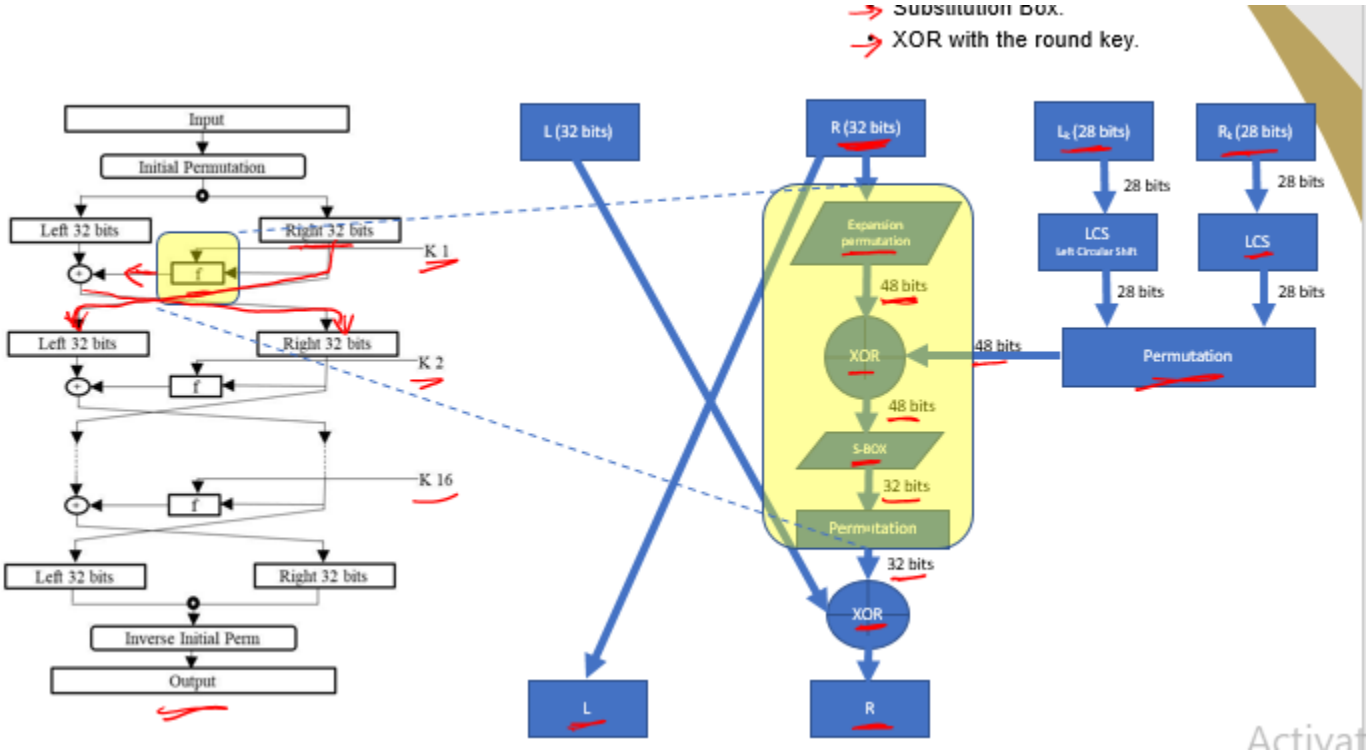
What happens in each round?

- 16 Rounds.
- In each round we apply:
  - Expansion Box.
  - Substitution Box.
  - XOR with the round key.

S-boxes



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)



Data Encryption Standard (DES)

How strong?

Concerns about the use of a 56-bit key

Brute-force attacks

- Try all possible keys on some ciphertext until an intelligible translation into plaintext is obtained
- On average ***half of all possible keys must be tried*** to achieve success
- Number of Keys are dictated by the key size.

Key size (bits)	Cipher	Number of Alternative Keys	Time Required at 10^9 decryptions/s	Time Required at 10^{13} decryptions/s
56	DES	$2^{56} \approx 7.2 \times 10^{16}$	2^{55} ns = 1.125 years	1 hour

$= \frac{3.6 \times 10^{16}}{10^9} = \frac{3.6 \times 10^7 \text{ sec}}{3.2 \times 10^7}$

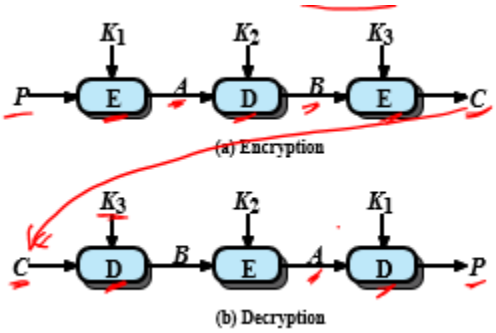
Think...what can you do to make it strong??

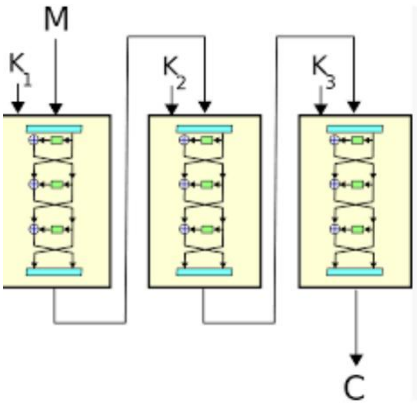
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

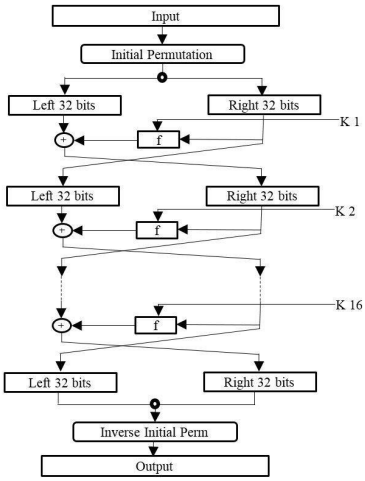
Triple DES (3DES)

Symmetric Encryption Algorithm

- Designed to address security concerns over DES
  - Original DES soon become prone to brute-force attack
  - Need more secure encryption algorithms
- Repeats basic DES algorithm three times using either two or three unique keys
- First standardized for use in financial applications in ANSI standard X9.17 in 1985







Attractions:

- With three distinct keys, 3DES has an effective key length of 168 bits.
- 168-bit key length overcomes the vulnerability to brute-force attack of DES
- Underlying encryption algorithm is the same as in DES

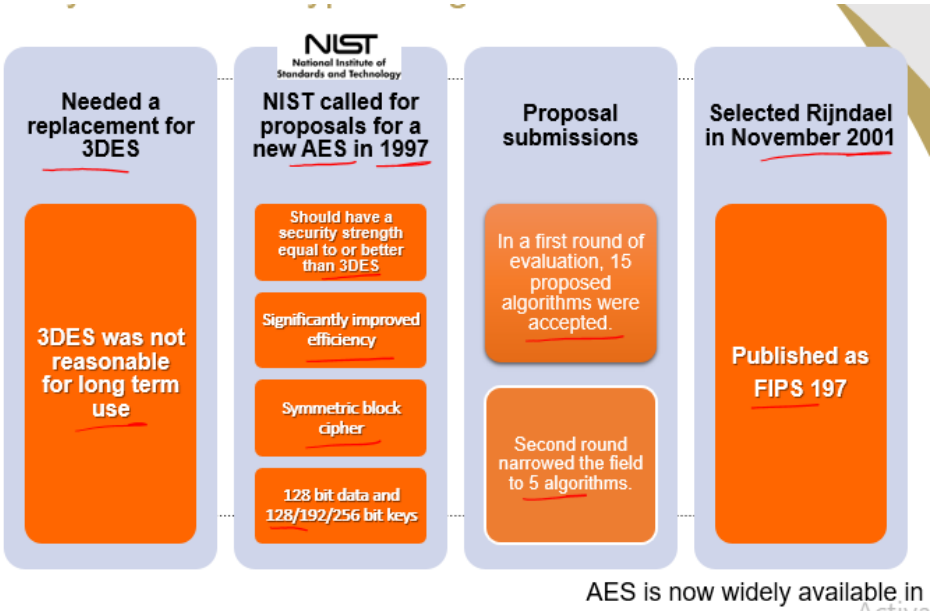
Key size (bits)	Cipher	Number of Alternative Keys	Time Required at 10^9 decryptions/s	Time Required at 10^{13} decryptions/s
56	DES	$2^{56} \approx 7.2 \times 10^{16}$	2^{55} ns = 1.125 years	1 hour
168	Triple DES	$2^{168} \approx 3.7 \times 10^{50}$	2^{167} ns = 5.8×10^{33} years	5.8×10^{29} years

Drawbacks:

- Algorithm is sluggish in software
- Uses a 64-bit block size

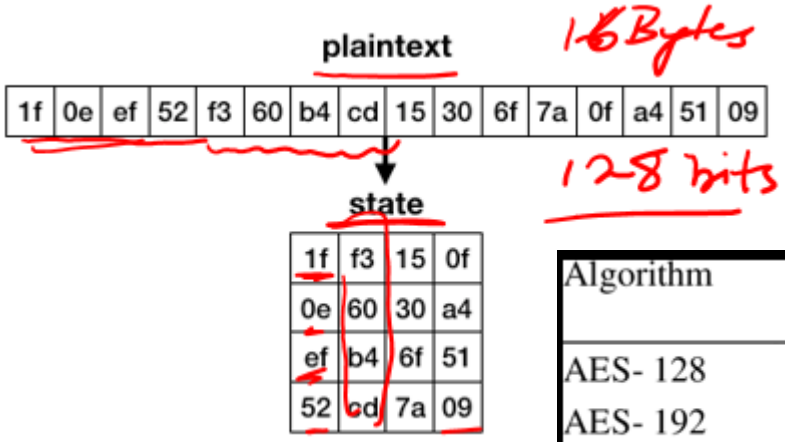
Advanced Encryption Standard (AES)

Symmetric Encryption Algorithm



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

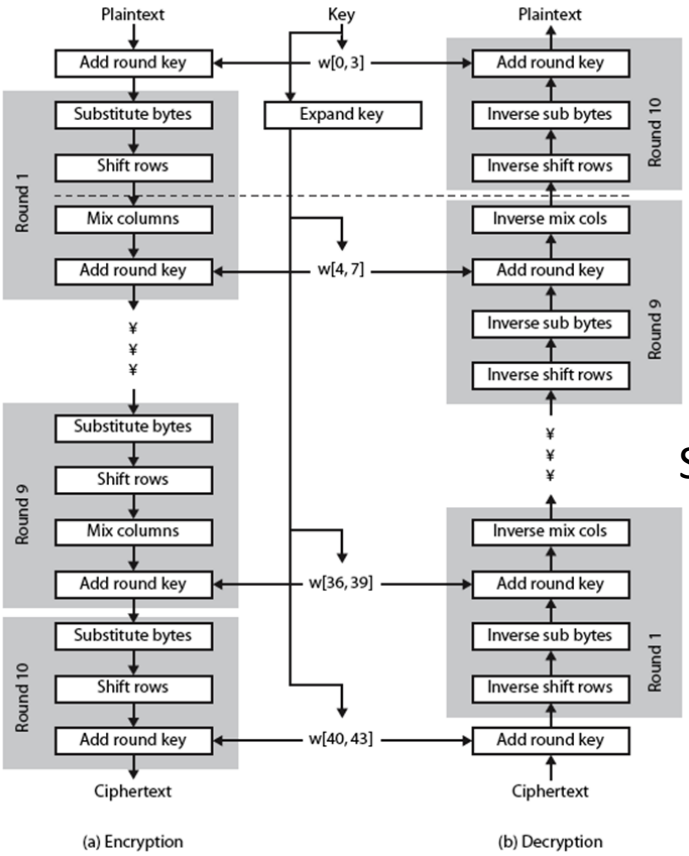
- An **iterative** rather than **Feistel** cipher
  - Processes data as block of 4 columns of 4 bytes
  - Operates on entire data block in every round
- Designed to be:
  - Resistant against known attacks
  - Speed and code compactness on many CPUs
  - Design simplicity
- Data block viewed as 4-by-4 table of bytes
  - Such a table is called the **current state**
- Key is expanded to array of words
- Has 10 rounds in which state the following transformations (called `layers'):
  - BS- byte substitution (1 S-box used on every byte)
  - SR- shift rows (permute bytes between groups/columns)
  - MC- mix columns (uses matrix multiplication in GF(256))
  - ARK- add round key (XOR state with round key)
- First and last round are a little different



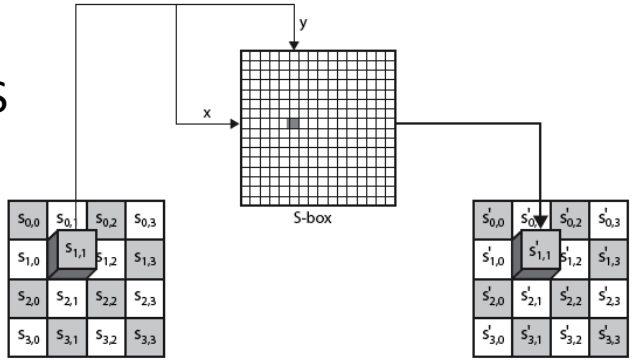
Algorithm	Key length (bits)	Block size (bits)	No of round
AES- 128	128	128	10
AES- 192	192	128	12
AES- 256	256	128	14

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

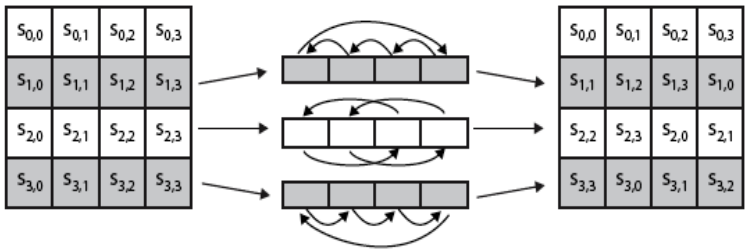
AES Working



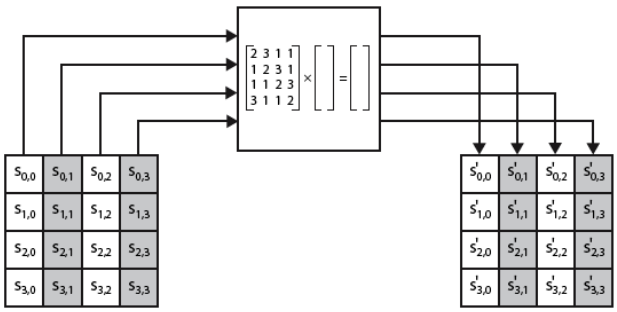
BS



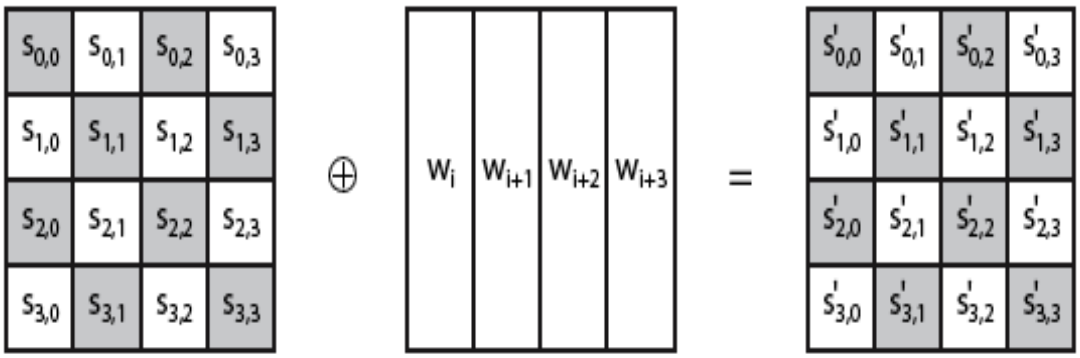
SR



MC



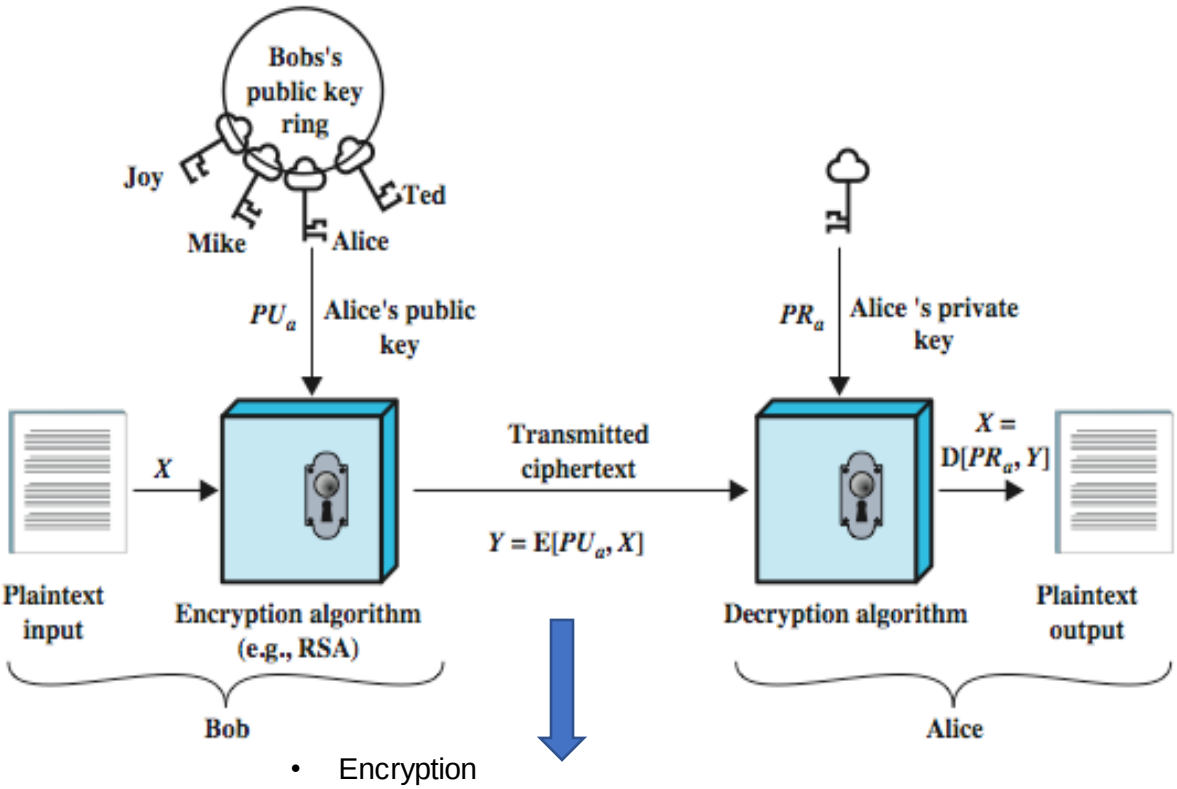
ARK



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Public-Key Cryptography

How public and private keys are used?



- Encryption algorithm
- Public Key
- Ciphertext

Private Key??
Plaintext??



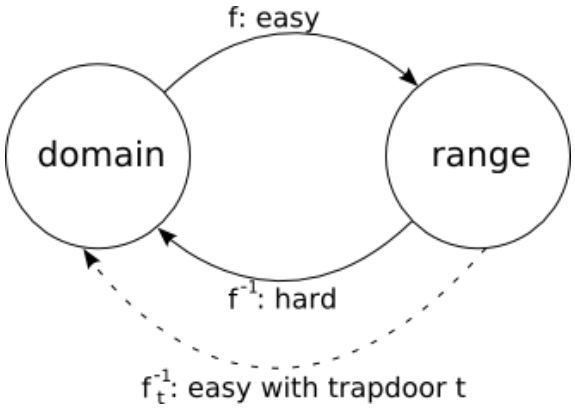
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

One-way Functions

Base for Modern Cryptography

- A **one-way function** is "easy" to compute and "difficult" to reverse.





- The process of **exponentiation** means raising numbers to a power.
- Raising **2** to the power **3**, normally denoted 2^3 just means multiplying **2** by itself **3** times. In other words:
  - $2^3 = (2x2x2)$
  - $a^x = a \times a \times a \times \ldots \times a$
- **Modular exponentiation** means computing $\mathbf{a^x}$ mod some other number **n**.
  - $a^x \bmod n$.
- In other words, given a number **a** and a prime number **n**, the function
  - $f(x) = a^x \bmod n$

  is a one-way function

For x=b, we can easily compute $y=f(b)=a^b \bmod n$ But its reverse is :(

For a particular y=c, its difficult to get respective x Such that $c=f(b)=a^x \bmod n$

Another Example

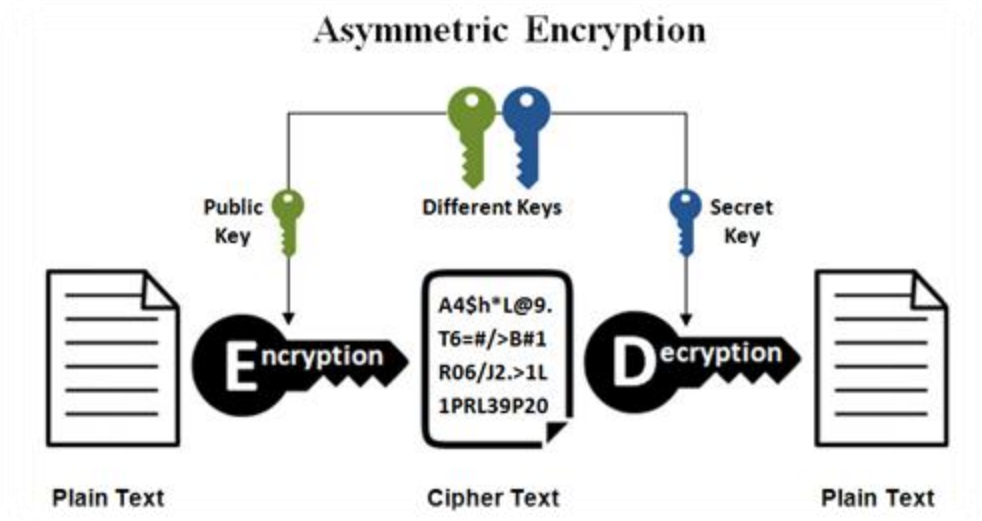
- It is easy to take two prime numbers and multiply them together.
- If the numbers are small, we can do this in our heads, on a piece of paper.
- What if numbers get bigger and bigger?
- Multiplication of two **big** prime numbers is **believed** to be a one-way function.
- Check Wikipedia for RSA Numbers
- https://en.wikipedia.org/wiki/RSA_numbers#:~:text=In%20mathematics%2C%20the%20RSA%20numbers,prime%20factors%20of%20each%20number.
- One of the modern asymmetric algorithm RSA is based on this idea

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

RSA Algorithm

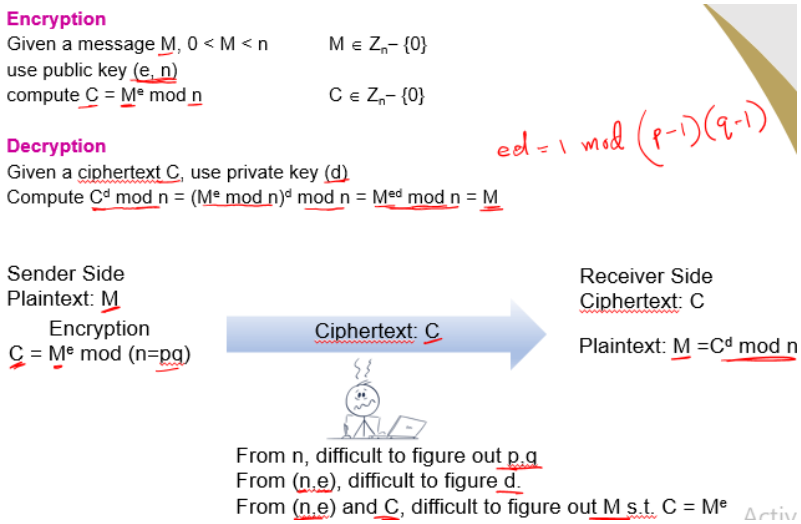
- The **RSA** algorithm was the first practical implementation of public key encryption.
- It is named after the three researchers Ron Rivest, Adi Shamir and Len Adleman



How the public and private keys are selected?

- Let **n** be the product of two large primes **p** and **q (i.e. n=pxq)**
  - at least 512 bits.
- Select a special number **e**
  - greater than 1 and less than (**p**-1)(**q**-1). The precise mathematical property that **e** must have is that there must be no numbers that divide neatly into **e** and into (**p**-1)(**q**-1), except for 1.
- Publish the pair of numbers (**n**,**e**)
- Compute the private key **d** from **p**, **q** and **e**
- The private key **d** is computed to be the unique inverse of **e** modulo (**p**-1)(**q**-1).
- In other words, **d** is the unique number less than (**p**-1)(**q**-1) that when multiplied by **e** gives you 1 modulo (**p**-1)(**q**-1).
  - ed = 1 mod (p-1)(q-1)

Public key: (e, n)
Private key: (d, n)
How the message is encrypted and decrypted?



Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Can we see the public and private keys?

- Let **n** be the product of two large primes **p** and **q (i.e. n=pxq)**
  - at least 512 bits.
- Select a special number **e**
  - greater than 1 and less than (**p**-1)(**q**-1). The precise mathematical property that **e** must have is that there must be no numbers that divide neatly into **e** and into (**p**-1)(**q**-1), except for 1.
- Publish the pair of numbers (**n**,**e**)
- Compute the private key **d** from **p**, **q** and **e**
- The private key **d** is computed to be the unique inverse of **e** modulo (**p**-1)(**q**-1).
- In other words, **d** is the unique number less than (**p**-1)(**q**-1) that when multiplied by **e** gives you 1 modulo (**p**-1)(**q**-1).
  - ed = 1 mod (p-1)(q-1)

Public key: (e, n)
Private key: (d, n)

A Digital Certificate is **an electronic file that is tied to a cryptographic key pair and authenticates the identity of a website, individual, organization, user, device or server**. It is also known as a public key certificate or identity certificate.

RSA Algorithm Example

How are the public and private keys generated?

- Assume we have generated the RSA public-private key pair:

- Choose two "big" primes p=11 and q=13
- Compute the number **n** =p*q = 143
- Number e=? ∈ [1, (p-1)(q-1)] = [1, 120]
  - Relative prime with (p-1)(q-1)
- e=7

- private exponent ***d*** = ?
  - ed = 1 mod (p-1)(q-1)
- ***d*** =103

Public key: (e, n)
Private key: (d, n)

- Let n be the product of two large primes p and q (i.e. n=pxq)
  - at least 512 bits.
- Select a special number e
  - greater than 1 and less than (p-1)(q-1). The precise mathematical property that e must have is that there must be no numbers that divide neatly into e and into (p-1)(q-1), except for 1.
- Publish the pair of numbers (n,e)
- Compute the private key d from p, q and e
- The private key d is computed to be the unique inverse of e modulo (p-1)(q-1).
- In other words, d is the unique number less than (p-1)(q-1) that when multiplied by e gives you 1 modulo (p-1)(q-1).
  - ed = 1 mod (p-1)(q-1)

Public key: (e, n)
Private key: (d, n)

Activate Windows
Go to Settings to activate

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

RSA Algorithm Example

How the message is encrypted and decrypted?

- number n say 143
- e=7
- d =103

Public key: (e, n) (7, 143)
Private key: (d, n) (103, 143)

- Let's encrypt a secret message *msg* = 83

Encryption
$C = M^e \bmod (n=pq)$

$C = 83^7 \bmod 143 = 8$

- Let's now try decryption of the secret message C=8

Plaintext: $M = C^d \bmod n$

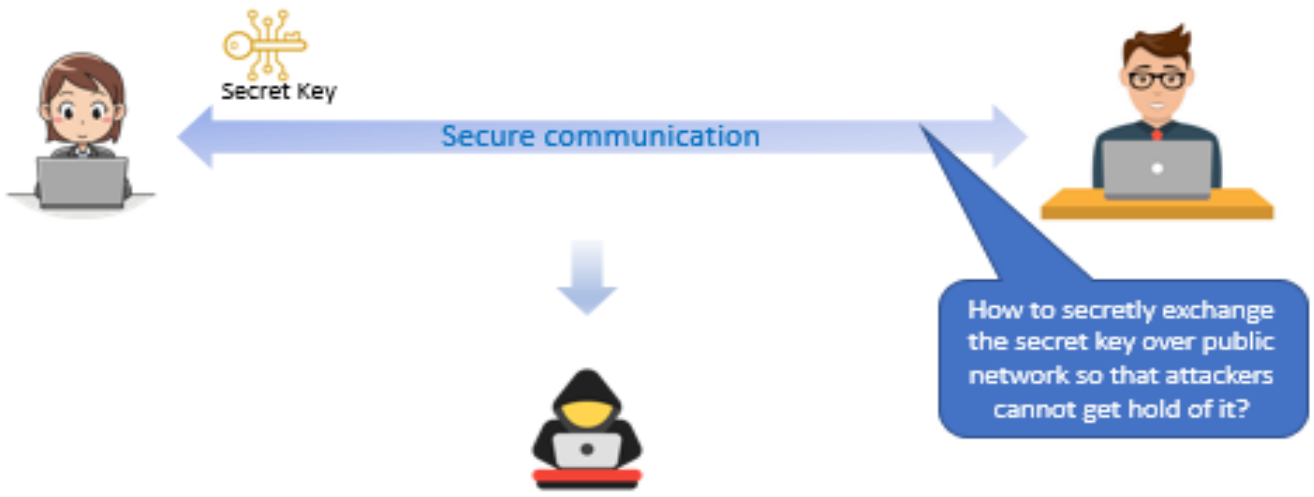
$M = 8^{103} \bmod 143 = 83$

Diffie–Hellman Key Exchange Protocol

For Secure Key Exchange

Two major issues with symmetric encryptions algorithms:

- **key distribution** – how to have secure key exchange among communicating parties
- **digital signatures** – how to verify a message comes intact from the claimed sender

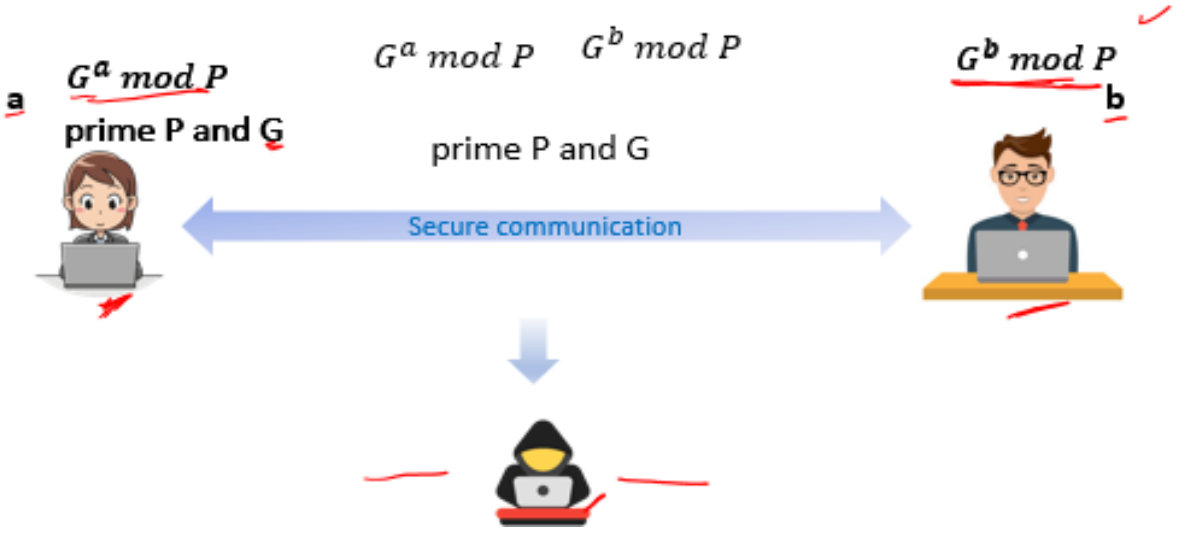


Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Diffie–Hellman Key Exchange Protocol

How Keys are secretly exchanged?

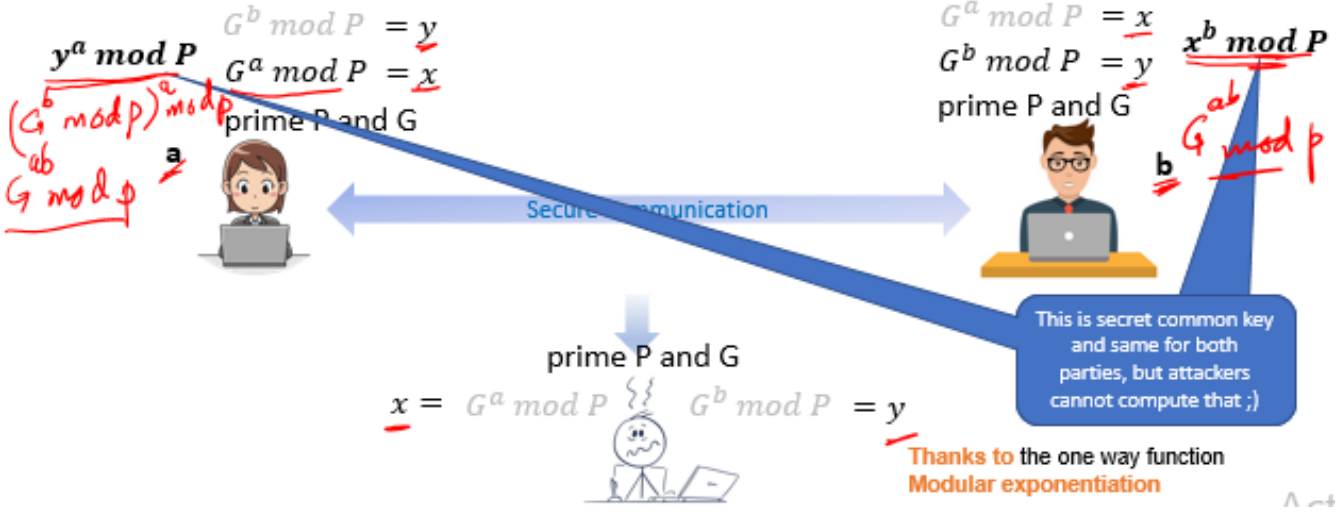
- Lets see, how two users can secretly exchange the key in presence of attacker
- Either party can choose one prime P and G (a primitive root of P) and exchange with the other…attacker can also see that
- Next, each party choose their private values
  - lets say, user-1 choose "**a**" and user-2 choose "**b**".
- Afterwards, both parties compute a number $G^x \ mod \ P$ and send it to the other
- Finally, both parties can generate the common secret key



Diffie–Hellman Key Exchange Protocol

How Keys are secretly exchanged?

- Lets see, how two users can secretly exchange the key in presence of attacker
- Either party can choose one prime P and G (a primitive root of P) and exchange with the other…attacker can also see that
- Next, each party choose their private values
  - lets say, user-1 choose "**a**" and user-2 choose "**b**".
- Afterwards, both parties compute a number $G^x \ mod \ P$ and send it to the other
- Finally, both parties can generate the common secret key

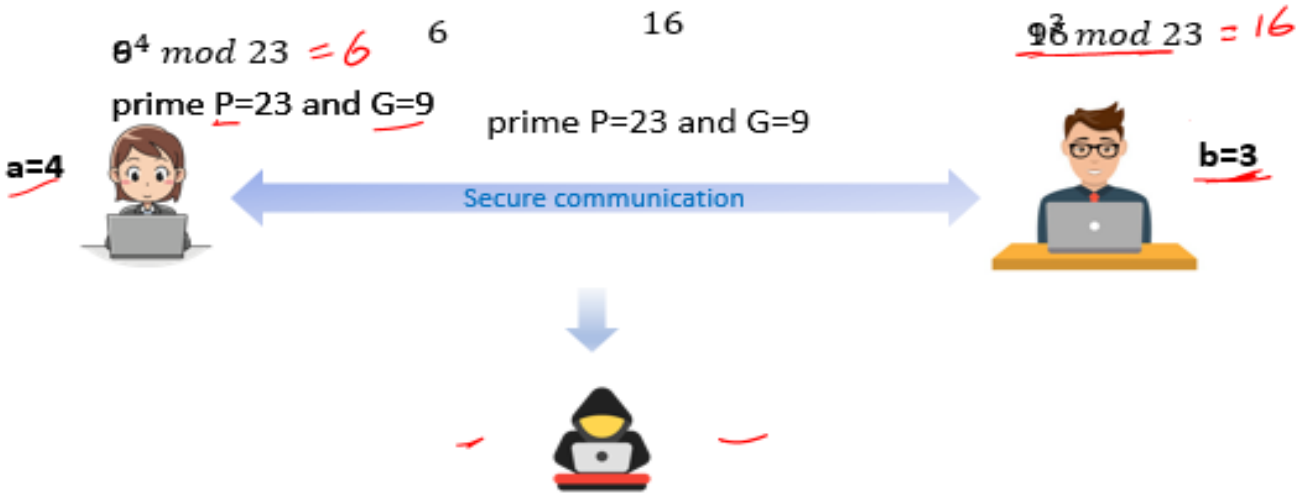


This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Diffie–Hellman Key Exchange - Example

How Keys are secretly exchanged?

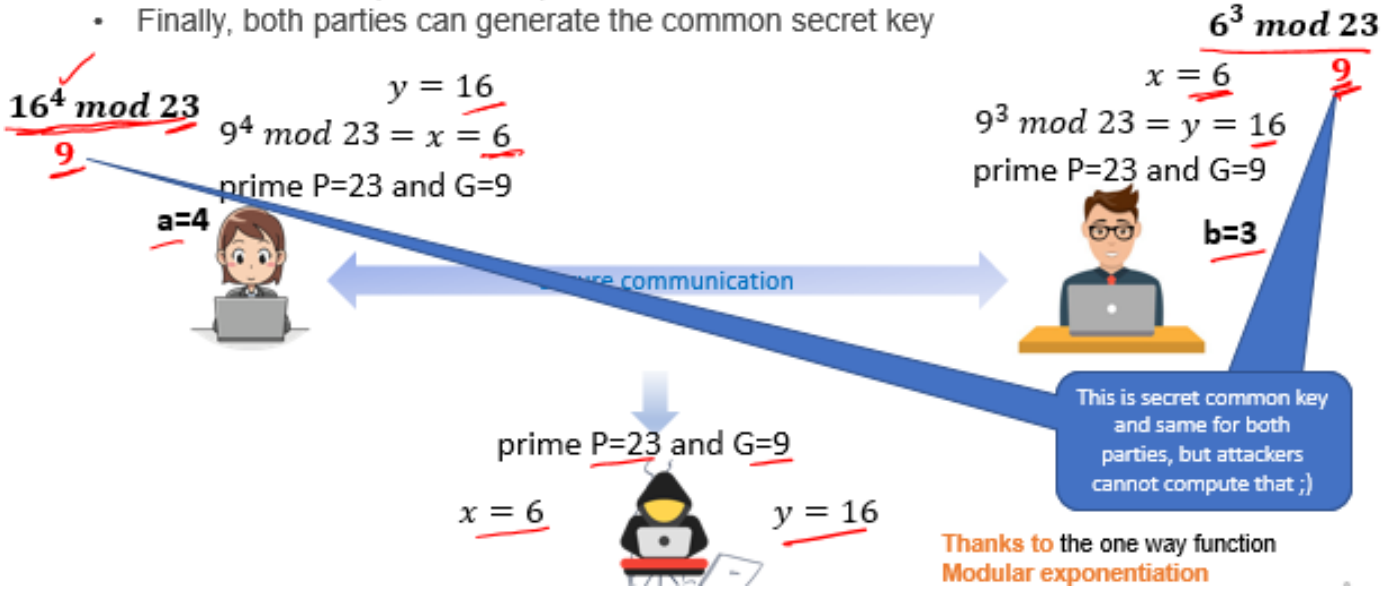
- Lets see, how two users can secretly exchange the key in presence of attacker
- Either party can choose one prime P=23 and G=9 (a primitive root of P) and exchange with the other…attacker can also see that
- Next, each party choose their private values
  - lets say, user-1 choose "**a=4**" and user-2 choose **"b=3"**.
- Afterwards, both parties compute a number $G^x \ mod \ P$ and send it to the other
- Finally, both parties can generate the common secret key



Diffie–Hellman Key Exchange - Example

How Keys are secretly exchanged?

- Lets see, how two users can secretly exchange the key in presence of attacker
- Either party can choose one prime P and G (a primitive root of P) and exchange with the other…attacker can also see that
- Next, each party choose their private values
  - lets say, user-1 choose "**a**" and user-2 choose **"b"**.
- Afterwards, both parties compute a number $G^x \ mod \ P$ and send it to the other
- Finally, both parties can generate the common secret key

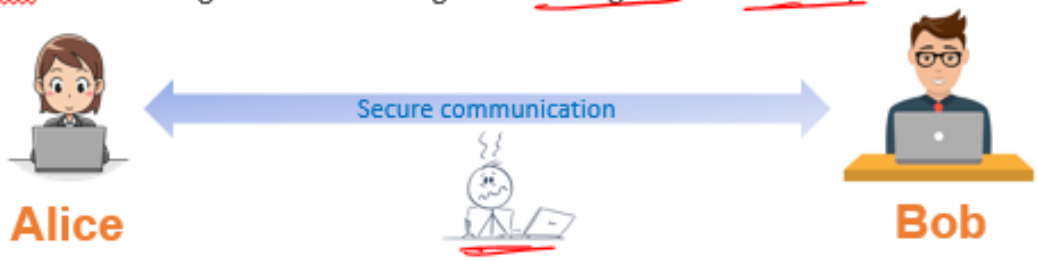


Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Security Issue in the Diffie-Hellman

Can we trust the Diffie-Hellman Algorithm for secure Key exchange?

- Diffie-Hellman Algorithm is safe against sniffing attack…interception



- But what if attacker sits in the middle?



Man in the Middle Attack

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Week#5:

Network Devices

Introduction

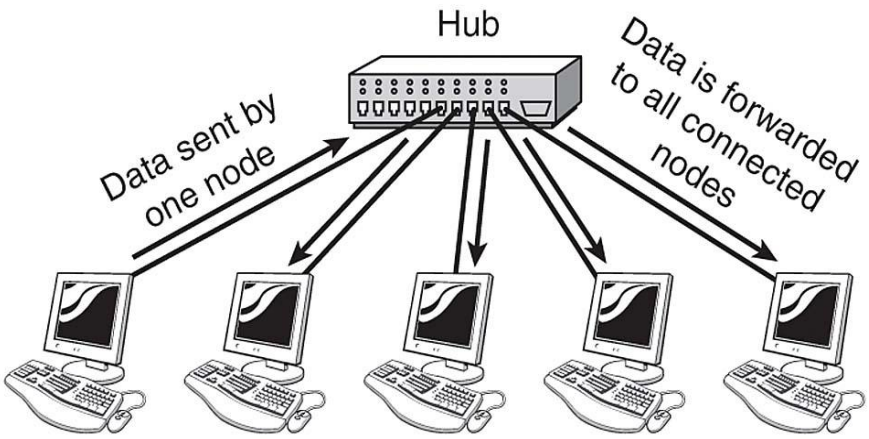
- In this topic we will cover the basics of network devices and their functions.
- We will discuss different types of network devices, including routers, switches, firewalls, and more.

Hub

- A network hub is a device that broadcasts data to every computer or Ethernet-based device connected to it.
- Network hubs are best suited for small, simple local area network (LAN) environments.



Working of Hub



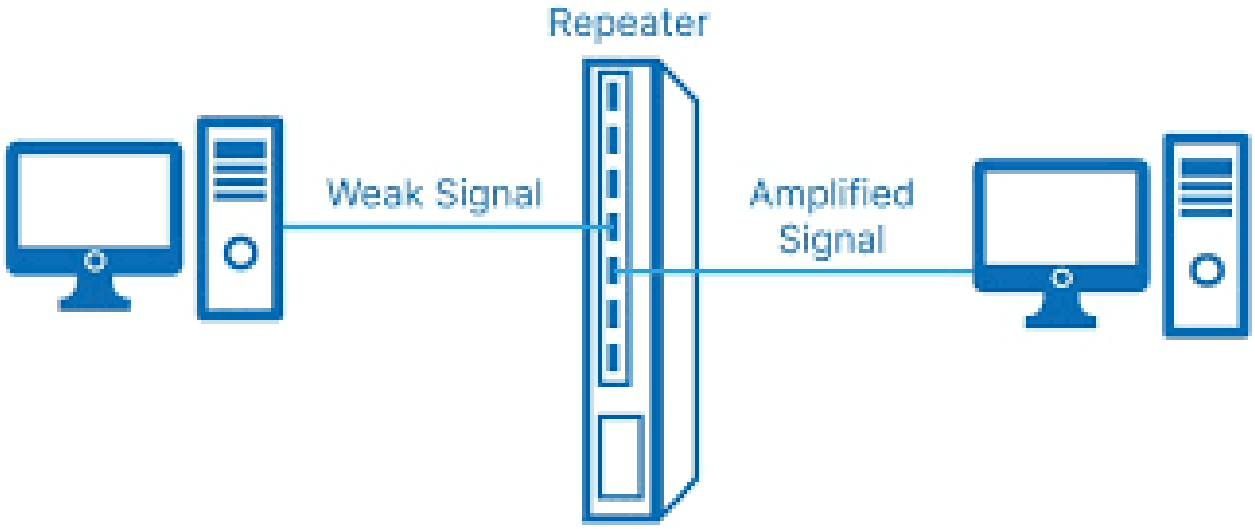
Repeater

- Repeaters are network devices operating at physical layer of the OSI model that amplify or regenerate an incoming signal before retransmitting it.
- They are incorporated in networks to expand its coverage area. They are also known as signal boosters.



Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Working of Repeater



Switch

- A switch is a network device that connects devices on a local area network (LAN).
- It operates at the data link layer of the OSI model and uses MAC addresses to direct traffic to the appropriate device.



Switch's working



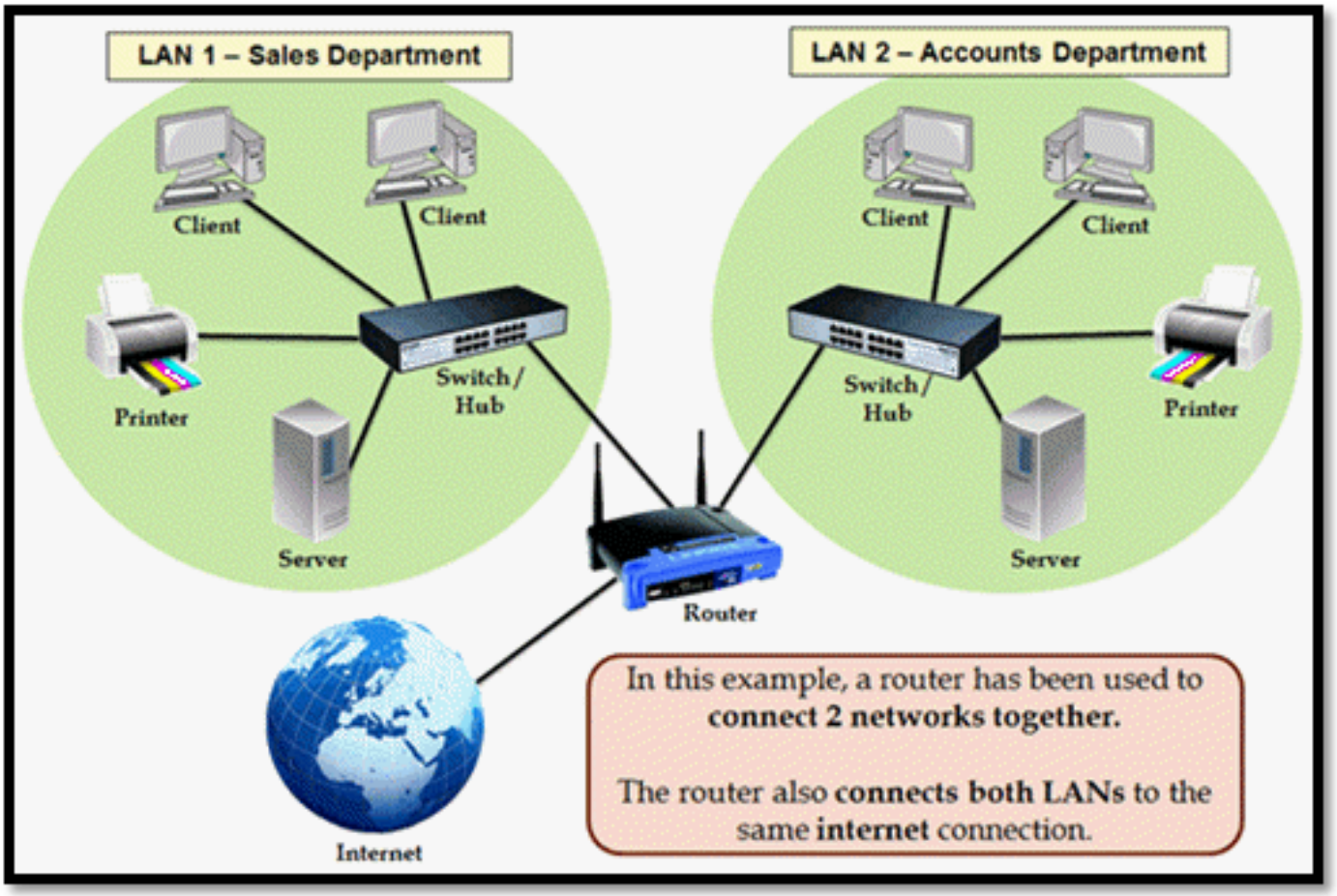
This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Routers

- A router is a network device that connects multiple networks and routes traffic between them.
- It operates at the network layer of the OSI model and uses routing tables to determine the best path for data to travel.



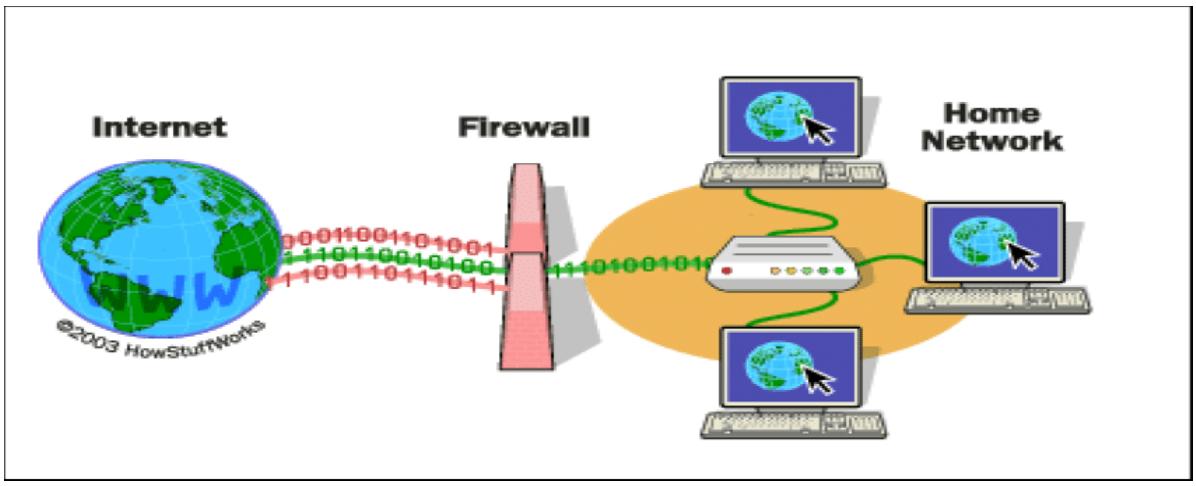
Router's working



Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Firewalls

- A firewall is a network security device that monitors and controls incoming and outgoing network traffic.
- It can block unauthorized access to a network and prevent malicious traffic from entering or leaving the network.

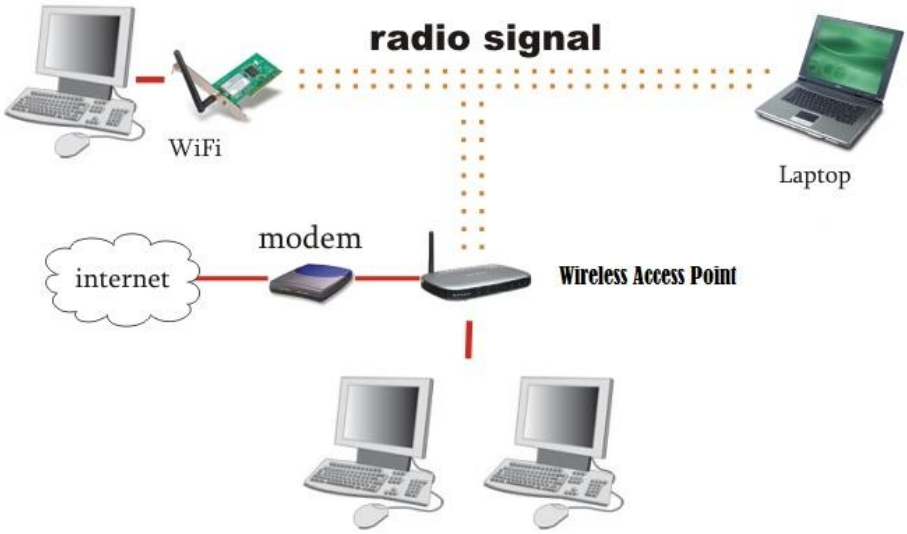


Wireless Access Points

- A wireless access point (WAP) is a network device that allows wireless devices to connect to a wired network.
- It provides a wireless signal for devices to connect to and can support multiple wireless devices simultaneously.



Wireless Access Point's working



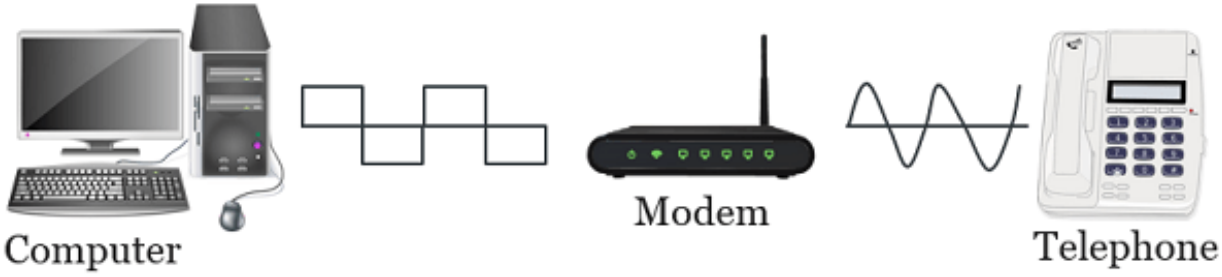
This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Modems



- A modem is a network device that modulates and demodulates signals between a computer and the internet service provider (ISP).
- It converts digital signals from a computer into analog signals that can travel over phone lines or cable lines, and vice versa

Working of Modem

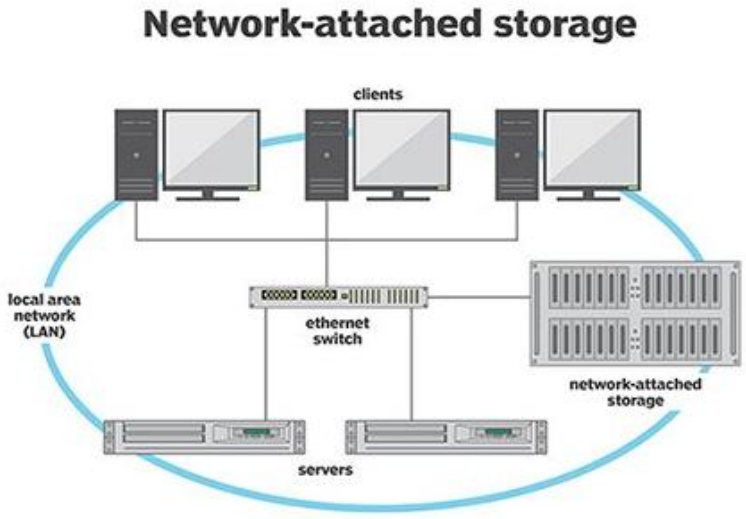


Network Attached Storage (NAS)

- Network Attached Storage (NAS) is a network device that allows multiple devices to share and access files from a central location.
- It can provide data redundancy, backup, and storage capabilities for a network.



Network Attached Storage working



Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Conclusion

- In conclusion, network devices are essential components of a computer network.
- Understanding the functions and capabilities of each device can help network administrators design, configure, and maintain a secure and efficient network infrastructure.

Perimeter Security

- In this topic we will cover the basics of perimeter security and its importance in protecting a network.
- We will discuss different types of perimeter security, including physical and logical measures.

Physical Perimeter Security

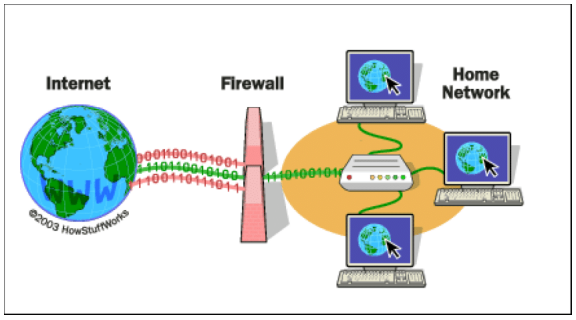
- Physical perimeter security includes measures such as fences, gates, walls, and security cameras.
- These measures restrict access to a physical location and can prevent unauthorized entry.

Logical Perimeter Security

- Logical perimeter security includes measures such as firewalls, intrusion detection systems, and virtual private networks (VPNs).
- These measures control access to a network and can prevent unauthorized access.

Firewalls

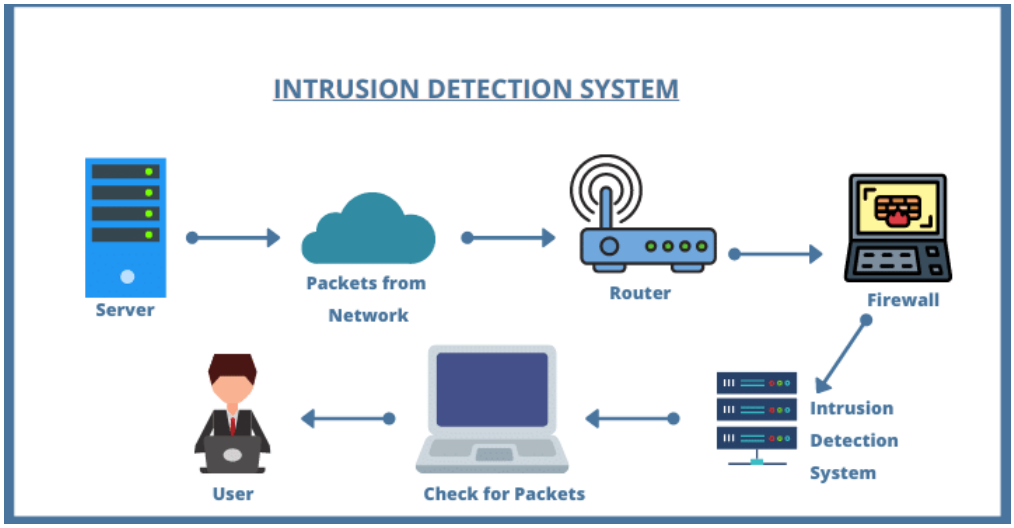
- A firewall is a logical perimeter security device that monitors and controls incoming and outgoing network traffic.
- It can block unauthorized access to a network and prevent malicious traffic from entering or leaving the network.



Intrusion Detection Systems (IDS)

- An intrusion detection system (IDS) is a logical perimeter security device that monitors a network for suspicious activity.
- It can detect and alert network administrators of potential security breaches.

Working of Intrusion Detection Systems (IDS)



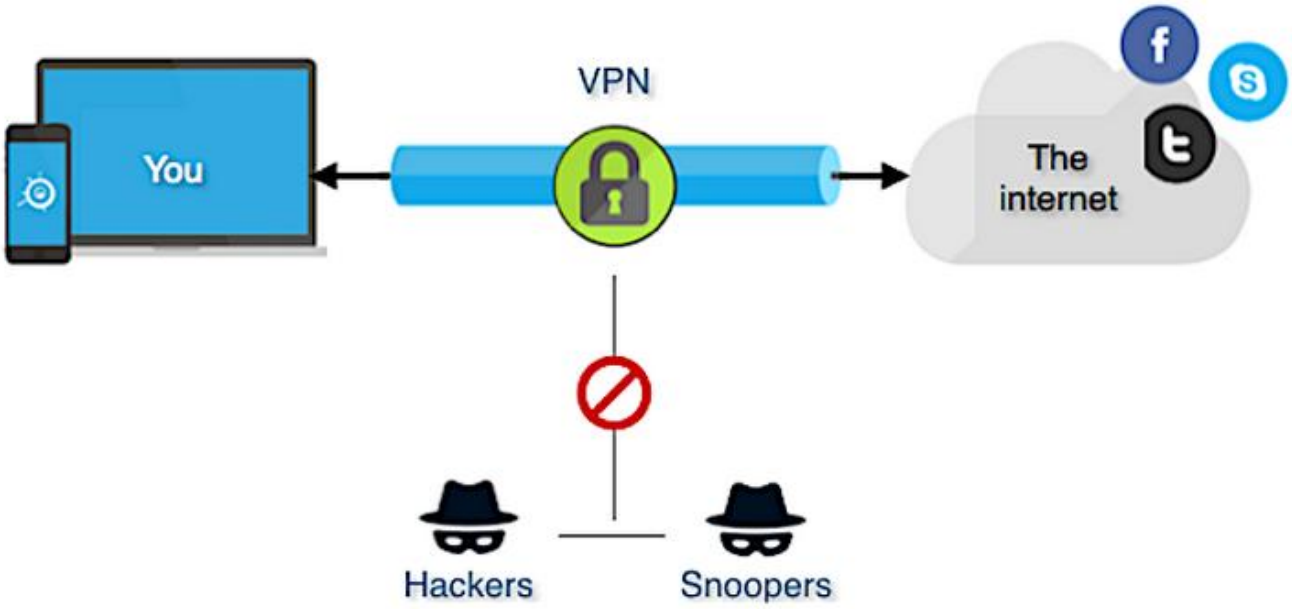
This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Virtual Private Networks (VPNs)

- A virtual private network (VPN) is a logical perimeter security measure that allows remote users to securely connect to a network.
- It encrypts traffic between the remote user and the network, providing secure access to network resources.



Working of VPN



Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Access Control

- Access control is a logical perimeter security measure that restricts access to network resources based on user credentials and permissions.
- It ensures that only authorized users have access to sensitive information.



Conclusion

- In conclusion, perimeter security is a critical component of network security.
- Physical and logical measures can be used to protect a network from unauthorized access and malicious attacks.
- Understanding the various types of perimeter security measures and their functions can help network administrators design, configure, and maintain a secure network infrastructure.

Introduction:

- In this topic we will cover the basics of intrusion and its impact on a network.
- We will discuss what an intrusion is, types of intrusions, and how to prevent them.
- **What is an intrusion?**
- An intrusion is an unauthorized attempt to access, use, or modify a network, system, or device.
- It can occur through various means, including malware, phishing attacks, and brute-force attacks.

Types of Intrusions

There are different types of intrusions, including:

- **External Intrusion**: when an attacker attempts to gain access to a network from outside.
- **Internal Intrusion**: when an attacker gains access to a network from within, such as an employee with malicious intent.
- **Insider Threat**: when an employee or contractor intentionally or unintentionally causes harm to a network.
- **Distributed Denial of Service (DDoS)**: when an attacker floods a network with traffic to disrupt normal operations.

Impact of Intrusions

Intrusions can have severe impacts on a network, including:

- lData theft or loss
- lFinancial loss
- lReputation damage
- lDisruption of operations

Prevention Measures

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

To prevent intrusions, organizations can implement various measures, including:

- Firewalls and intrusion detection/prevention systems
- Regular software updates and patching
- Strong password policies
- Employee training on phishing and social engineering attacks
- Access control policies

Incident Response

- Despite preventative measures, intrusions can still occur.
- Organizations should have an incident response plan in place to quickly and effectively respond to a security breach.

Conclusion

- In conclusion, intrusions are unauthorized attempts to access, use, or modify a network, system, or device.
- They can have severe impacts on an organization, but prevention measures and incident response plans can help mitigate the risks.

Examples of Intrusion

Introduction

- In this topic we will cover some common examples of intrusions.
- We will discuss the types of attacks used in each example and the impact on the affected network.

Malware Infection

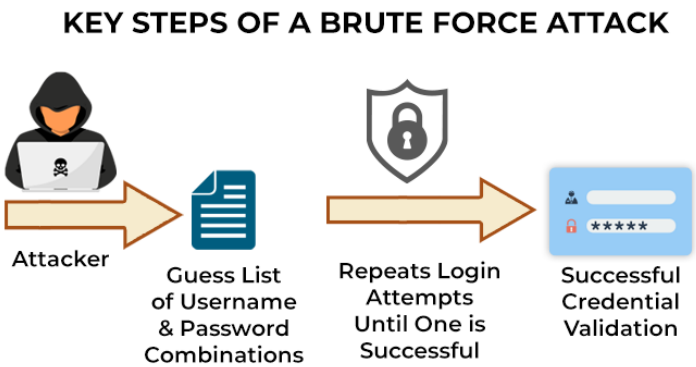
- Malware is a type of software designed to harm a computer system or network.
- Examples of malware include viruses, worms, and Trojan horses.
- A malware infection can result in stolen data, financial loss, and network downtime.

Phishing Attacks

- Phishing attacks are attempts to trick individuals into revealing sensitive information.
- Attackers often use email or social media to deceive victims into clicking a malicious link or providing personal information.
- A successful phishing attack can result in stolen login credentials or sensitive data.

Brute-Force Attacks

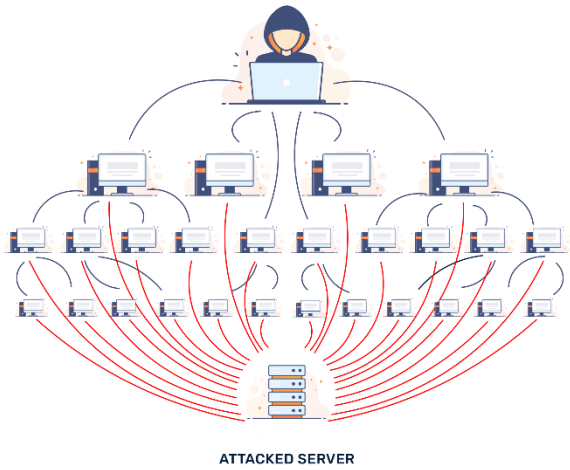
- A brute-force attack is an attempt to gain unauthorized access to a system or network by guessing passwords.
- Attackers use automated tools to try multiple password combinations until they find the correct one.
- A successful brute-force attack can result in unauthorized access to sensitive data.



Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

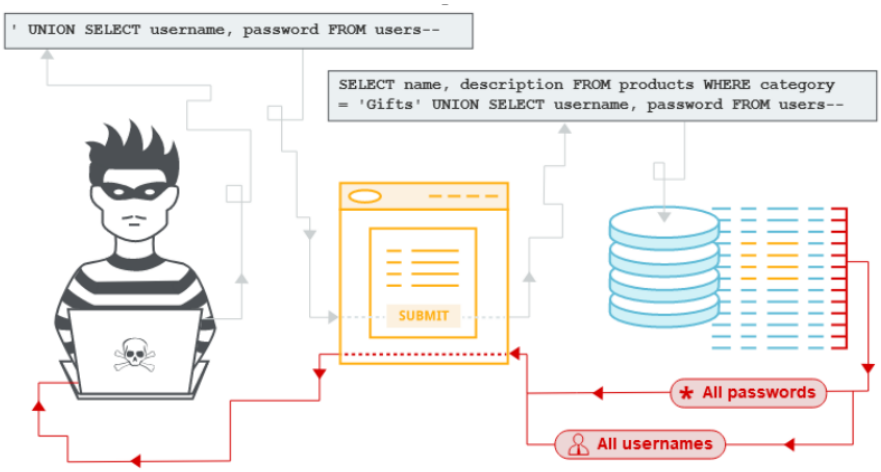
Distributed Denial of Service (DDoS)

- A DDoS attack is an attempt to disrupt normal network operations by overwhelming the network with traffic.
- Attackers use a botnet, a group of compromised devices, to flood the network with traffic.
- A successful DDoS attack can result in network downtime and financial loss



SQL Injection

- An SQL injection is an attack that targets the database of a web application.
- Attackers input malicious SQL code into a web form to access or modify sensitive information stored in the database.
- A successful SQL injection can result in unauthorized access to sensitive data.



Conclusion

- In conclusion, there are various examples of intrusions that can impact a network.
- Attackers use different types of attacks, including malware infections, phishing attacks, brute-force attacks, DDoS attacks, and SQL injections.
- Organizations must implement strong security measures, such as firewalls, intrusion detection systems, and access control policies, to prevent and mitigate the impact of intrusions.

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Intruder Behavior

Introduction

- In this topic we will cover intruder behavior and how it can impact a network.
- We will discuss the different types of intruders and their motivations for attacking a network.

Types of Intruders

There are different types of intruders, including:

Script Kiddies: inexperienced attackers who use pre-written scripts to launch attacks.

- **Hacktivists**: attackers who target a network to promote a political or social cause.
- **Insiders**: employees or contractors who intentionally or unintentionally cause harm to a network.
- **Cybercriminals**: attackers who target a network for financial gain.
- **Nation-state Actors**: attackers who are sponsored by a government to gain access to sensitive information.

Motivations for Intruder Behavior

Intruders may have various motivations for attacking a network, including:

- Financial gain
- Political or social reasons
- Espionage
- Personal challenge
- Revenge

Intruder Methods

Intruders use various methods to gain access to a network, including:

- Exploiting vulnerabilities in software or hardware
- Social engineering, such as phishing attacks
- Brute-force attacks
- Distributed denial of service (DDoS) attacks
- Insider threats

Impact of Intruder Behavior

Intruder behavior can have severe impacts on a network, including:

- Data loss or theft
- Financial loss
- Reputation damage
- Disruption of operations
- Legal consequences

Prevention and Mitigation

To prevent and mitigate the impact of intruder behavior, organizations can implement various measures, including:

- lStrong passwords and access control policies
- lRegular software updates and patching
- lEmployee training on social engineering attacks
- lFirewalls and intrusion detection/prevention systems
- lIncident response plans

Conclusion

- In conclusion, intruder behavior can have severe impacts on a network, and there are different types of intruders with varying motivations for attacking a network.
- Organizations must implement strong security measures to prevent and mitigate the impact of intruder behavior, including strong passwords, access control policies, regular software updates, employee training, and incident response plans

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

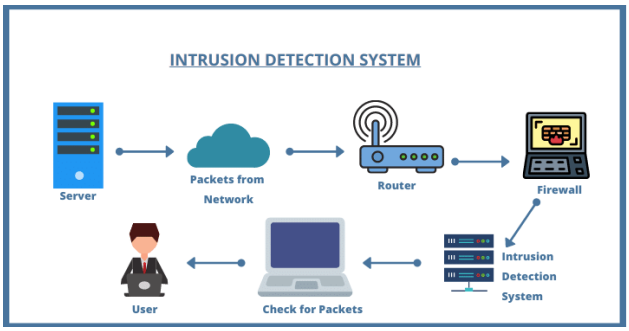
Intrusion Detection System (IDS)

Introduction

- In this topic we will cover Intrusion Detection System (IDS) and its importance in network security.
- We will discuss the types of IDS and how they work to detect intrusions.

What is an IDS?

- An IDS is a security tool designed to detect and alert on malicious activity on a network.
- IDS can detect unauthorized access, malware infections, phishing attacks, and other types of intrusions.



Types of IDS

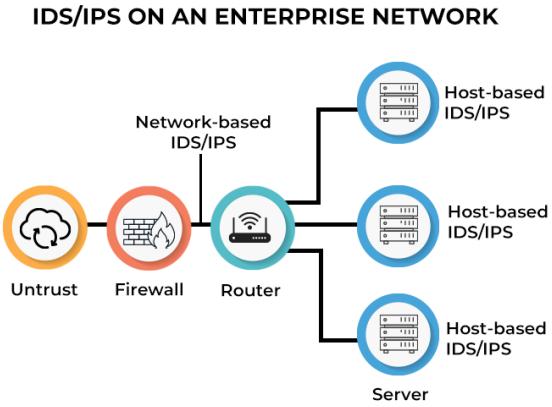
There are two types of IDS:

- **Network-based IDS (NIDS)**: These monitor network traffic for suspicious activity, such as unusual traffic patterns or known attack signatures.
- **Host-based IDS (HIDS)**: These monitor activity on individual devices, such as servers or workstations, to detect unauthorized access or system-level attacks.

How IDS Works?

- IDS works by comparing network traffic or system activity against known attack signatures, behavior patterns, or other indicators of compromise (IoCs).
- IDS can detect intrusions by analyzing packet headers and payloads, system logs, and other data sources.

IDS alerts security teams or generates automated responses, such as blocking traffic or quarantining affected devices



Benefits of IDS

IDS provides several benefits, including:

- Early detection and alerting of intrusions, reducing the impact of an attack.
- Faster incident response by identifying the affected devices and the scope of the attack.
- Improved visibility into network traffic and activity, allowing security teams to identify vulnerabilities and potential attack vectors.

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Limitations of IDS

IDS has some limitations, including:

- IDS may generate false positives or false negatives, leading to unnecessary alerts or missed intrusions.
- IDS requires maintenance and updates to stay current with the latest attack signatures and IoCs.
- IDS may not detect new or unknown attack vectors.

Conclusion

- In conclusion, IDS is an important tool in network security that can detect and alert on intrusions, reducing the impact of an attack.
- Organizations must choose the right type of IDS, NIDS or HIDS, based on their network architecture and security needs.
- IDS has limitations, and organizations must implement complementary security measures, such as firewalls, access control, and endpoint security, to achieve a comprehensive security posture.

IDS Analysis Approaches

Introduction

- In this topic we will cover IDS analysis approaches and how they can be used to detect and respond to network intrusions.
- We will discuss the different types of IDS analysis approaches and how they work.

Types of IDS Analysis Approaches

There are three main types of IDS analysis approaches:

- lSignature-based analysis
- lAnomaly-based analysis
- lHybrid analysis

Signature-based Analysis

- Signature-based analysis compares network traffic against known attack signatures or patterns.
- IDS with signature-based analysis can identify known attacks with high accuracy but may miss new or unknown attacks.
- Signature-based analysis requires regular updates to stay current with new attack signatures.

Anomaly-based Analysis

- Anomaly-based analysis detects deviations from normal network traffic or user behavior.
- IDS with anomaly-based analysis can identify new or unknown attacks but may generate more false positives than signature-based analysis.
- Anomaly-based analysis requires a baseline of normal network traffic or user behavior to be established and updated regularly.

Hybrid Analysis

- Hybrid analysis combines signature-based and anomaly-based analysis to achieve a more comprehensive detection capability.
- IDS with hybrid analysis can identify known and unknown attacks with fewer false positives but require more resources to operate effectively.

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Conclusion

- In conclusion, IDS analysis approaches are essential for detecting and responding to network intrusions effectively.
- Organizations must choose the right type of IDS analysis approach based on their network architecture and security needs.
- IDS analysis approaches require regular maintenance, updates, and baseline establishment to operate effectively.

Host-Based IDS

Introduction

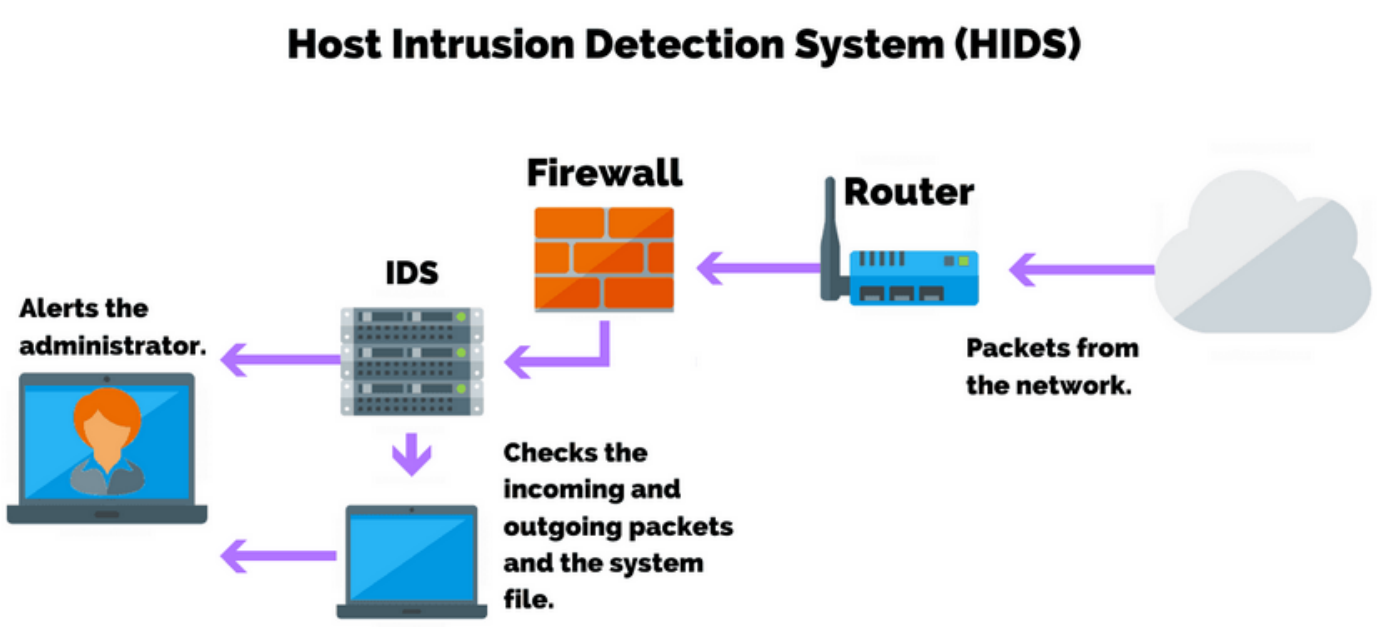
- In this topic we will cover Host-Based Intrusion Detection System (HIDS) and its importance in host-level security.
- We will discuss how HIDS works and its benefits and limitations.

What is HIDS?

- HIDS is an intrusion detection system that monitors activity on individual devices, such as servers or workstations, to detect unauthorized access or system-level attacks.
- HIDS can detect malicious activity that network-based IDS (NIDS) may not capture, such as file modifications or process-level attacks.

How HIDS Works?

- HIDS works by collecting and analyzing system activity logs, file integrity, and system performance metrics to identify suspicious activity.
- HIDS can detect unauthorized access attempts, malware infections, and other types of host-level attacks.
- HIDS alerts security teams or generates automated responses, such as terminating malicious processes or isolating affected devices.



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Benefits of HIDS

HIDS provides several benefits, including:

- Granular visibility into host-level activity, allowing for faster incident response and reducing the impact of an attack.
- Detecting threats that may evade NIDS, such as fileless malware or process-level attacks.

Enhancing compliance by monitoring and reporting on system-level activity

Limitations of HIDS

HIDS has some limitations, including:

- HIDS can generate a high number of alerts, leading to alert fatigue and missed intrusions.
- HIDS requires maintenance and updates to stay current with the latest attack patterns and IoCs.
- HIDS may not detect sophisticated or zero-day attacks.

HIDS Deployment

HIDS can be deployed in several ways, including:

- **Agent-based:** HIDS agent installed on each monitored device.
- **Agentless:** HIDS uses system logs and network packets for analysis.
- **Hybrid:** HIDS uses a combination of agent-based and agentless approaches.

Conclusion

- In conclusion, HIDS is an essential tool in host-level security that can detect and alert on intrusions, reducing the impact of an attack.
- Organizations must choose the right type of HIDS deployment based on their network architecture and security needs.
- HIDS has limitations, and organizations must implement complementary security measures, such as firewalls, access control, and endpoint security, to achieve a comprehensive security posture.

Network-Based IDS

Introduction

- Network-based Intrusion Detection Systems (NIDS) are security tools that monitor and analyze network traffic to detect suspicious activity or malicious attacks.
- NIDS is one of the most important security measures in modern-day networks.
- NIDS provides a higher level of security by detecting and alerting the network administrator of potential threats.

Types of NIDS

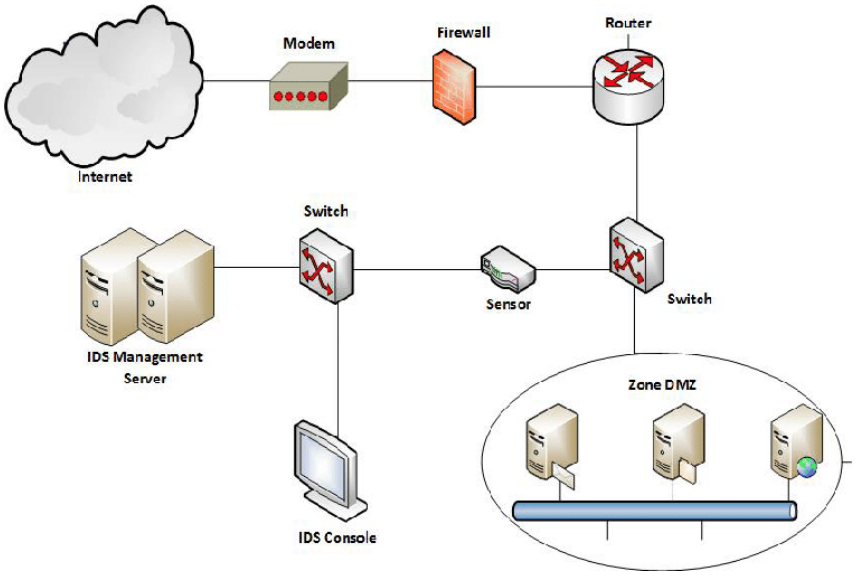
- **Signature-based NIDS**: Uses a pre-defined database of known attack patterns, and alerts when a network packet matches a signature in the database.
- **Anomaly-based NIDS**: Analyzes the network traffic for abnormal behavior or traffic patterns, and alerts the administrator when such activity is detected.
- **Hybrid NIDS**: Combines both signature-based and anomaly-based detection methods to provide a more comprehensive approach to intrusion detection.

NIDS Architecture

NIDS architecture includes the following components:

- **Network Taps**: Collect and route network traffic to the NIDS for analysis.
- **Sensors**: Monitor network traffic and analyze packets for malicious activity.
- **Console**: Provides the interface for administrators to configure and manage the NIDS, and review alerts and logs.

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)



NIDS Deployment

NIDS can be deployed in two ways: passive or active.

- **Passive deployment**: Does not alter the network traffic or packets, and only analyzes network traffic.
- **Active deployment**: Alters network traffic or packets, such as dropping or modifying packets, to prevent malicious activity.

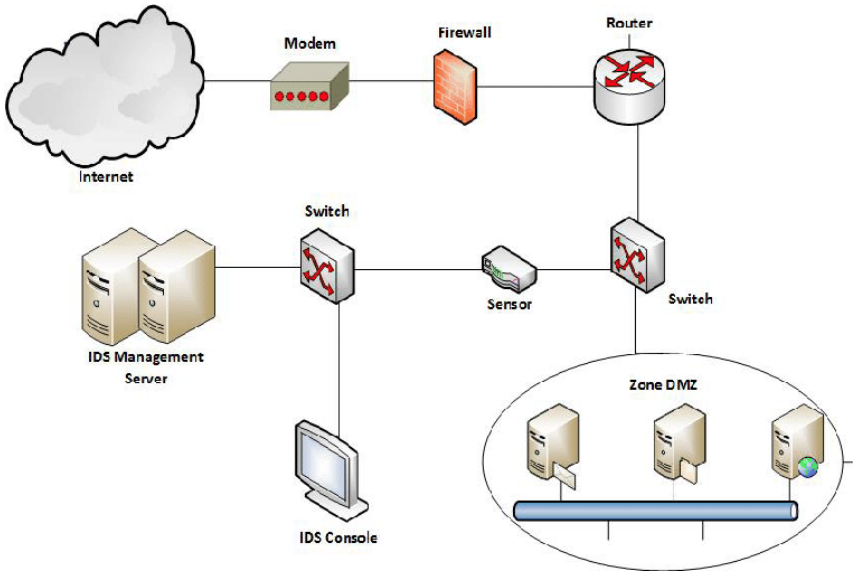
Advantages of NIDS

- Provides real-time monitoring of network traffic.
- Detects and alerts the administrator of potential threats, allowing for timely action to be taken.
- Can be deployed on a variety of network architectures and sizes.
- Can be configured to monitor specific types of traffic, such as web traffic or email traffic.

NIDS Architecture

NIDS architecture includes the following components:

- **Network Taps**: Collect and route network traffic to the NIDS for analysis.
- **Sensors**: Monitor network traffic and analyze packets for malicious activity.
- **Console**: Provides the interface for administrators to configure and manage the NIDS, and review alerts and logs.



This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

NIDS Deployment

NIDS can be deployed in two ways: passive or active.

- **Passive deployment**: Does not alter the network traffic or packets, and only analyzes network traffic.
- **Active deployment**: Alters network traffic or packets, such as dropping or modifying packets, to prevent malicious activity.

Advantages of NIDS

- Provides real-time monitoring of network traffic.
- Detects and alerts the administrator of potential threats, allowing for timely action to be taken.
- Can be deployed on a variety of network architectures and sizes.
- Can be configured to monitor specific types of traffic, such as web traffic or email traffic.

Disadvantages of NIDS

- **False positives**: Alerts generated by NIDS may not always indicate a genuine threat, which can lead to unnecessary investigations.
- **Limited visibility**: NIDS can only monitor network traffic, and may not be able to detect attacks on endpoints or applications.
- **Performance impact**: NIDS can impact network performance, especially if the network traffic is high.

Conclusion

- NIDS is an important tool for network security, providing real-time monitoring and alerting of potential threats.
- NIDS architecture includes sensors, network taps, and a console for management and configuration.
- NIDS can be deployed passively or actively, with advantages and disadvantages for each deployment method.

WIPS - Wireless IPS

Introduction

- Wireless Intrusion Prevention Systems (WIPS) are security tools that detect and prevent unauthorized access to wireless networks.
- WIPS is a crucial security measure for modern-day wireless networks.

WIPS provides a higher level of security by detecting and preventing potential threats to wireless networks

Types of WIPS

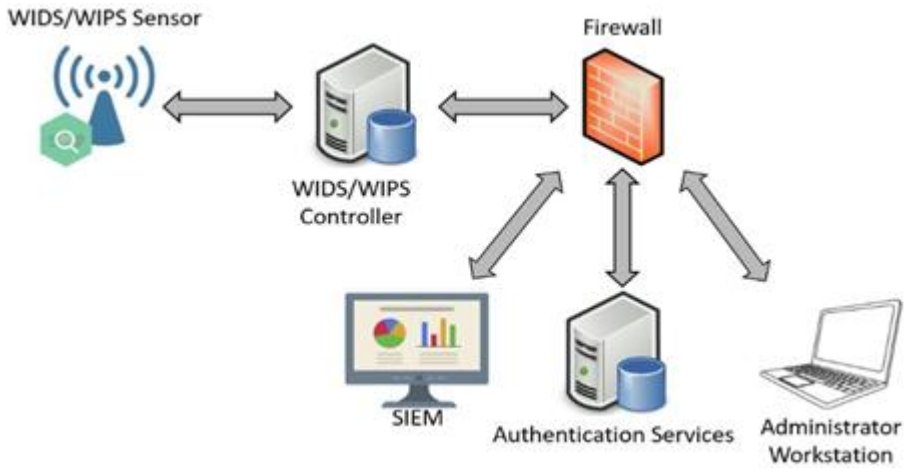
- **Overlay WIPS**: A separate wireless sensor network is deployed to monitor and secure the wireless network.
- **Integrated WIPS**: The WIPS functionality is integrated into the wireless access points (APs) themselves.

WIPS Architecture

WIPS architecture includes the following components:

- **Access Points**: Provide wireless connectivity to devices and also monitor for suspicious activity.
- **Sensors**: Detect wireless attacks or suspicious behavior and notify the access points to take appropriate action.
- **Management Console**: Provides the interface for administrators to configure and manage the WIPS, and review alerts and logs.

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)



WIPS Deployment

- WIPS can be deployed in two ways: standalone or integrated.
- Standalone deployment: A separate sensor network is deployed to monitor wireless traffic and detect attacks.
- Integrated deployment: WIPS functionality is integrated into wireless APs themselves, reducing the need for additional hardware.

Advantages of WIPS

- Provides real-time monitoring of wireless traffic.
- Detects and prevents potential threats to the wireless network, including rogue APs and unauthorized access attempts.
- Can be configured to monitor and protect specific types of wireless traffic, such as voice or data.
- Supports compliance with regulatory requirements, such as PCI-DSS.

Disadvantages of WIPS

- **False positives**: Alerts generated by WIPS may not always indicate a genuine threat, which can lead to unnecessary investigations.
- **Limited visibility**: WIPS can only monitor wireless traffic, and may not be able to detect attacks on wired networks or applications.
- **Performance impact**: WIPS can impact wireless performance, especially if the wireless network traffic is high.

Conclusion

- WIPS is a crucial tool for wireless network security, providing real-time monitoring and prevention of potential threats.
- WIPS architecture includes access points, sensors, and a management console for configuration and management.
- WIPS can be deployed standalone or integrated, with advantages and disadvantages for each deployment method.

This document is available on studocu
Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

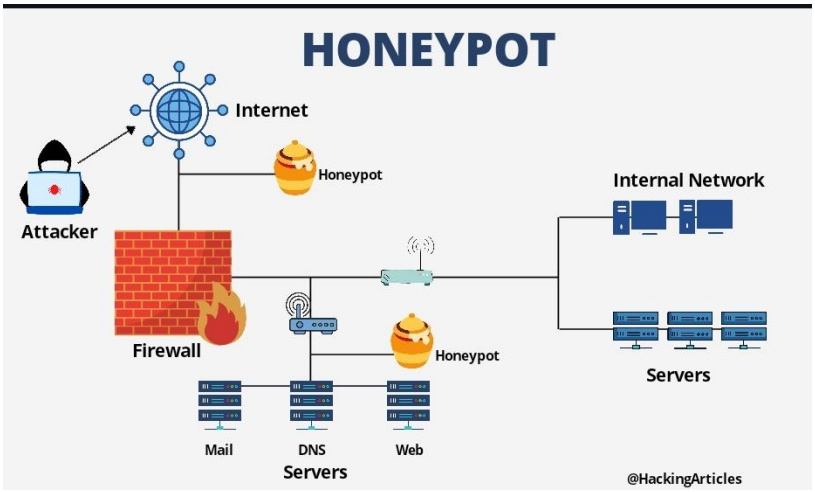
Honeypots

Introduction

- Honeypots are a type of security tool that simulate vulnerable systems or applications to attract attackers and gather information about their techniques and motives.
- Honeypots are a crucial tool for modern-day cybersecurity.
- Honeypots can provide valuable insights into attacker behavior and help improve overall security posture.

Types of Honeypots

- **Production honeypots:** Real systems or applications that are deployed to gather information about attackers.
- **Research honeypots:** Simulated systems or applications that are deployed in a controlled environment to gather research data about attacker behavior.



Advantages of Honeypots

- Provides early warning of potential attacks, allowing for quick detection and response.
- Can gather valuable intelligence about attacker techniques, tactics, and motives.
- Helps identify vulnerabilities in systems or applications that can be remediated to improve overall security posture.
- Can divert attackers away from real systems and applications, reducing the risk of successful attacks.

Disadvantages of Honeypots

- **False positives**: Honeypots can generate false alarms, which can lead to unnecessary investigations and waste of resources.
- **Security risks**: Honeypots can be compromised by attackers, potentially exposing sensitive information or systems.
- **Maintenance overhead**: Honeypots require regular maintenance and updates, which can be resource-intensive.

Honeypot Deployment Strategies

- **Low interaction honeypots**: Simulate only the most basic functionality of a system or application, providing limited interaction with attackers.
- **Medium interaction honeypots**: Simulate more functionality of a system or application, allowing attackers to interact with them more fully.
- **High interaction honeypots**: Provide a full simulation of a real system or application, allowing attackers to interact with it as if it were real.

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Honeypot Tools

Examples of honeypot tools include:

- **KFSensor**: A Windows-based honeypot that simulates vulnerable services and applications.
- **Honeyd**: A customizable honeypot that can simulate multiple operating systems and services.
- **Cowrie**: A high-interaction honeypot that simulates a full SSH environment.

Conclusion

- Honeypots are a crucial tool for modern-day cybersecurity, providing valuable insights into attacker behavior and improving overall security posture.
- Honeypots can be deployed in different ways, with advantages and disadvantages for each deployment strategy.
- Honeypot tools, such as KFSensor, Honeyd, and Cowrie, are available as open-source solutions or as part of commercial cybersecurity solutions.

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Week#6

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)

This document is available on studocu

Downloaded by Haseeb Saleem (haseebsaleem312@gmail.com)